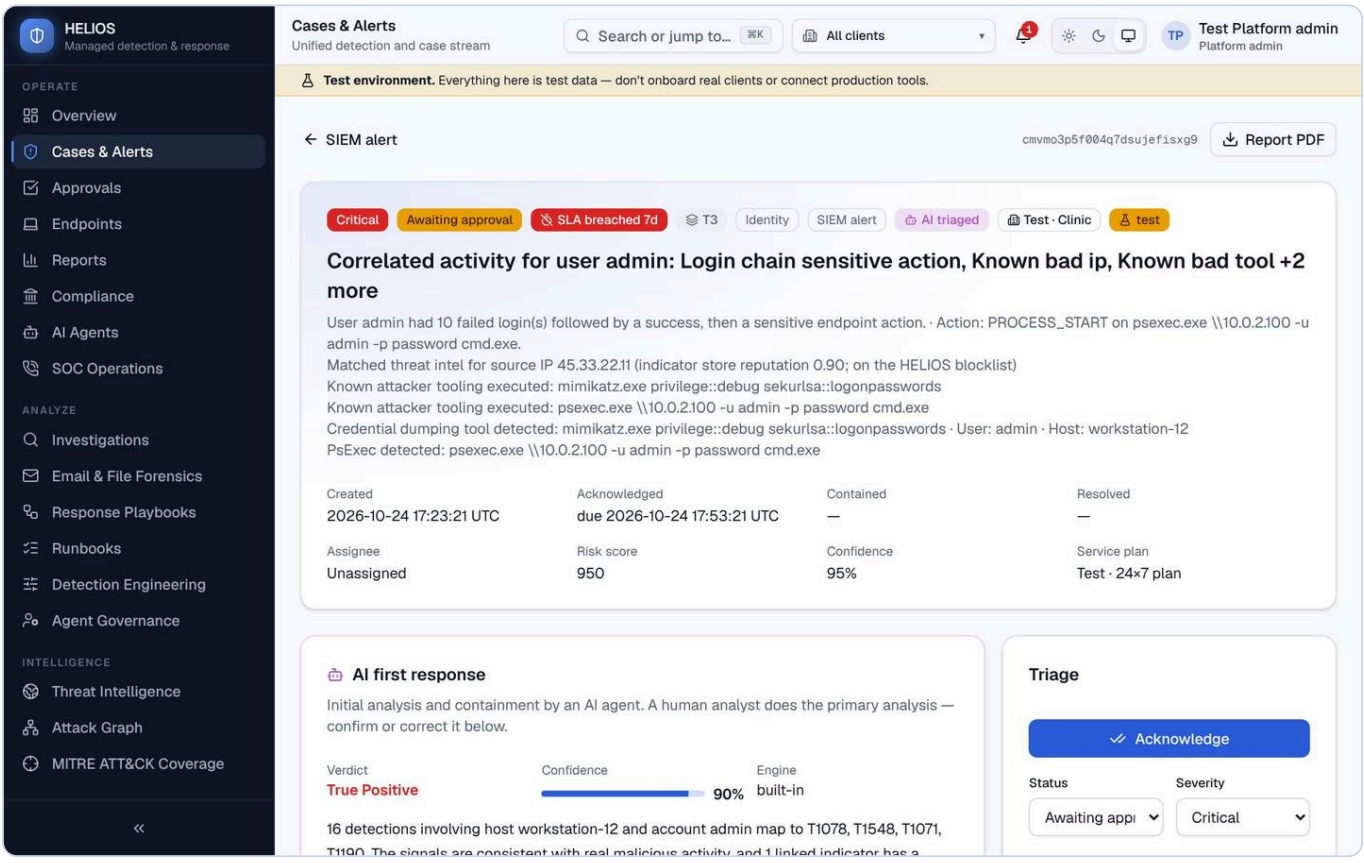
PRODUCT GUIDE AND DOCUMENTATION

HELIOS

Managed detection and response for a security company that protects many clients: one case queue, AI first responders that act only within each client's signed rules, and analysts who stay in charge.



Edition	31 October 2026 · written against HELIOS 4c7e30d
Contents	Part 1: the product at a glance. Part 2: getting started, how it works, roles and access, every screen, procedures, guidelines and reference.
Screenshots	Taken in the HELIOS test environment with test data.

Contents

1. **Part 1: HELIOS at a glance**
   - What HELIOS is
   - How it works
   - What it does
   - Built to be trusted
   - Who uses it
2. **Part 2: Documentation**
   - 1. Getting started
   - 2. How HELIOS works
   - 3. Roles and access
   - 4. Screen by screen
   - 5. Procedures
   - 6. Guidelines
   - 7. Reference

PART 1

HELIOS at a glance

What HELIOS is, how it works, what it does, and why it can be trusted with a client's estate.

What HELIOS is

HELIOS runs a security operations centre (SOC) for many client organisations at once. Each client's security tools stream their alerts and logs into one place; HELIOS turns them into cases; AI agents do the first analysis and propose containment; analysts confirm, investigate and decide; and everything that happens on a client's estate follows the rules that client has signed.

It is built for a managed security service provider (MSSP) of modest size: the platform covers the SOC's daily work, the client relationship (portal, approvals, reports), regulatory reporting in India (CERT-In, DPDP), and the business side (quotes, pilots, contracts, GST invoices).

11
roles, from tier-1 analyst to the client's own administrator

9
vendor log collectors, plus a push URL and a signed forwarder

11
built-in detectors, plus Sigma rules tested before they go live

7
native response connectors acting through the client's own tools

4
kinds of AI provider: Anthropic, Amazon Bedrock, Azure OpenAI, local models

6 h
CERT-In clock, with the report drafted from the case

180 days
minimum log retention where CERT-In applies, kept in India

1
hash-chained audit trail of every action

The problem it solves

- Alerts arrive from dozens of tools across many clients, in different formats, faster than a small team can read them.
- Automation helps only if each client can trust it: what it may touch, when, and who says yes.
- Clients need to see what was done for them, approve what matters, and meet their regulators' clocks.

The HELIOS answer

- **One queue** for every source, with related alerts correlated into one case and SLA clocks from the client's plan.
- **AI first responders** that triage every case, cite their evidence, and propose containment that a deterministic policy then decides.
- **The client's rulebook**, signed by the client, binding the AI, playbooks and people alike.
- **A client portal** for incidents, approvals, reports, the rulebook and the contract.

How it works

A case's life, from the first log line to the report. Every step is recorded in the audit trail.

Collect 1
Logs and alerts arrive by push, by HELIOS pulling the vendor's API, or through the signed forwarder.

Normalize 2
Every event is stored once in OCSF form, with its addresses' country, city and network.

Detect 3
Built-in detectors and tested Sigma rules run over each batch and the last 24 hours.

Correlate 4
Findings for the same user, host or IP join one case; severity only ratchets up.

Triage 5
An AI agent analyses the case, cites evidence, and proposes containment.

Decide 6
A fixed stack of rules (kill switch, plan, consent, rulebook, autonomy, evaluation, rate limit) decides.

Act 7
Connectors act through the client's tools and count an action only once the vendor confirms it.

Report 8
Analysts close with a disposition; clients get reports, digests and regulatory notices.

People stay in charge

- The AI proposes; a deterministic policy decides; people approve what the client's rules say they must.
- Autonomy is earned per client and per action: new clients start in shadow mode, where the AI's proposals are only recorded and scored against what analysts did.
- The kill switch stops all AI action at once.

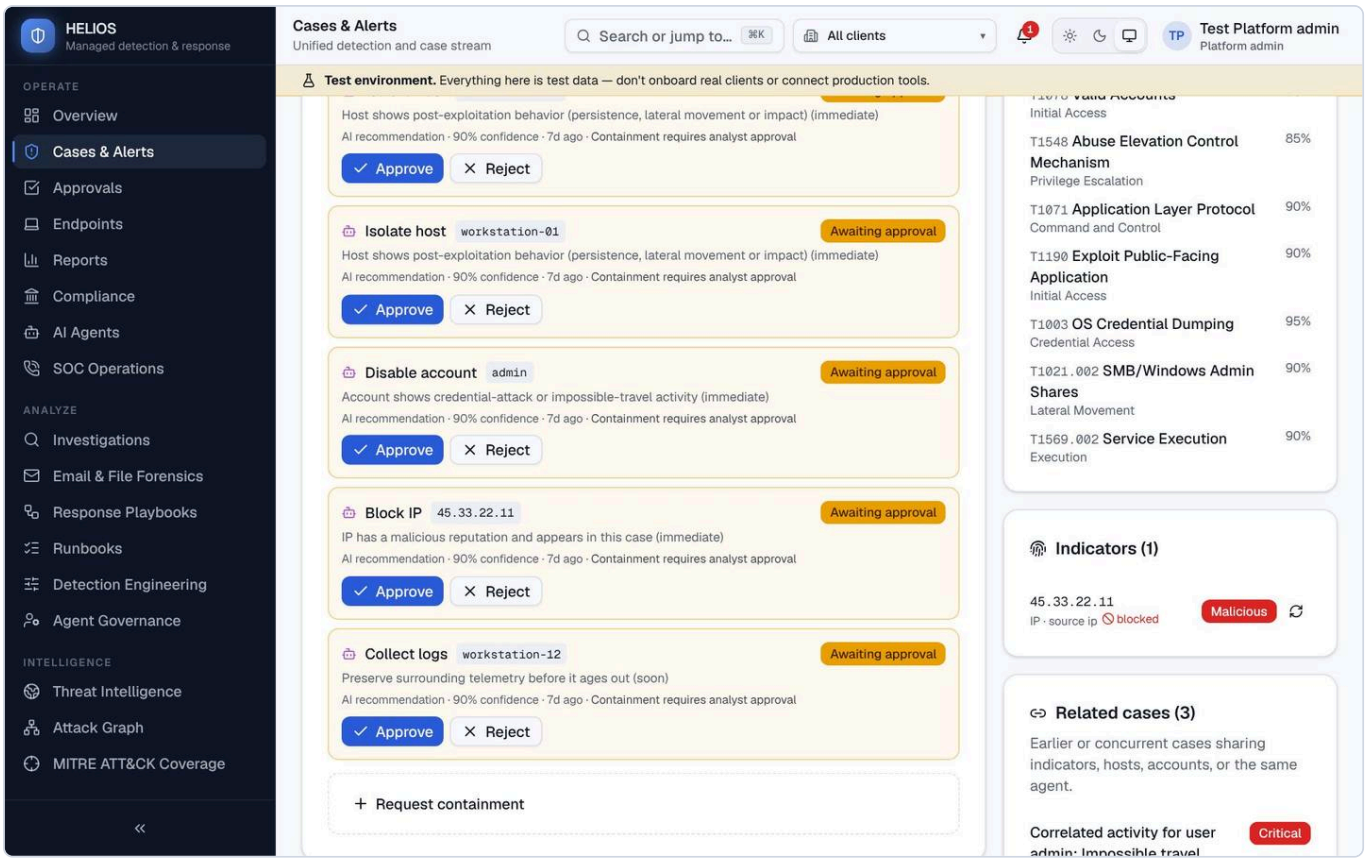


Figure 1. AI first response and response actions on a case: verdict, cited evidence, and containment awaiting approval.

What it does

Cases and alerts

One queue for every source, with tier 1-3 escalation, assignment, watchers, @mentions, internal or client-visible discussion, SLA clocks and correlation of related alerts.

Log collection

Push, pull from nine vendor APIs, or a signed Fluent Bit forwarder; a durable queue that takes clients in turn; OCSF storage; dead-letter replay; quiet sources open cases.

Detection engineering

Eleven built-in detectors; Sigma rules compiled, backtested, run in testing, then made live; tuning per client with reasons and expiry.

AI first responder

Triage, phishing, threat-intel and investigation agents with cited evidence, grounding, prompt-injection defences and model evaluations.

Response actions

Defender for Endpoint, Entra ID, Exchange Online, CrowdStrike, SentinelOne, Okta and Cloudflare, or a signed webhook; dry run, rollback, time-boxing, circuit breaker.

Client rulebooks

Protected assets and accounts, action modes, blast radius, business hours, approver chains and AI data handling, signed by the client, with a dry run.

Approvals and alerts

One inbox for held containment, playbooks, notices and rulebooks; alerts by email, SMS and WhatsApp; approver chains that contact people in turn.

Regulatory reporting

CERT-In's 6-hour report and DPDP breach notices drafted from the case, approved by the client, filed and recorded; ISO 27001 evidence map.

Data retention

Per-client searchable and kept periods, an encrypted archive in India, legal holds, and monthly partitions dropped whole when past retention.

SOC operations

On-call rota with escalating pages and handoffs, runbooks worked as checklists, weekly QA of what the AI did alone, daily digests.

Investigations and forensics

Upload logs for a root-cause pipeline; analyse emails and files (headers, links, macros, archives, QR codes, detonation).

Threat intelligence

A shared indicator store with feeds and providers, a blocklist, and IP locations; an attack graph that finds chains across cases.

Build and Price

Quote a client's stack across every protection layer with an advisor, an upgrade review and a solution design; save versioned quotes.

Contracts and billing

Pilots measured from HELIOS's own records, contracts signed in the app, and GST invoices numbered per financial year.

Agent governance

Govern the AI agents clients run: identities, policy checks before every action, trust, and revocation.

Platform

Two-step sign-in, single sign-on, database-enforced client isolation, per-client encryption keys, REST API, installable app.

Built to be trusted

The client's rules bind everyone

A signed, versioned rulebook decides what may happen on the client's estate. Rules only ever restrict. Hard rules (never-isolate assets, protected accounts, forbidden actions, the two-person rule) bind analysts too, and are re-checked at the moment of acting.

Evidence, not assertions

Every AI finding cites the evidence it rests on. A grounding check drops claims and containment targets the evidence doesn't contain.

Attacker text is treated as attacker text

Command lines, emails and file names are scanned for text aimed at the AI, escaped and fenced off; a fooled model can't downgrade a case, and anything proposed from steered evidence waits for a person.

Autonomy is earned

Per client and per action: shadow mode first, promotion only on a clean record and the client's approval, automatic demotion after a bad week or a critical mistake, weekly QA by people.

Actions are real or they don't count

A connector checks the target first, acts with an idempotency key, and reads the vendor's state back. Until the vendor confirms, an action is in progress and doesn't count as containment.

Each client's data stays theirs

Client isolation is enforced by the database itself; each client's credentials are sealed with its own key, which can be destroyed at offboarding; logs can be kept in India.

Everything is on the record

A hash-chained audit trail: changing or deleting any entry breaks every hash after it, and a check names the first altered entry.

Your choice of AI

Claude through Anthropic or the client's own AWS account, Azure OpenAI, or a local model on the client's own hardware; a model acts on its own only after passing HELIOS's evaluation.

Who uses it

Eleven roles: nine for the MSSP's own people and two for each client's. Each person has one role, which decides every page, button and API call they can use.

Platform admin · Leadership

Owns the platform: users, AI configuration, price book, everything else.

SOC manager · Leadership

Runs the SOC: every queue, approvals, AI autonomy, tool onboarding.

Tier-1 triage analyst · Security operations

Works the first-line queue: acknowledges, validates AI triage, escalates.

Tier-2 security analyst · Security operations

Primary analysis: investigations, forensics, containment requests.

Tier-3 incident responder · Security operations

Owns major incidents: approves containment, isolates endpoints, client comms.

Threat hunter · Security operations

Hunts across all tenants with investigations, forensics and intel.

Detection engineer · Engineering

Maintains playbooks, detections, tool integrations and ATT&CK coverage.

Auditor / compliance · Governance

Read-only oversight: cases, AI decisions and the audit chain.

Account manager · Commercial

Client onboarding, Build & Price quotes and margins.

Client admin · Client

Client-side: their own tenant's cases and tools; approves containment on their estate.

Client stakeholder · Client

Client-side read-only: dashboards, incident reports and endpoint coverage.

PART 2

Documentation

Getting started, how HELIOS works, roles and access, every screen, procedures, guidelines and reference.

1. Getting started

1.1 Install and run

HELIOS is a Next.js application on PostgreSQL 16. For a first installation:

```
docker compose up -d              # or any Postgres 16; point DATABASE_URL at it
cp .env.example .env              # set AUTH_SECRET (and HELIOS_ENCRYPTION_KEY in production)
npm install
npm run db:migrate                # applies the database migrations
npm run db:seed                   # first admin and reference facts
npm run build && npm start
```

The seed creates the first platform admin (admin@helios.local by default) and prints a password once unless SEED_ADMIN_PASSWORD is set. Background work (the ingest queue, collectors, regulatory clocks, paging, retention) runs in the web process, or separately with `npm run worker` when `HELIOS_INGEST_WORKER=external` is set.

1.2 First-run set-up

Sign in as the admin, fill in Settings (your company details go on quotes, reports and invoices), then work through the Get HELIOS ready checklist on the Overview:

1. Define service plans and fill in the price book (Build & Price → Pricing setup).
2. Connect an AI provider (AI Agents), or leave agents on the built-in engine for now.
3. Invite your team (Team & Roles).
4. Add clients (Clients).
5. Onboard their tools (Tools & Integrations).
6. Enable threat feeds (Threat Intelligence).

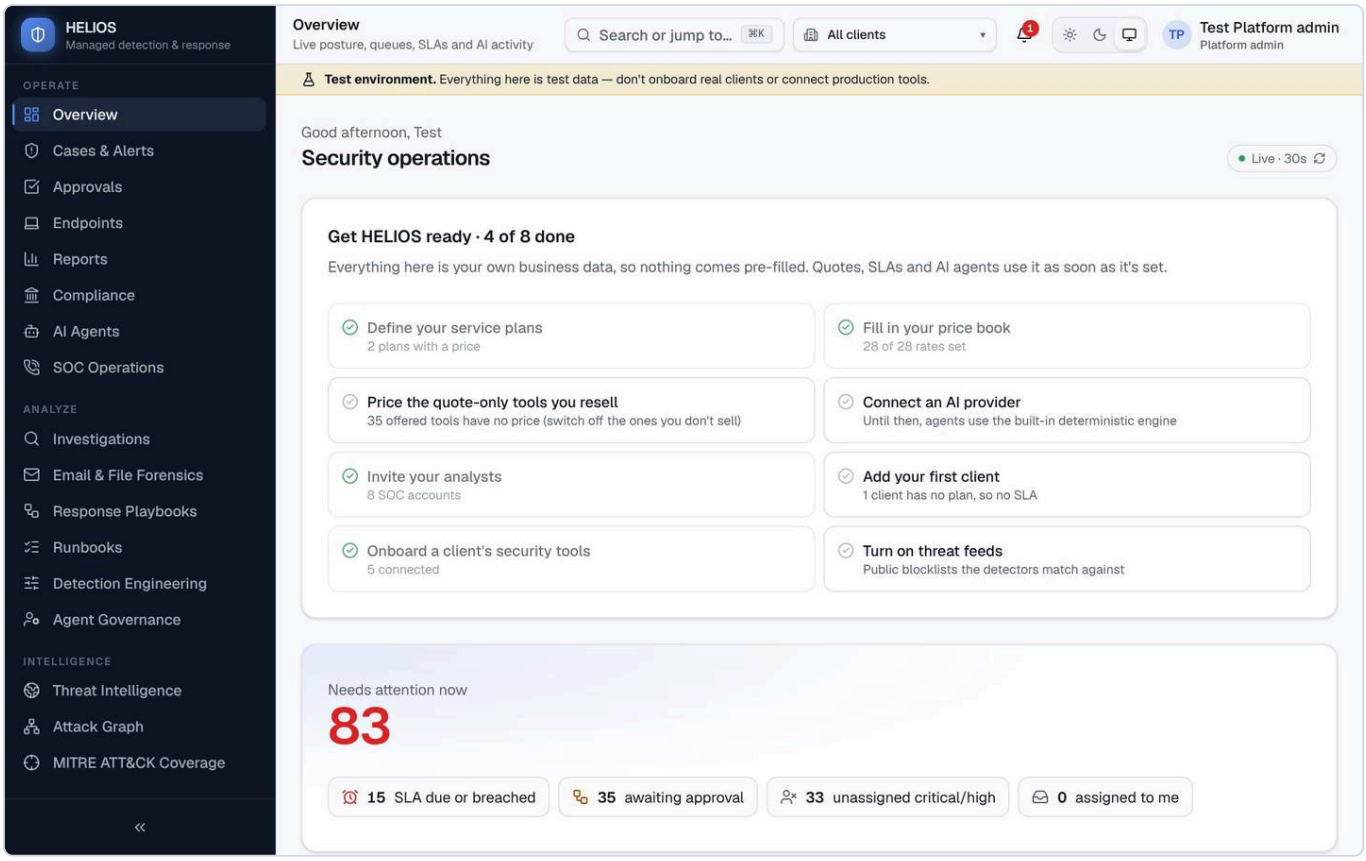


Figure 2. The Overview, with the first-run checklist and what needs attention now.

1.3 Signing in

1. Sign in with your email and password. A new account gets a temporary password from its administrator.
2. If two-step sign-in is required, set it up the first time: scan the code with an authenticator app, enter a code, and keep the ten recovery codes somewhere safe. Each recovery code works once.
3. Staff can sign in with the organisation's identity provider when single sign-on is set up; it satisfies two-step sign-in.
4. Five wrong passwords or codes in a row lock the account for 15 minutes. An administrator can reset a password or two-step sign-in.

1.4 Finding your way

- **Sidebar**: your pages, grouped as Operate, Analyze, Intelligence, Platform and Commercial. You only see the pages your role allows.
- **Search or jump to** (Ctrl K or Cmd K): find a case, page or client.
- **Client switcher** (staff): All clients, or focus every page on one client.
- **The bell**: notifications (mentions, hand-offs, approvals, pages). Choose which also arrive by email, SMS or WhatsApp under My alerts.
- **Theme** (light, dark or system) and the **user menu**: My alerts, two-step sign-in, Sign out.
- A yellow **Test environment** banner means everything on that installation is test data.
- HELIOS installs from the browser as a desktop or mobile app.

2. How HELIOS works

The methods behind each stage, in plain terms: what HELIOS does, in what order, and what it will and won't do on its own.

2.1 Collecting logs

- **Three ways in, one queue.** A tool pushes to its own ingest URL with its token; HELIOS pulls from the vendor's API with the client's read-only credentials (Entra ID, Defender XDR, CrowdStrike, SentinelOne, Okta, Google Workspace, AWS CloudTrail, Azure Activity Log, Google Cloud audit logs); or the HELIOS forwarder (a signed Fluent Bit configuration) sends syslog, Windows event logs and files.
- **A durable queue.** The edge only authenticates and stores the batch. Workers take clients in turn, so one noisy client can't starve the others; failed batches retry, then wait in a dead-letter queue for replay.
- **One form.** Every event is stored once in OCSF 1.9 form; a resend is recognised by its source event id and dropped.
- **Where addresses are.** With a GeoIP database on the server, each event gets the country, city and network of its addresses. No lookup leaves the machine.
- **Silence is a signal.** A source quiet for longer than its limit opens a case of its own, because attackers often stop logging first.

2.2 Detecting and correlating

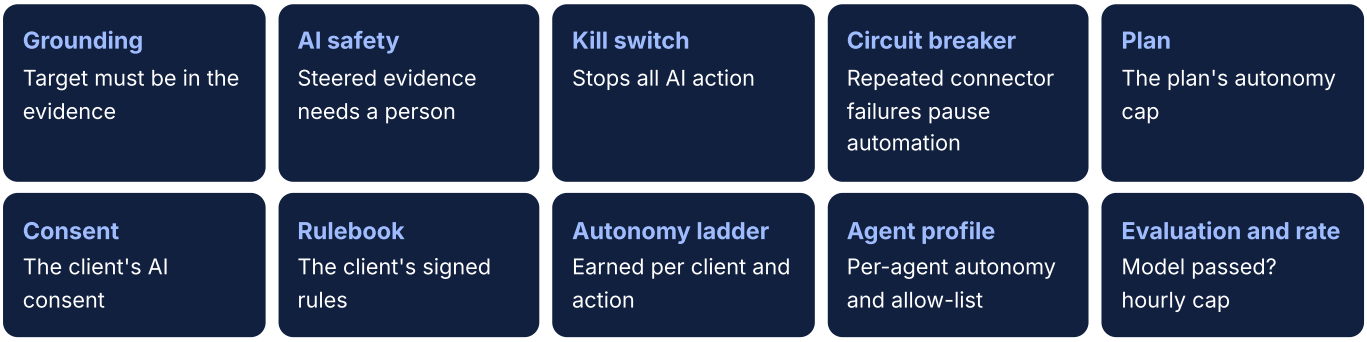
- **Detect.** Eleven built-in detectors (impossible travel, failed-then-successful logins leading to sensitive actions, credential dumping, lateral movement, exfiltration, persistence, defence evasion, ransomware impact, threat-intel matches…) run over each batch plus the last 24 hours. Active Sigma rules run too.
- **Score.** Each finding's confidence and signal family set a risk score, which maps to a severity.
- **Tune.** The client's tuning (detectors switched off there, known-good exclusions, severity overrides) applies, and what it held back is counted.
- **De-duplicate and correlate.** A finding already on file is never filed again. Fresh findings for the same user, host or IP join an open case from the last 24 hours, whose severity only ratchets up; otherwise a new case opens with the client's SLA clock.

2.3 AI first response

- **The agents.** The triage first responder runs on every new case at or above a severity. Analysts can dispatch the phishing analyst, the threat-intel enricher, the investigation agent (which searches the client's telemetry with read-only tools) and the client report writer.
- **Evidence first.** The case is rendered as numbered evidence (D detections, E events, I indicators, T timeline, C context). The agent must cite it; a grounding check drops claims and containment targets the evidence doesn't contain.
- **Attacker text.** Evidence is treated as written by the attacker: text addressing the AI is flagged, escaped and fenced off. A benign verdict on high-severity or steered evidence is held for a person.
- **Models.** Claude through Anthropic's API or Amazon Bedrock, Azure OpenAI, or a local model (Ollama, vLLM, the HELIOS AI box). Each client's rulebook decides which may read its evidence; personal data can be masked before a cloud model sees it. Without a model, a deterministic built-in engine does the work.
- **Evaluation.** A model is scored on a labelled set (attacks, benign activity, look-alikes, planted instructions) through the same pipeline; the investigation agent is scored on what it finds in seeded worlds. A model a client picks only suggests until it passes.

2.4 Deciding what happens

Every proposed action, from the AI, a playbook or a person, goes through the response policy: a fixed stack of layers where the most restrictive wins, and every decision records which rule decided.



- **Outcomes.** Executed, pending approval, suggested only, or blocked, with the reason.
- **Approvals.** Held actions wait in Approvals; the client's approver chain is contacted in turn (in the app, Slack or Teams, email, SMS, WhatsApp). Two-person actions need two different approvers. When the chain runs out, the action holds or becomes a suggestion, as the rulebook says.
- **The autonomy ladder.** Per client and per action type: L0 observe (shadow mode), L1 suggest, L2 approve, L3 act and notify, L4 act. Promotion needs at least 20 scored decisions in 30 days with 90% agreement, at most 2% wrong containment and none on a critical asset, and the client's approval. A week below 80% drops a level; a critical mistake drops to suggestions.

2.5 Acting

- **Native connectors** act with the client's own least-privilege credentials: Defender for Endpoint (isolate, release, investigation package, file and IP indicators), Entra ID (disable, enable, password reset), Exchange Online (purge a message), CrowdStrike (contain, release, file block), SentinelOne (disconnect, reconnect, file block), Okta (suspend, unsuspend), Cloudflare (block an IP).
- **One contract.** Preflight (the target exists, isn't ambiguous, isn't already in that state), execute (with an idempotency key), verify (read the vendor's state back). Unconfirmed means in progress, never contained.
- **No connector?** A signed webhook to the client's automation, or the action is left to do by hand and counts only once an analyst records it.
- **Safety.** Dry-run mode first; rollback for every containment; IP blocks and account disables can be time-boxed; repeated failures pause automation for that client and page the on-call analyst.

2.6 SOC operations

- **On call.** A rota of primary and backup shifts. Unacknowledged critical cases page the primary, then the backup after 15 minutes, then the SOC managers, by SMS, email and in the app. Each shift starts with a handoff.
- **Runbooks.** Procedures that attach themselves to matching cases (by ATT&CK technique or title words) and are worked as checklists; a true positive can't close with a required step open.
- **QA of the AI.** Each Monday a weighted sample of last week's autonomous actions and benign verdicts goes to people for review; a wrong call counts against the AI at once.
- **Digests.** Once a day, each client's admins and the SOC get what HELIOS did on its own, what is waiting, and the deadlines coming up.

2.7 Compliance and data

- **CERT-In.** Incidents of the 20 listed types are reported within 6 hours of being noticed. HELIOS proposes the type from the case, opens the clock at the client's threshold, drafts the report, gets the client's approval, and emails or records the filing; reminders go at half time, in the last sixth and when overdue.

- **DPDP.** The Data Protection Board and each affected person are told without delay, and the Board gets a detailed report within 72 hours.
- **ISO 27001.** An evidence map of 15 Annex A controls from what HELIOS's records show, with gaps shown plainly.
- **Retention.** Searchable then archived (compressed, encrypted with the client's own key, hash-checked) and deleted at the end; at least 180 days where CERT-In applies; legal holds stop deletion; whole months are dropped once past every client's retention.

2.8 Securing the platform

- **Sign-in.** Two-step sign-in (authenticator app and recovery codes) required for staff or everyone; single sign-on for staff; lockout after five failures.
- **Isolation.** Postgres row-level policies confine client sessions and API tokens to their own organisation, even if a query forgets its filter.
- **Encryption.** Each client has its own data key, wrapped by the master key (or AWS KMS); its credentials and AI keys are sealed with it; destroying it makes them unreadable for good.
- **Audit.** Every action is appended to a hash-chained trail that can be verified and exported.
- **API.** Personal tokens act as their owner, read-only unless created with write, with expiry and revocation; 300 requests a minute per token.

2.9 The business side

- **Build and Price.** A client's estate (endpoints by OS, cloud, network, identities, IoT/OT, applications) and stack per layer; an advisor for best value, lowest cost or strongest protection; an upgrade review against what the client has; a solution design; versioned quotes without cost or margin.
- **Pilots and contracts.** Pilots measured from HELIOS's own records; contracts that snapshot the AI autonomy agreed and the rulebook in force, signed in the app by the client's admin.
- **Invoices.** Drafted each billing period, numbered per Indian financial year, with CGST and SGST or IGST by place of supply; paid, voided, chased and renewed.

3. Roles and access

Every person has one role. The role decides every page, button and API call; HELIOS checks it on the server for each request, and a change of role applies on the person's next click. Hiding a button is only a convenience.

- **Client users** (client admin, client stakeholder) see their own organisation only, enforced by the database itself.
- **Staff** work across clients; the client switcher focuses every page on one.
- **Security domains** (endpoint, email, identity, network, cloud, AI agents) can limit an analyst to those queues; roles with every-queue access ignore them.

3.1 The roles

Platform admin · Leadership · 50 permissions

The person who owns the HELIOS platform for the MSSP: accounts and roles, platform settings, AI configuration, the price book and every client's set-up. There should be few of them, and each should also hold a day-to-day role account for ordinary work.

Responsible for: Set up and maintain the platform: environment, company profile, provider keys, alert channels and sign-in security; Manage accounts: invite people, give them the right role and queues, deactivate leavers at once, reset two-step sign-in; Own the commercial reference data: service plans, the price book, exchange rates; Configure AI: providers, agent profiles, autonomy, the kill switch, and evaluations before a model acts on its own; Look after client data: retention periods, legal holds, data keys (rotation, destruction at offboarding); Keep the audit chain intact and exportable for auditors and regulators.

Pages: Overview, Cases & Alerts, Approvals, Endpoints, Reports, Compliance, AI Agents, SOC Operations, Investigations, Email & File Forensics, Response Playbooks, Runbooks, Detection Engineering, Agent Governance, Threat Intelligence, Attack Graph, MITRE ATT&CK Coverage, Tools & Integrations, Rulebooks, Clients, Team & Roles, Data Retention, Audit Log, API Tokens, Settings, Build & Price, Contracts & Billing.

Turn to: Security concerns about the platform itself go to your security lead; client-facing incidents go to the SOC manager on duty.

SOC manager · Leadership · 46 permissions

The person who runs the security operations centre day to day: every queue, approvals, AI autonomy, the on-call rota and the quality of the work.

Responsible for: Keep every queue moving within SLA; assign and re-assign work; step in on critical cases; Approve or reject containment the policy holds, and decide on promotions of the AI's autonomy with clients; Run the on-call rota and make sure pages are answered; Review the weekly QA sample of what the AI did on its own, and act on what it finds; Onboard clients' tools with the detection engineer, and draft rulebooks with clients; Oversee regulatory clocks (CERT-In, DPDP) and the daily digests.

Pages: Overview, Cases & Alerts, Approvals, Endpoints, Reports, Compliance, AI Agents, SOC Operations, Investigations, Email & File Forensics, Response Playbooks, Runbooks, Detection Engineering, Agent Governance, Threat Intelligence, Attack Graph, MITRE ATT&CK Coverage, Tools & Integrations, Rulebooks, Clients, Data Retention, Audit Log, API Tokens, Settings, Build & Price, Contracts & Billing.

Turn to: Platform problems go to the platform admin; client relationship matters go to the account manager; major incidents are led by a tier-3 incident responder.

Tier-1 triage analyst · Security operations · 18 permissions

The first line: you take new cases, check what the AI made of them, close the noise and pass the real ones on with what you found.

Responsible for: Acknowledge new cases in your queues within the SLA; Check the AI's first response: agree or disagree, and say why when it's wrong; Validate the evidence; close false positives with a disposition and a reason; Escalate real or unclear cases to tier 2 with a clear note; request containment where it's needed; Page on-call for anything urgent you can't move.

Pages: Overview, Cases & Alerts, Endpoints, Compliance, AI Agents, SOC Operations, Response Playbooks, Runbooks, Threat Intelligence, Attack Graph, MITRE ATT&CK Coverage, Tools & Integrations, Rulebooks, Clients.

Turn to: Escalate cases to tier 2; ask the SOC manager on duty about anything in the queue itself; page on-call for urgent help.

Tier-2 security analyst · Security operations · 28 permissions

Tier 2: the primary analysis of real cases, investigations and forensics, containment requests, and keeping the client informed.

Responsible for: Investigate escalated cases fully: scope, root cause, affected hosts and accounts; Run log investigations and email and file forensics; Request containment, including email purges, password resets and investigation packages; Share cases and publish reports to the client; prepare regulatory notices; Maintain the indicator store and blocklist; govern clients' AI agents.

Pages: Overview, Cases & Alerts, Endpoints, Reports, Compliance, AI Agents, SOC Operations, Investigations, Email & File Forensics, Response Playbooks, Runbooks, Agent Governance, Threat Intelligence, Attack Graph, MITRE ATT&CK Coverage, Tools & Integrations, Rulebooks, Clients, API Tokens.

Turn to: Major incidents go to tier 3 (incident responder); ask the threat hunter for wider campaigns; tuning requests go to the detection engineer.

Tier-3 incident responder · Security operations · 33 permissions

Tier 3: you own major incidents end to end: containment decisions, isolating endpoints, client communication, regulatory reporting, and the review afterwards.

Responsible for: Lead major incidents and coordinate the people working them; Approve or reject containment; isolate and release endpoints directly; Communicate with the client's people during an incident; Prepare and file regulatory notices with the client's approval; Maintain the on-call rota and runbooks with the SOC manager; review the AI's QA sample.

Pages: Overview, Cases & Alerts, Approvals, Endpoints, Reports, Compliance, AI Agents, SOC Operations, Investigations, Email & File Forensics, Response Playbooks, Runbooks, Agent Governance, Threat Intelligence, Attack Graph, MITRE ATT&CK Coverage, Tools & Integrations, Rulebooks, Clients, API Tokens.

Turn to: Escalate business decisions to the SOC manager and the client; platform problems to the platform admin.

Threat hunter · Security operations · 21 permissions

You look for what the detectors didn't catch, across every client: campaigns, shared infrastructure, quiet intrusions.

Responsible for: Hunt across all clients' cases and telemetry for patterns the detectors missed; Run investigations and forensics on what you find; Maintain the indicator store, the blocklist and threat feeds; Hand what you find to the analysts (escalate) and to the detection engineer (new rules).

Pages: Overview, Cases & Alerts, Endpoints, AI Agents, SOC Operations, Investigations, Email & File Forensics, Response Playbooks, Runbooks, Threat Intelligence, Attack Graph, MITRE ATT&CK Coverage, Tools & Integrations, Rulebooks, Clients, API Tokens.

Turn to: Hand cases to tier 2 or tier 3; rule ideas to the detection engineer.

Detection engineer · Engineering · 20 permissions

You maintain how HELIOS sees and responds: tool integrations and log collection, detectors and Sigma rules, per-client tuning, playbooks, and ATT&CK coverage.

Responsible for: Onboard clients' security tools: log collection (push, pull, forwarder) and response connectors; Keep sources healthy; replay what landed in the dead-letter queue; Import, test and publish Sigma rules; tune detections per client; Author and maintain response playbooks; Draft rulebook changes with the SOC manager and the client.

Pages: Overview, Cases & Alerts, Endpoints, AI Agents, SOC Operations, Response Playbooks, Runbooks, Detection Engineering, Threat Intelligence, Attack Graph, MITRE ATT&CK Coverage, Tools & Integrations, Rulebooks, Clients, API Tokens.

Turn to: Ask the SOC manager before changes that affect every client; ask the platform admin for provider keys and platform settings.

Auditor / compliance · Governance · 17 permissions

Read-only oversight: you review cases, AI decisions, rulebooks, retention and the audit chain, for internal audit, compliance or a regulator.

Responsible for: Verify the audit chain and export it for review; Review how cases were handled and what the AI decided, and why; Review compliance evidence (CERT-In, DPDP, ISO 27001 mapping) and data retention.

Pages: Overview, Cases & Alerts, Endpoints, Reports, Compliance, AI Agents, SOC Operations, Response Playbooks, Runbooks, Threat Intelligence, Attack Graph, MITRE ATT&CK Coverage, Tools & Integrations, Rulebooks, Clients, Data Retention, Audit Log, API Tokens.

Turn to: Report findings to the SOC manager and the platform admin, or as your audit charter says.

Account manager · Commercial · 10 permissions

The account manager: you onboard clients commercially: quotes, pilots, contracts and invoices, and the client's first rulebook.

Responsible for: Build quotes in Build & Price and send them; Run pilots against their measured success criteria and convert them; Draft, send and record contracts; issue invoices and record payments; Create client records and help draft their first rulebook.

Pages: Overview, Tools & Integrations, Rulebooks, Clients, Build & Price, Contracts & Billing.

Turn to: Technical questions go to the SOC manager or detection engineer; price-book changes to the platform admin.

Client admin · Client · 15 permissions

The administrator on the client's side: you see your organisation's incidents, approve containment on your estate, sign the rules HELIOS works under, and look after your security tools and contracts.

Responsible for: Approve or reject containment on your estate when the SOC or the AI asks; Own your rulebook: protected assets and accounts, what may happen automatically, approvers; sign each version; Approve regulatory notices (CERT-In, DPDP) before the SOC files them; Keep your security tools connected; decide which AI models may read your data; Sign contracts and keep track of invoices.

Pages: Overview, Incidents, Approvals, Endpoints, Service reports, Compliance, Attack Graph, Security tools, Our rulebook, API Tokens, Contracts & invoices.

Turn to: Ask the SOC in the incident's discussion; for contract matters, contact your account manager.

Client stakeholder · Client · 6 permissions

A stakeholder on the client's side (a manager, an executive, an IT lead): you read your organisation's incidents, reports and coverage.

Responsible for: Keep informed of incidents affecting your organisation; Read the monthly service reports and endpoint coverage; Know the rules HELIOS works under on your estate.

Pages: Overview, Incidents, Endpoints, Service reports, Compliance, Attack Graph, Our rulebook.

Turn to: Questions about an incident go to your client admin, who can raise them with the SOC.

3.2 Who can do what

● the role has the permission · · it doesn't. Taken from the role definitions in HELIOS itself.

Permission	Admin	SOC manager	Tier 1	Tier 2	Tier 3	Hunter	Detection eng.	Auditor	Account mgr	Client admin	Client viewer
Cases											
See the overview dashboard	●	●	●	●	●	●	●	●	●	●	●
See cases in their queues (or their own tenant, for clients)	●	●	●	●	●	●	●	●	·	●	●
See every queue, regardless of assigned security domains	●	●	·	·	●	●	●	●	·	·	·
Acknowledge cases, change status and severity	●	●	●	●	●	·	·	·	·	·	·
Assign cases to other analysts	●	●	·	●	●	·	·	·	·	·	·
Escalate or hand off a case to the next tier	●	●	●	●	●	●	·	·	·	·	·
Comment on cases and @mention teammates	●	●	●	●	●	●	●	·	·	●	·
Share cases with the client and external channels	●	●	·	●	●	·	·	·	·	·	·
Response											
Run containment playbooks (subject to approval)	●	●	●	●	●	·	·	·	·	·	·
Approve or reject pending containment	●	●	·	·	●	·	·	·	·	●	·
Isolate and release endpoints directly	●	●	·	·	●	·	·	·	·	·	·
Analysis											
Run log investigations	●	●	·	●	●	●	·	·	·	·	·
Submit emails and files for forensic analysis	●	●	·	●	●	●	·	·	·	·	·
Upload raw logs into the detection pipeline	●	●	·	●	●	●	●	·	·	·	·
Govern AI agents: identities, tokens, revocation	●	●	·	●	●	·	·	·	·	·	·
Intelligence and detection											
Look up threat indicators	●	●	●	●	●	●	●	●	·	·	·
Edit the blocklist and indicator store	●	●	·	●	●	●	·	·	·	·	·
See ATT&CK coverage	●	●	●	●	●	●	●	●	·	·	·
Switch SIEM detectors on and off	●	●	·	·	·	·	●	·	·	·	·
See response playbooks	●	●	●	●	●	●	●	●	·	·	·
Author and enable response playbooks	●	●	·	·	·	·	●	·	·	·	·
AI agents											
See AI agent runs and configuration	●	●	●	●	●	●	●	●	·	·	·
Dispatch AI agents onto a case	●	●	●	●	●	●	●	·	·	·	·
Rate AI agent output	●	●	●	●	●	●	·	·	·	·	·
Configure AI providers, agent profiles and autonomy	●	●	·	·	·	·	·	·	·	·	·

Tools and endpoints											
See onboarded security tools	●	●	●	●	●	●	●	●	●	●	·
Onboard and configure security tools	●	●	·	·	·	·	●	·	·	●	·
See the endpoint inventory and protection coverage	●	●	●	●	●	●	●	●	·	●	●
Clients and rulebooks											
See client tenants	●	●	●	●	●	●	●	●	●	·	·
Create and edit client tenants	●	●	·	·	·	·	·	·	●	·	·
Read a client's rulebook: what HELIOS may do on its estate	●	●	●	●	●	●	●	●	●	●	●
Draft changes to a client's rulebook and its allowlist	●	●	·	·	·	·	●	·	●	●	·
Put a client's rulebook in force (client admins sign; staff only on the client's recorded instruction)	●	●	·	·	·	·	·	·	·	●	·
Compliance and reports											
See regulatory clocks and notices (CERT-In, DPDP) and the ISO 27001 evidence map	●	●	●	●	●	·	·	●	·	●	●
Draft regulatory notices, record the client's approval, and file them	●	●	·	●	●	·	·	·	·	·	·
Approve a regulatory notice before it is filed (the report is the client's; staff record a client's approval given elsewhere)	●	●	·	·	·	·	·	·	·	●	·
Read client-facing incident reports	●	●	·	●	●	·	·	●	·	●	●
SOC operations											
See the on-call rota, pages, runbooks, QA results and digests	●	●	●	●	●	●	●	●	·	·	·
Edit the on-call rota, runbooks and operations settings	●	●	·	·	●	·	·	·	·	·	·
Review the weekly sample of what the AI did on its own	●	●	·	·	●	·	·	·	·	·	·
Commercial											
Use the Build & Price configurator	●	●	·	·	·	·	·	·	●	·	·
See internal cost and margin	●	·	·	·	·	·	·	·	●	·	·
Edit the price book	●	·	·	·	·	·	·	·	·	·	·
See contracts, pilots and invoices (clients: their own)	●	●	·	·	·	·	·	·	●	●	·
Draft and record contracts, issue invoices and record payments	●	·	·	·	·	·	·	·	●	·	·
Platform											
Invite users and change roles	●	·	·	·	·	·	·	·	·	·	·
Edit platform settings: company profile, provider keys, forensics thresholds	●	●	·	·	·	·	·	·	·	·	·
Read the audit chain	●	●	·	·	·	·	·	●	·	·	·
Export the audit chain	●	●	·	·	·	·	·	●	·	·	·
Create personal API tokens for the REST API (acting with their own permissions)	●	●	·	●	●	●	●	●	·	●	·

4. Screen by screen

Every page in HELIOS: what it is for, who can open it, and how to use it. Where an instruction needs a particular permission, the roles that have it are named. Screenshots are from the test environment.

4.1 Overview

Your starting page. It shows what needs you now, and it changes with your role: the SOC sees live posture, queues, SLAs and AI activity; account managers see the commercial picture; client users see their own organisation.

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor, Account mgr, Client admin, Client viewer

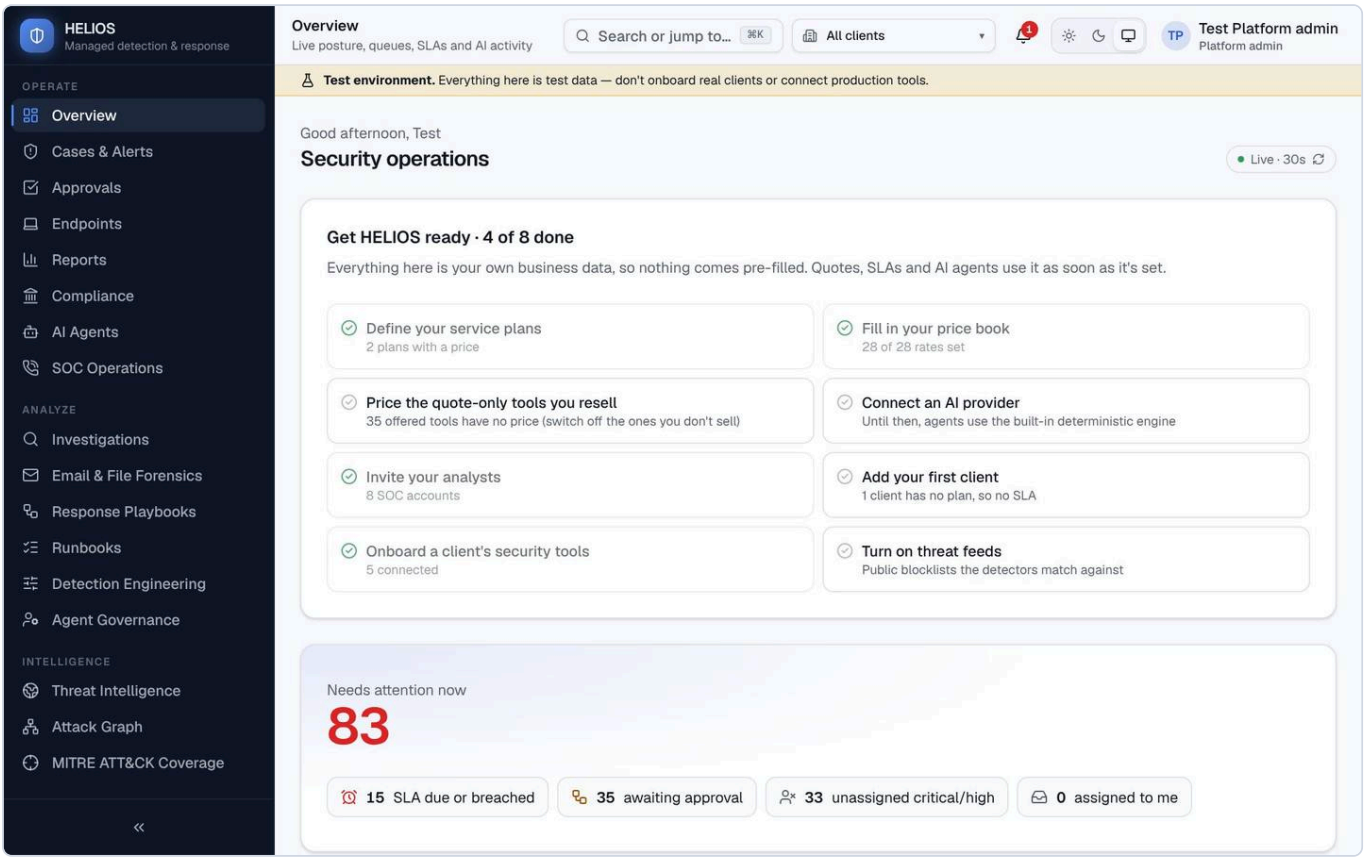


Figure 3. Overview (as platform admin).

How to use it

- Needs attention now adds up what is due: cases whose SLA is due or breached, containment awaiting approval, unassigned critical and high cases, and cases assigned to you. Click a figure to open the matching list. Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor
- The Live badge means the figures refresh on their own every 30 seconds; the arrow refreshes now. Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor, Client admin, Client viewer
- Get HELIOS ready is the first-run checklist: service plans, price book, prices for quote-only tools, an AI provider, analysts, the first client, its security tools and threat feeds. Each item links to where it is done and ticks itself once it is. Admin, SOC manager
- The commercial overview shows won monthly recurring revenue, the open pipeline, win rate, clients and endpoints under contract, and recent quotes. Build a quote opens Build & Price. Account mgr
- Your security at a glance: open incidents, SLA met over 30 days, average time to acknowledge and to contain, and your endpoints' average protection score. Below, incidents over the last 14 days and your service plan. Client admin, Client viewer

- Waiting for your approval lists containment the SOC proposed on your systems; Review opens the incident to approve or reject it. Client admin
- Waiting for your organisation's approval lists containment the SOC proposed on your systems; your client admin decides. View opens the incident. Client viewer

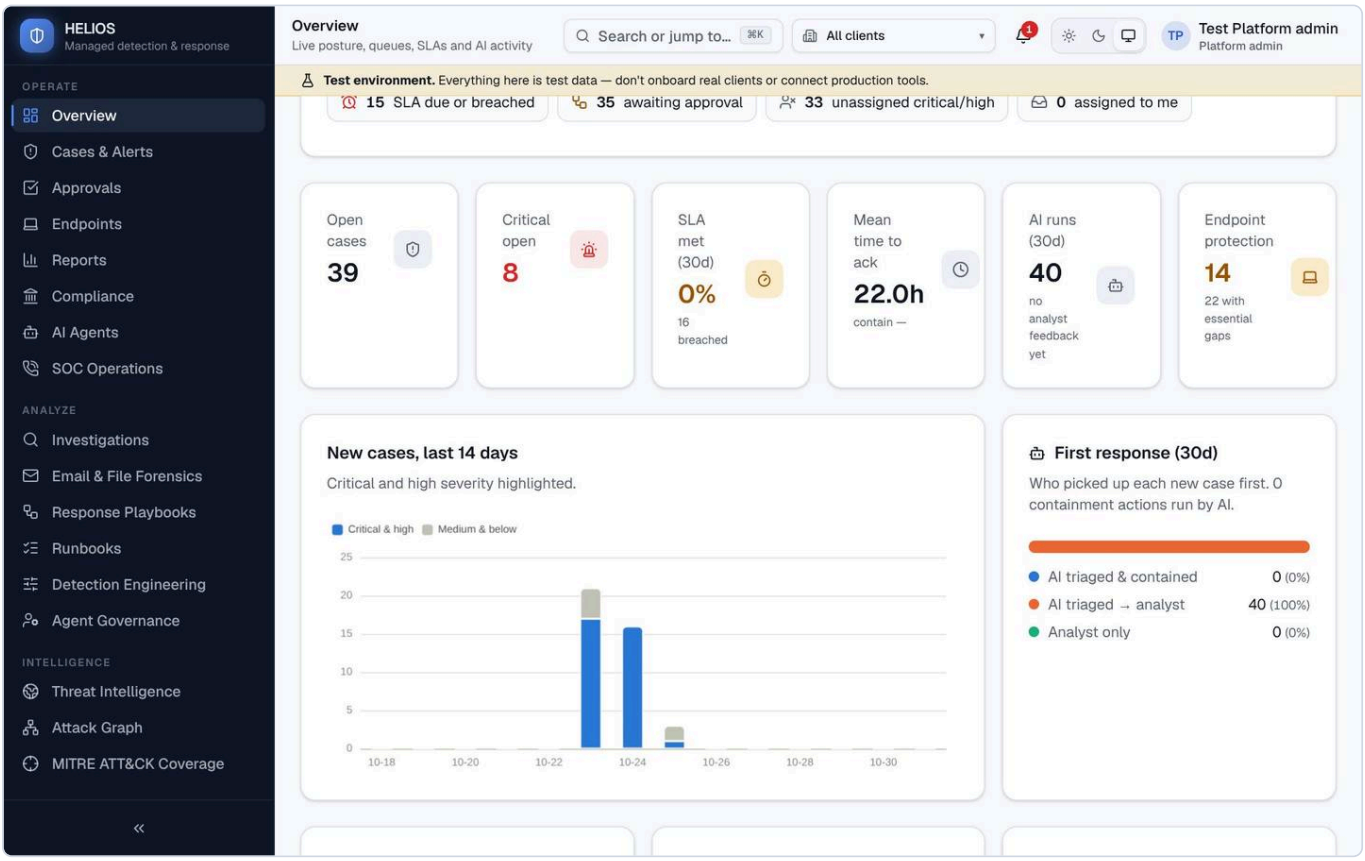


Figure 4. Overview, further down the page.

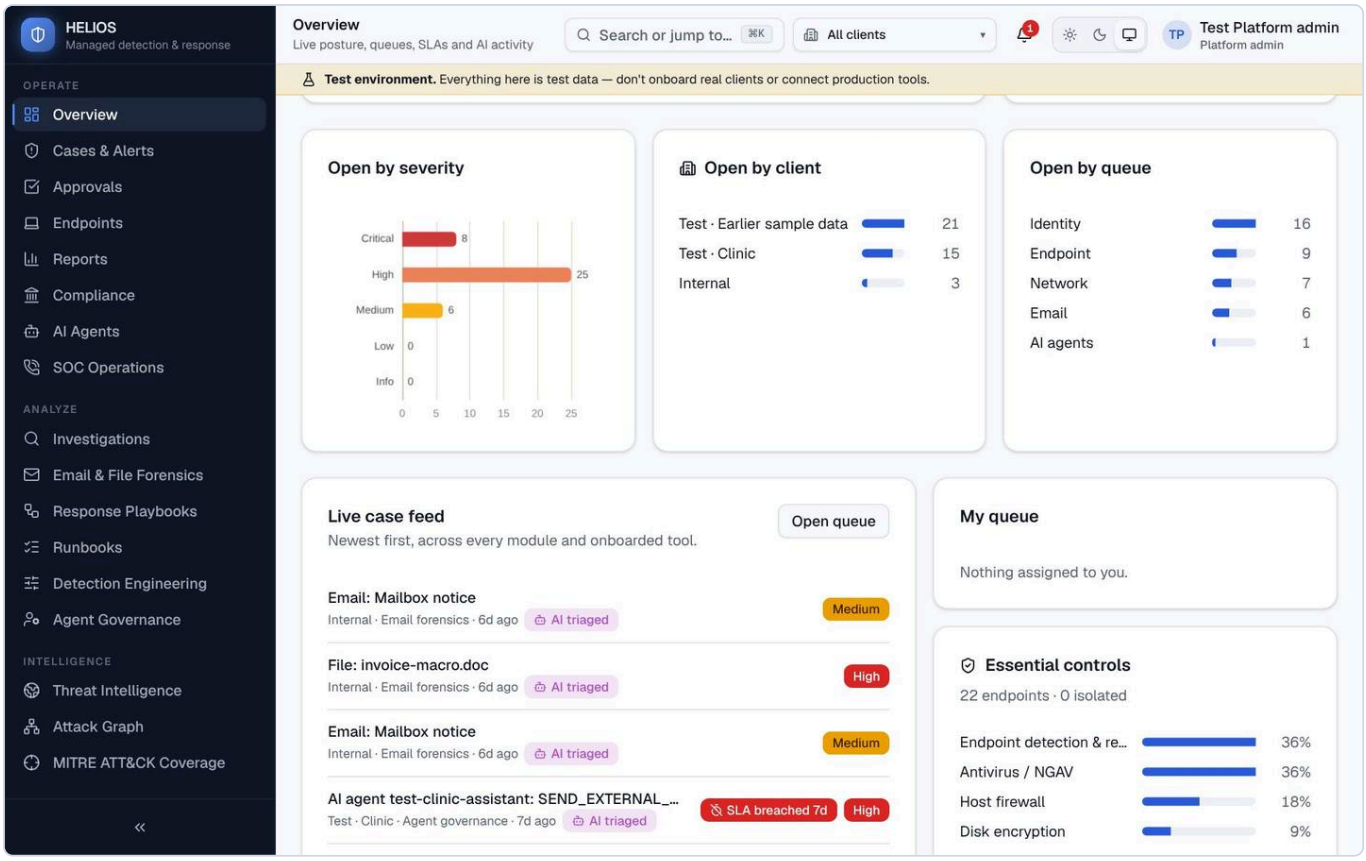


Figure 5. Overview, further down the page.

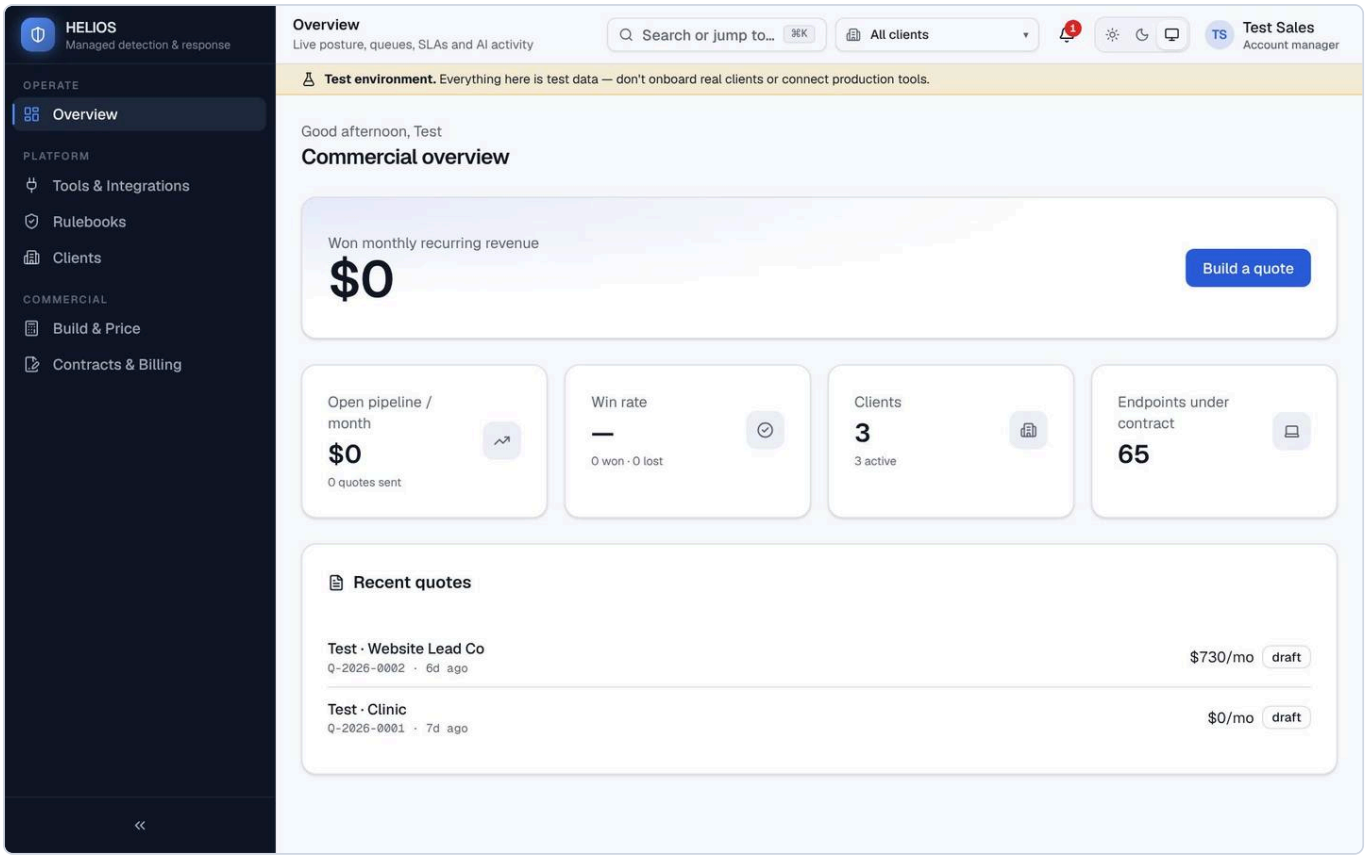


Figure 6. The account manager's commercial overview.

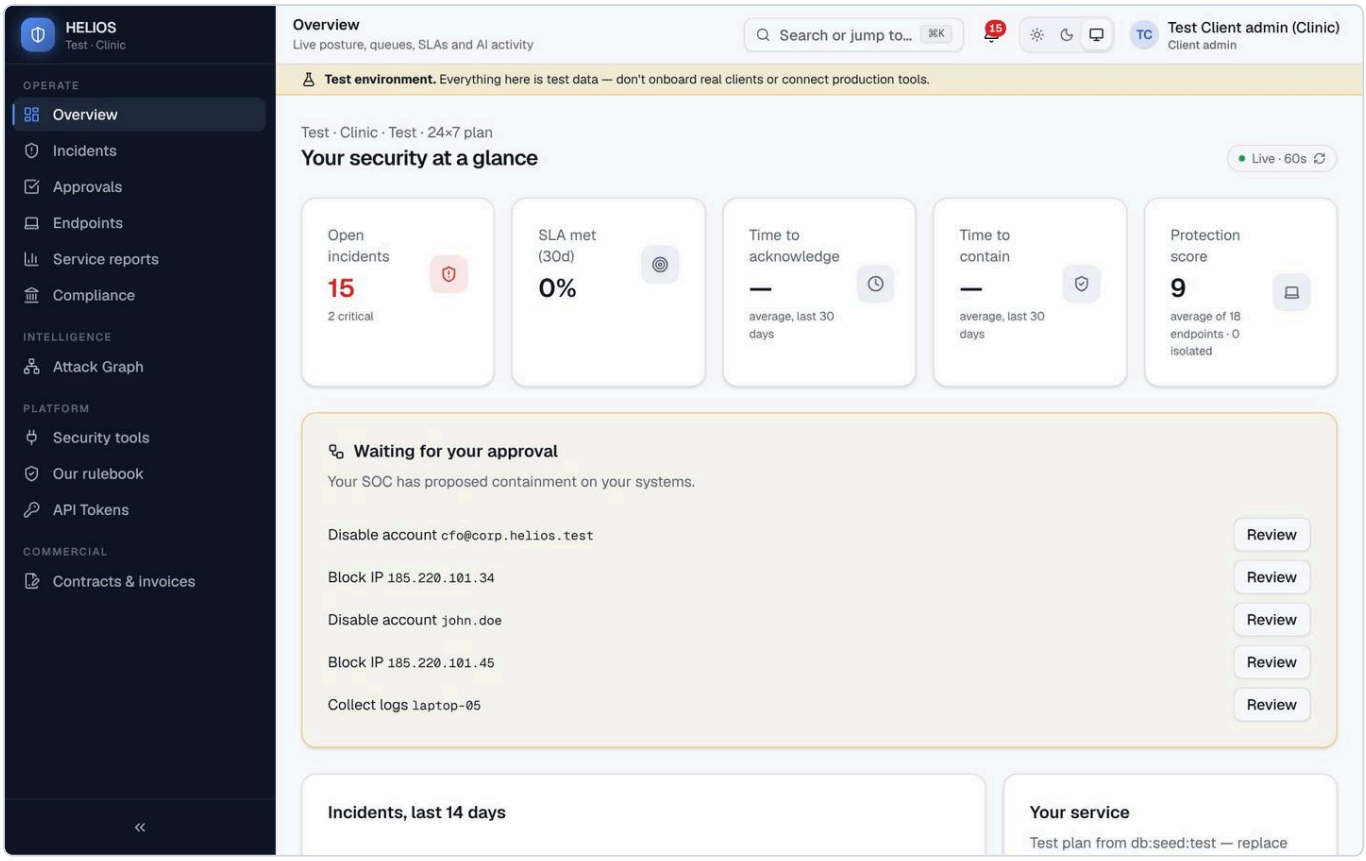


Figure 7. The client's view: Overview (as client admin).

4.2 Cases & Alerts (clients: Incidents)

Every case HELIOS has opened: detections from your clients' telemetry, vendor alerts, uploaded investigations, email and file analysis, and governed AI agents. Correlated detections for the same user, host or IP join one case instead of opening many.

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor, Client admin, Client viewer

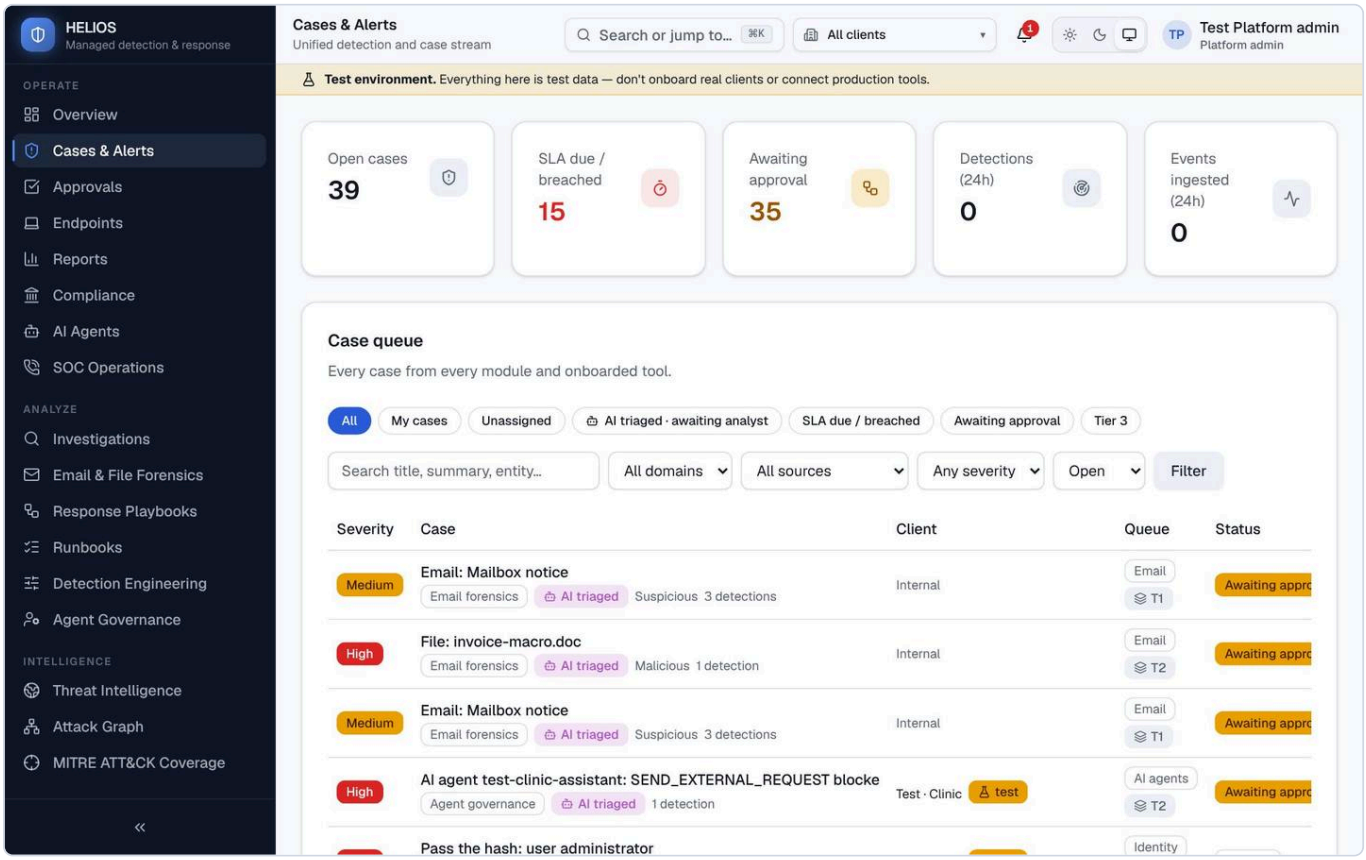


Figure 8. Cases & Alerts (as platform admin).

How to use it

- Filter by status, severity, source, client and assignee, or search by title. Open a case by clicking its row. Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor
- If your account is limited to security domains (endpoint, identity, email, network, cloud, AI agents), you see only those queues. Tier 1, Tier 2
- You see every queue regardless of security domains. Admin, SOC manager, Tier 3, Hunter, Detection eng., Auditor
- The SLA badge counts down to the acknowledgement deadline from the client's plan; a red badge means it has been breached. Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor
- You see only your own organisation's incidents. Open one to read what happened, what was done and what is waiting on you. Client admin, Client viewer

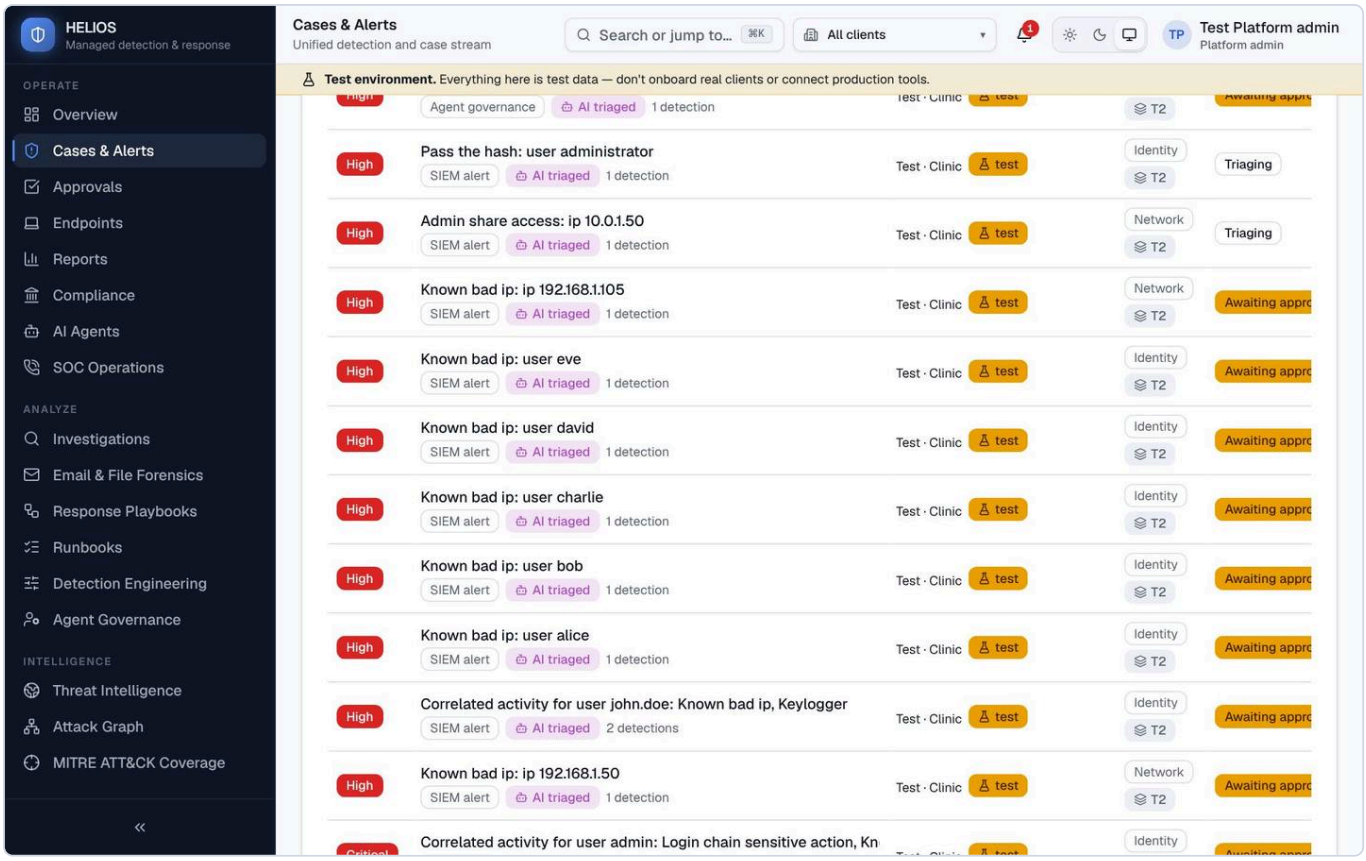


Figure 9. Cases & Alerts, further down the page.

4.3 A case

Everything about one case on one page: what was detected, what the AI made of it, what has been done and what is waiting, the evidence, and the discussion.

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor, Client admin, Client viewer

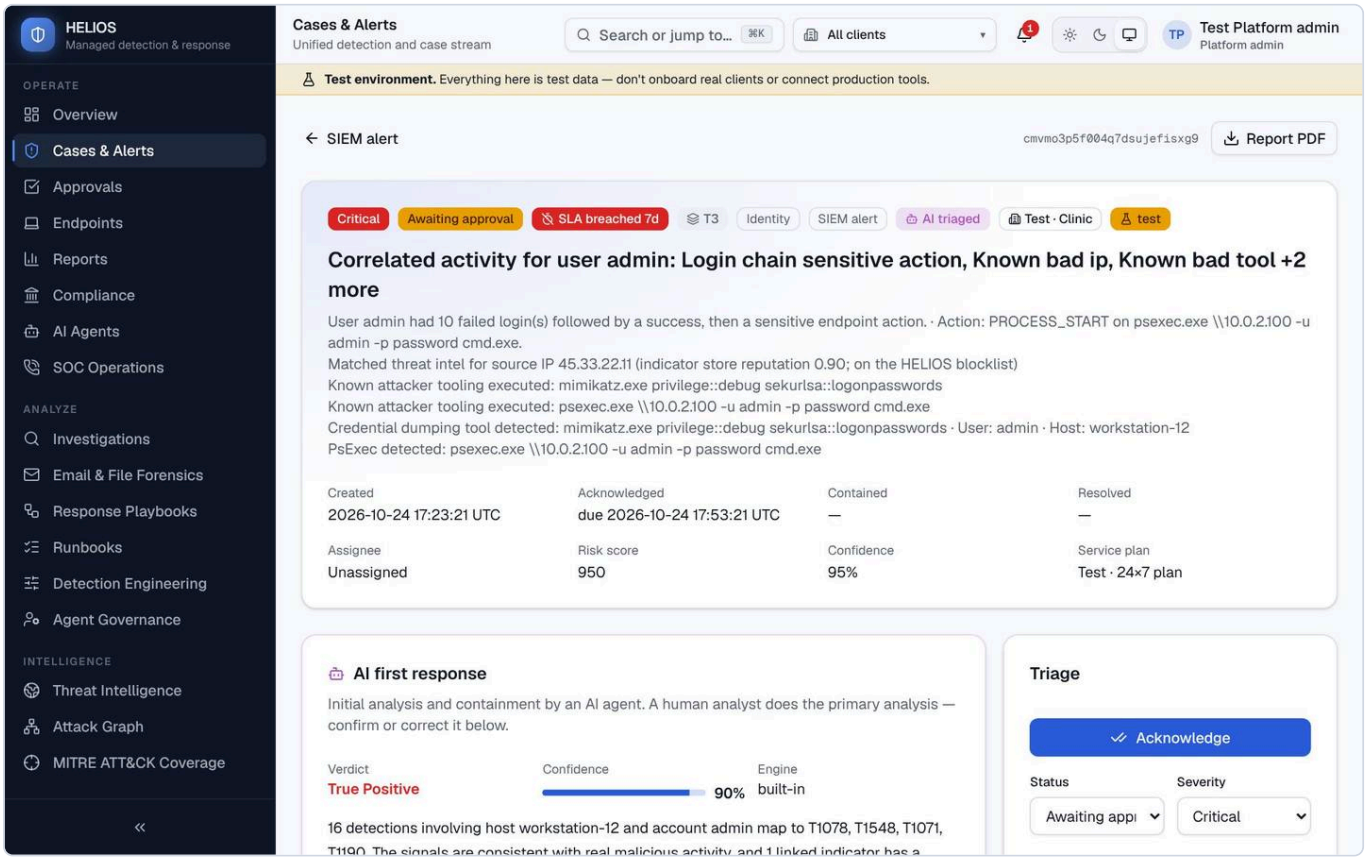


Figure 10. A case (as platform admin).

How to use it

- The header shows severity, status, the SLA, the tier (T1 triage, T2 analysis, T3 incident response), the security domain, the source, the client and whether AI triaged it. Below are the dates (created, acknowledged, contained, resolved), the assignee, the risk score, the confidence and the client's service plan. Report PDF downloads the incident report.
- AI first response shows the agent's verdict, confidence and engine, its summary, its key findings (each citing evidence: D detections, E events, I indicators, T timeline, C context) and what it asks the analyst to check. It is a first pass: a person confirms or corrects it. Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor
- Agree or Disagree records whether the analysis was right; a disagreement asks what it got wrong. These ratings drive the AI's autonomy ladder. Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter
- Dispatch agent runs another agent on the case: the triage first responder, the phishing analyst, the threat-intel enricher, the investigation agent (works the case with read-only tools) or the client report writer. Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng.
- In Triage: Acknowledge stops the SLA clock; Status and Severity change the case; Assignee gives it to someone. Admin, SOC manager, Tier 1, Tier 2, Tier 3
- Watch case sends you its updates. Escalate hands the case to another tier or person with a note; Share makes it visible to the client or sends it to an external channel. Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter
- Page on-call (in the On call card) pages whoever is on call about this case, with what you need from them. Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter
- Response actions lists containment the AI proposed and people requested, each with its status. Approve or Reject what is awaiting approval; the client's rulebook and the response policy still apply. Admin, SOC manager, Tier 3, Client admin
- Request containment asks for an action (isolate host, block IP, disable account, kill process, quarantine file, block sender, collect logs, purge email, reset password, collect an investigation package...) against a target,

with a reason shown to the approver. Admin, SOC manager, Tier 1, Tier 2, Tier 3

- Indicators shows the case's IPs, domains, URLs, hashes and addresses with their reputation; the arrow re-checks one. Related cases lists earlier or concurrent cases sharing hosts, accounts, indicators or the same agent. Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor
- Regulatory reporting shows whether CERT-In's 6-hour report or the DPDP breach notices apply, the incident types HELIOS proposes, and the notices' state.
  Admin, SOC manager, Tier 1, Tier 2, Tier 3, Auditor, Client admin, Client viewer
- Runbooks attach themselves to matching cases; tick each step or skip it with a reason. A case can't be closed as a true positive while a required step is open. Admin, SOC manager, Tier 1, Tier 2, Tier 3
- The discussion takes comments and @mentions. Internal comments stay with the SOC; client-visible ones reach the client. Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Client admin
- Closing: set the status to Resolved or False positive, then give a disposition (true positive, benign true positive, false positive) and a reason. Admin, SOC manager, Tier 1, Tier 2, Tier 3
- You can read the case, its timeline and what was done. Approve or reject containment on your estate from here or from Approvals. Client admin
- You can read the case, its timeline and what was done; you can't change it. Client viewer

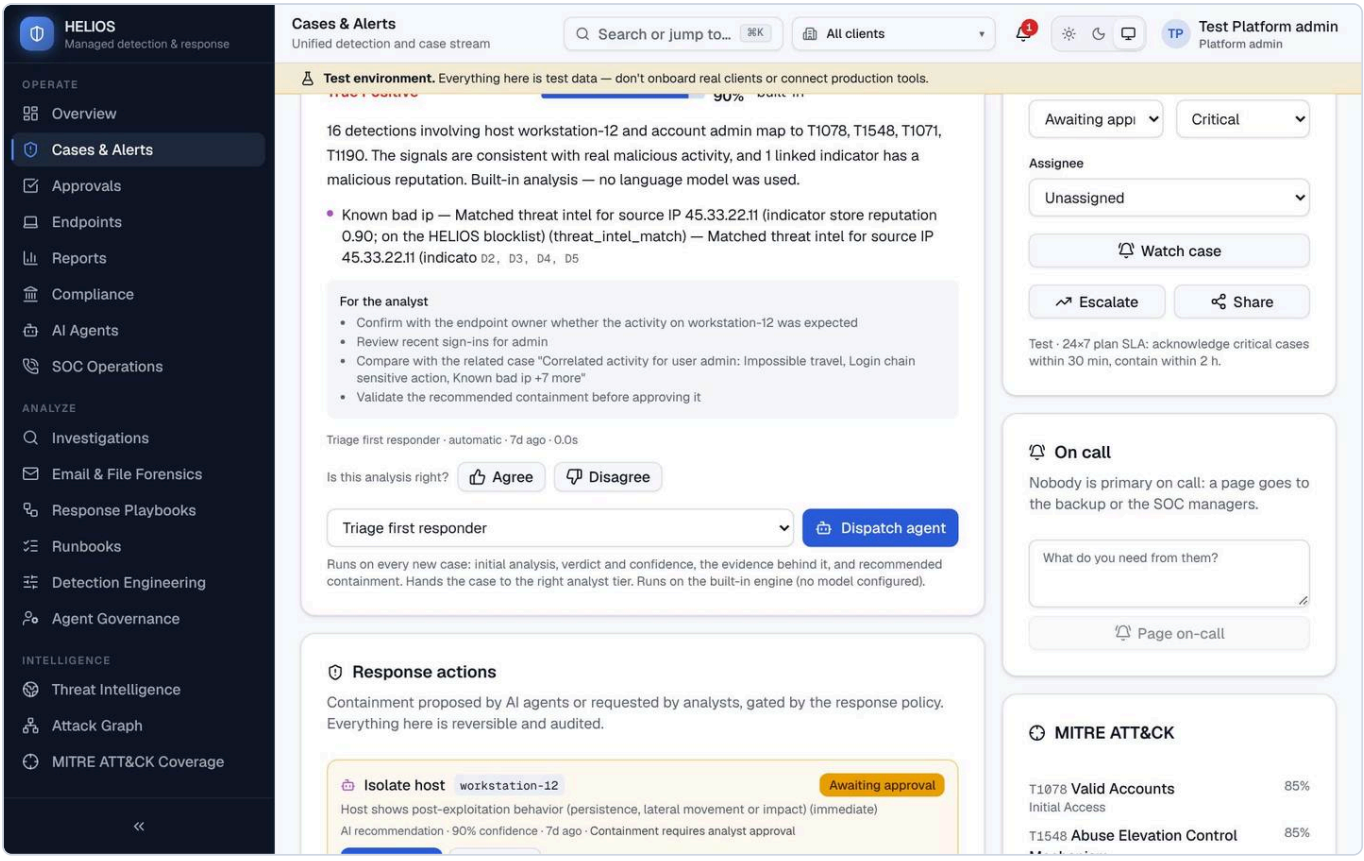


Figure 11. A case, further down the page.

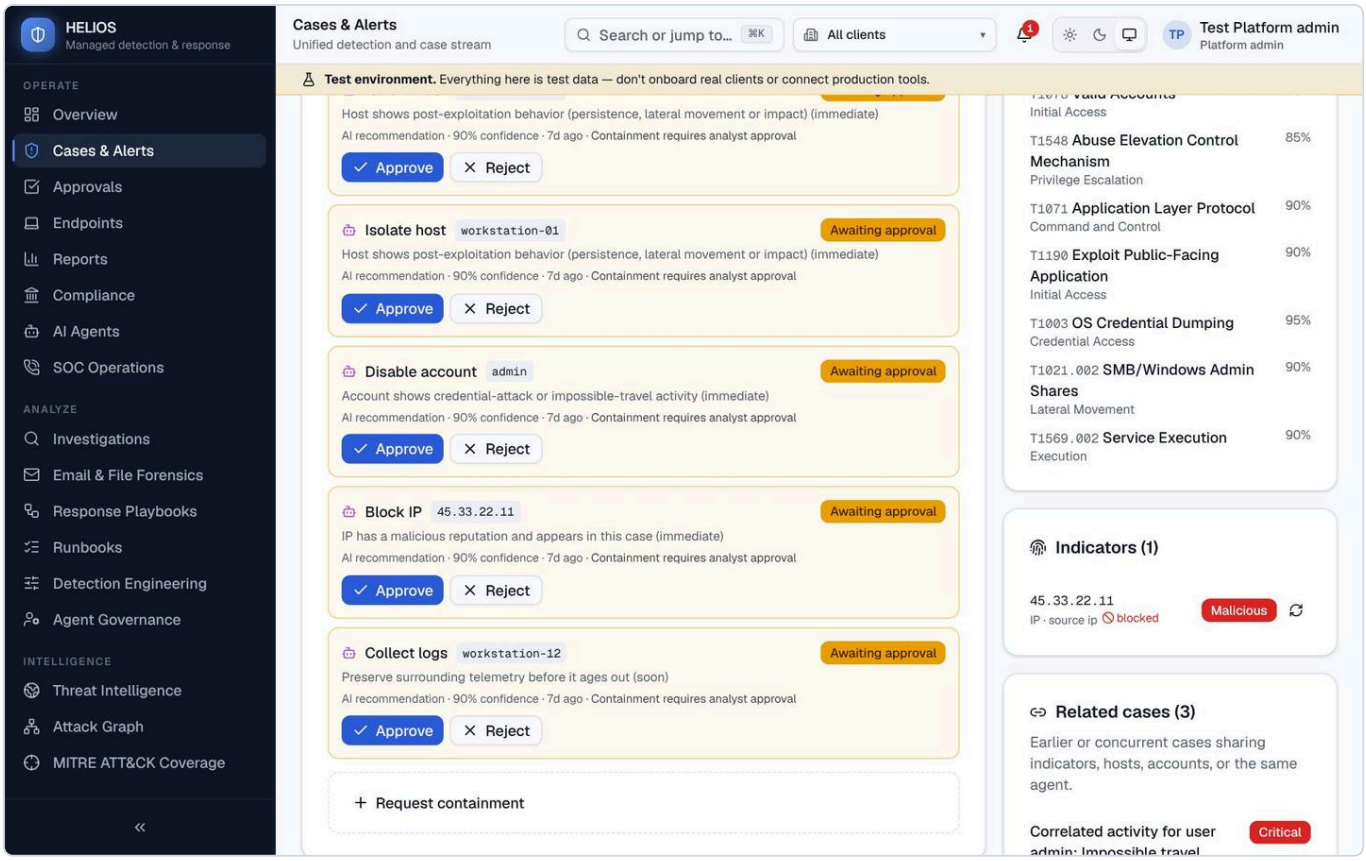


Figure 12. A case, further down the page.

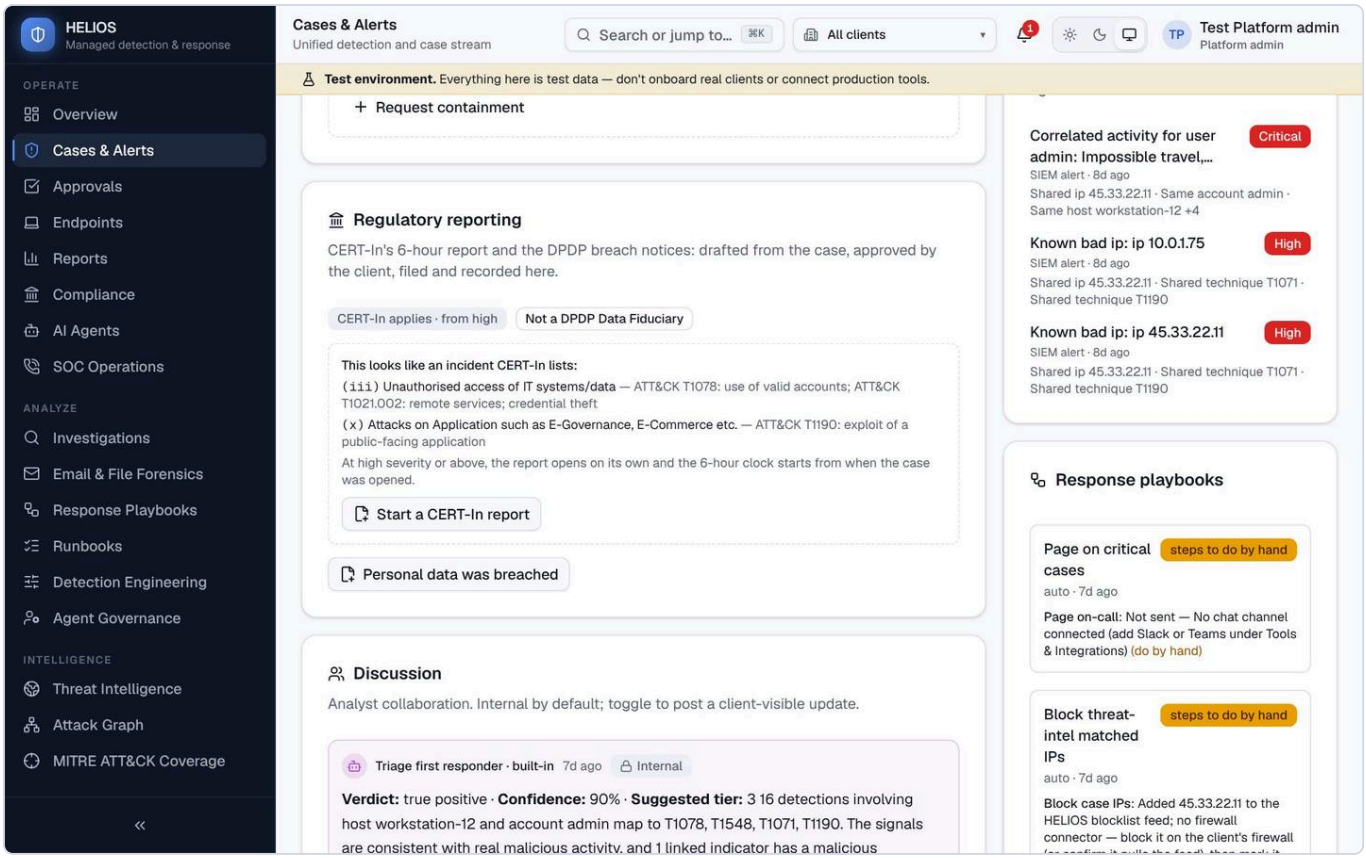


Figure 13. A case, further down the page.

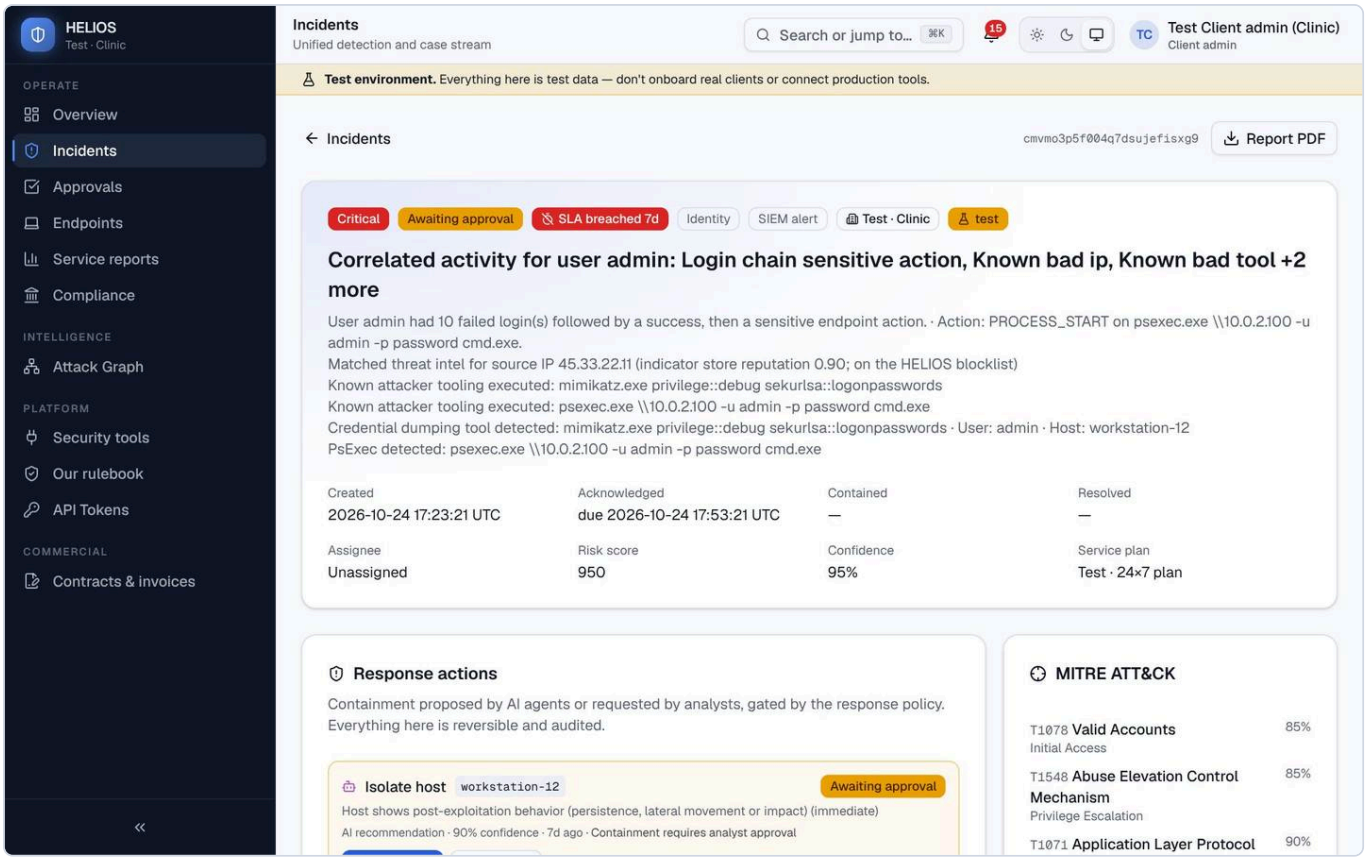


Figure 14. The client's view: A case (as client admin).

4.4 Approvals

Everything waiting on someone's yes, in your scope: containment the response policy held, playbook runs that need approval, regulatory notices waiting on the client, and rulebooks to sign.

Who can open it: Admin, SOC manager, Tier 3, Client admin

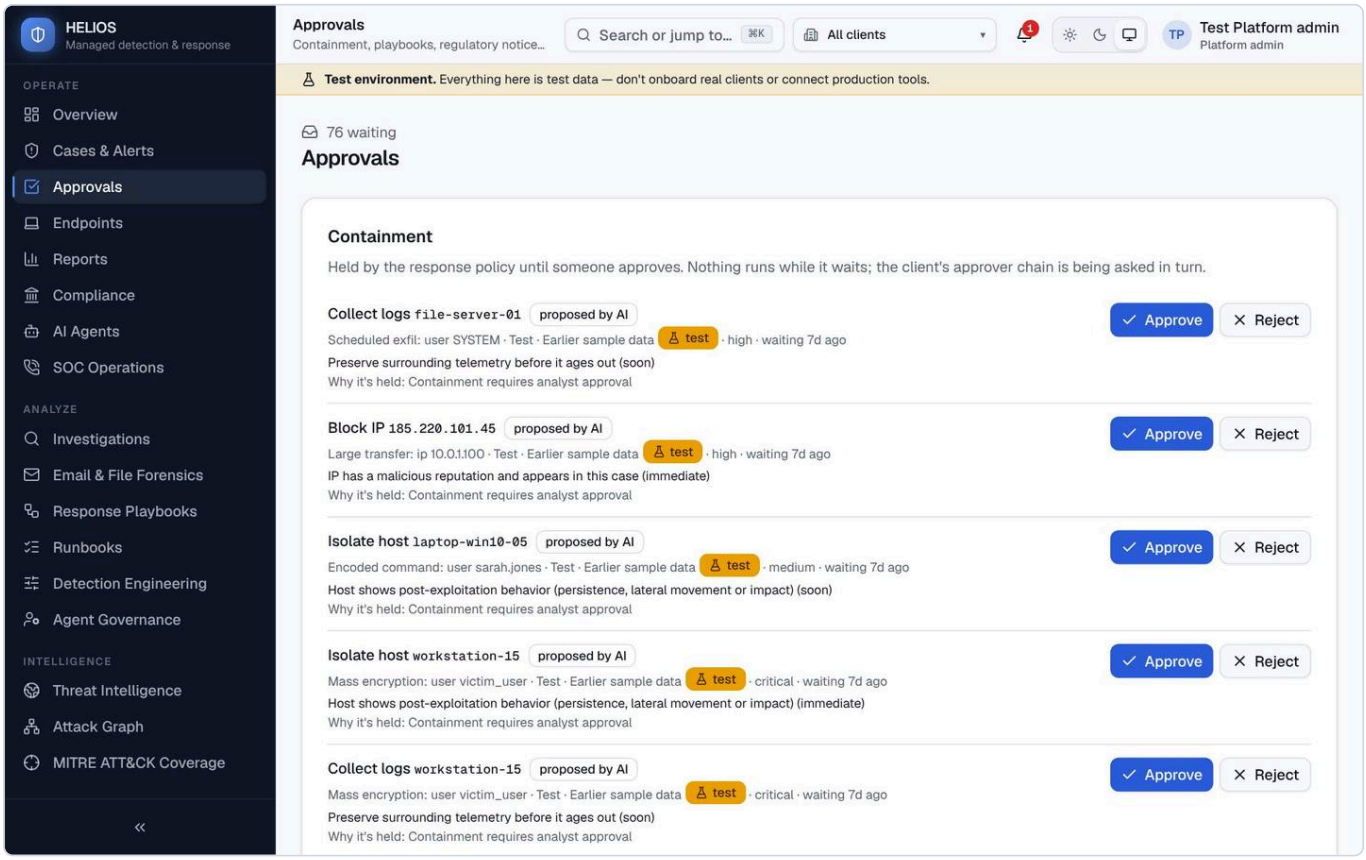


Figure 15. Approvals (as platform admin).

How to use it

- Each item says what would happen, against what, why it was held, who proposed it, the client, the severity and how long it has waited. Approve or Reject right there.
- Nothing held runs while it waits. The client's approver chain is asked in turn (in the app, by Slack or Teams, email, SMS or WhatsApp); when the chain runs out, the action holds or becomes a suggestion, as the client's rulebook says.
- A two-person rule in the rulebook needs two different approvers; one approval leaves it waiting for the second.
- As a client admin you see only your organisation's items: containment on your estate, notices to approve before filing, and rulebook versions to sign. Client admin

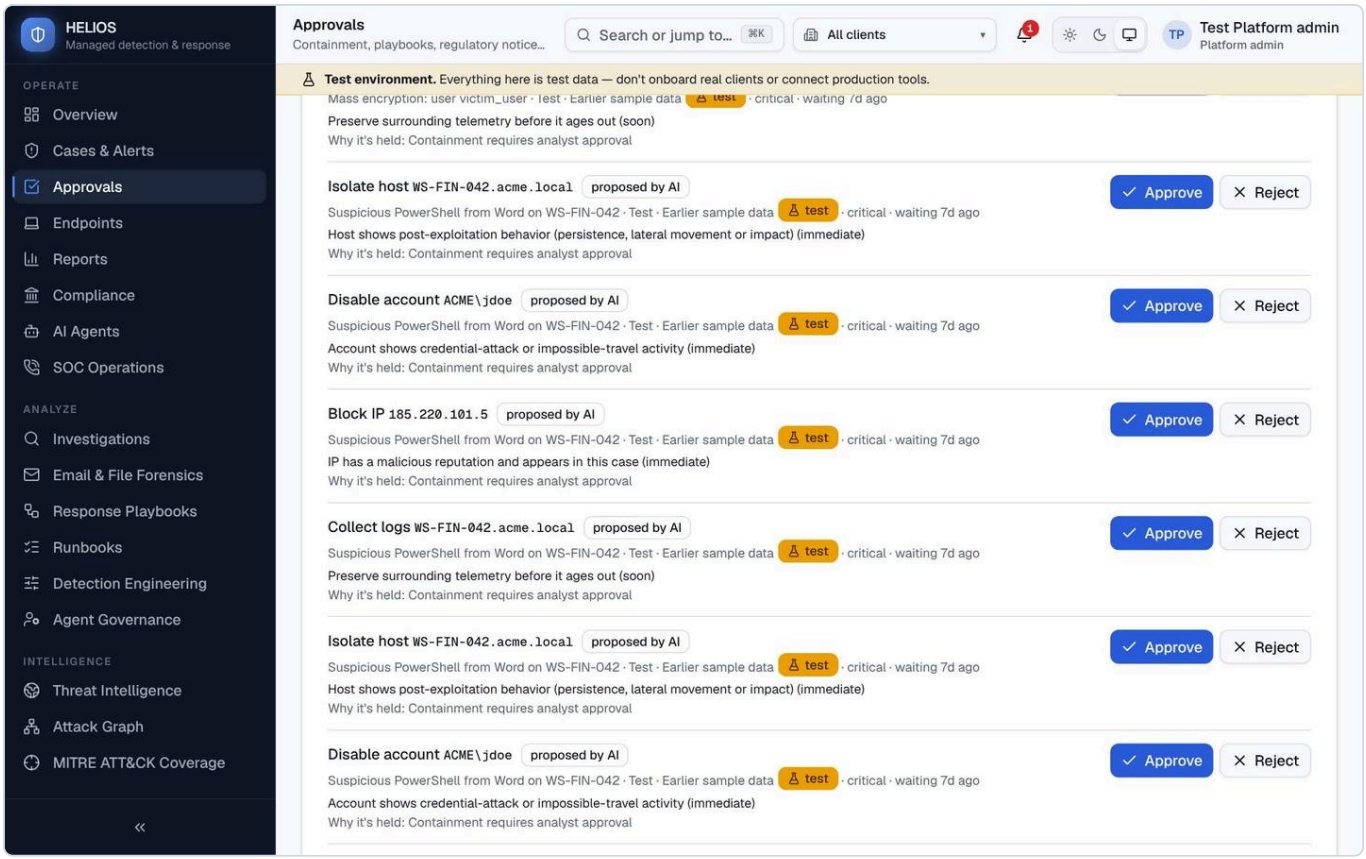


Figure 16. Approvals, further down the page.

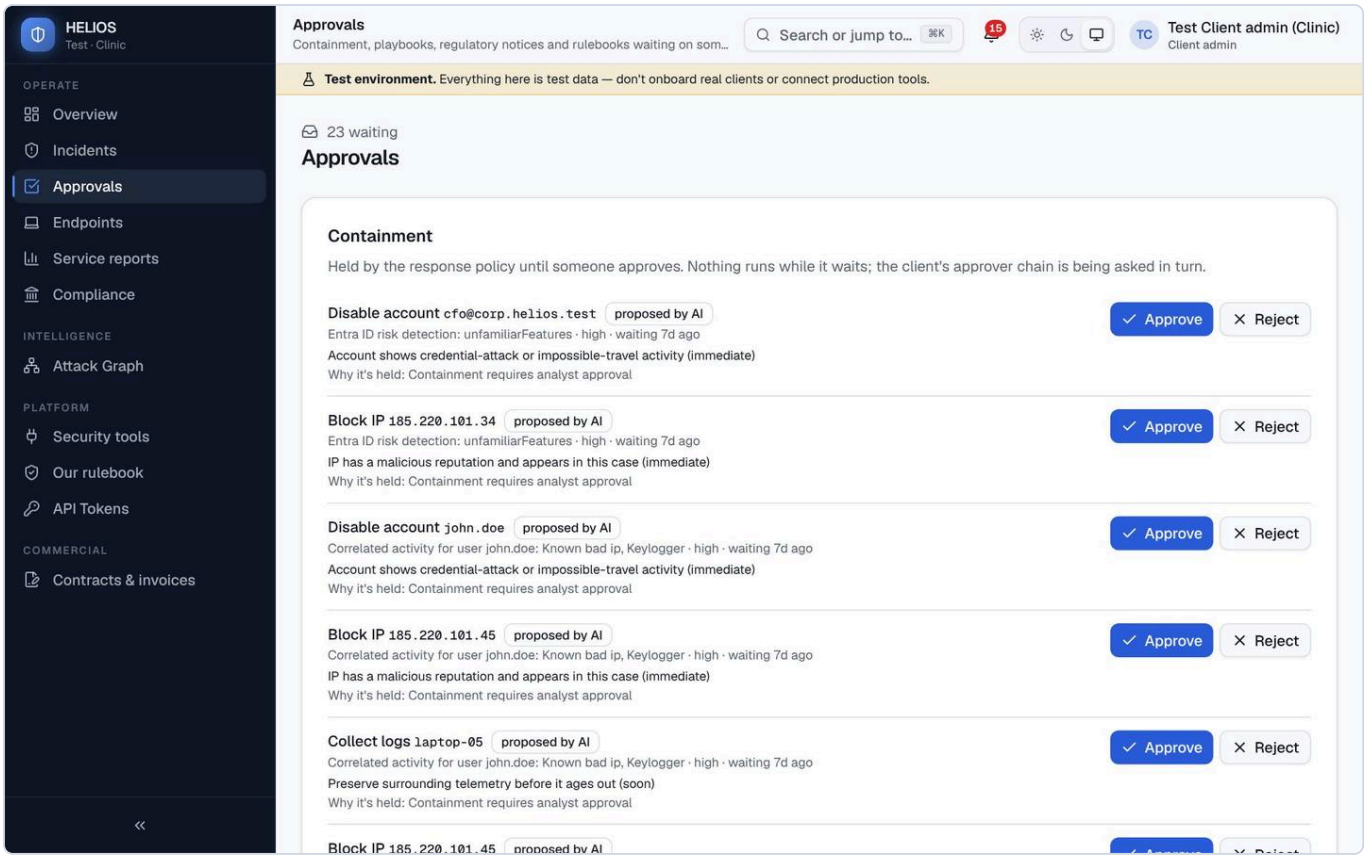


Figure 17. The client's view: Approvals (as client admin).

4.5 Endpoints

The endpoint inventory and the whole attack surface: devices, servers, cloud, network, identity, IoT/OT and applications, with how well each is protected.

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor, Client admin, Client viewer

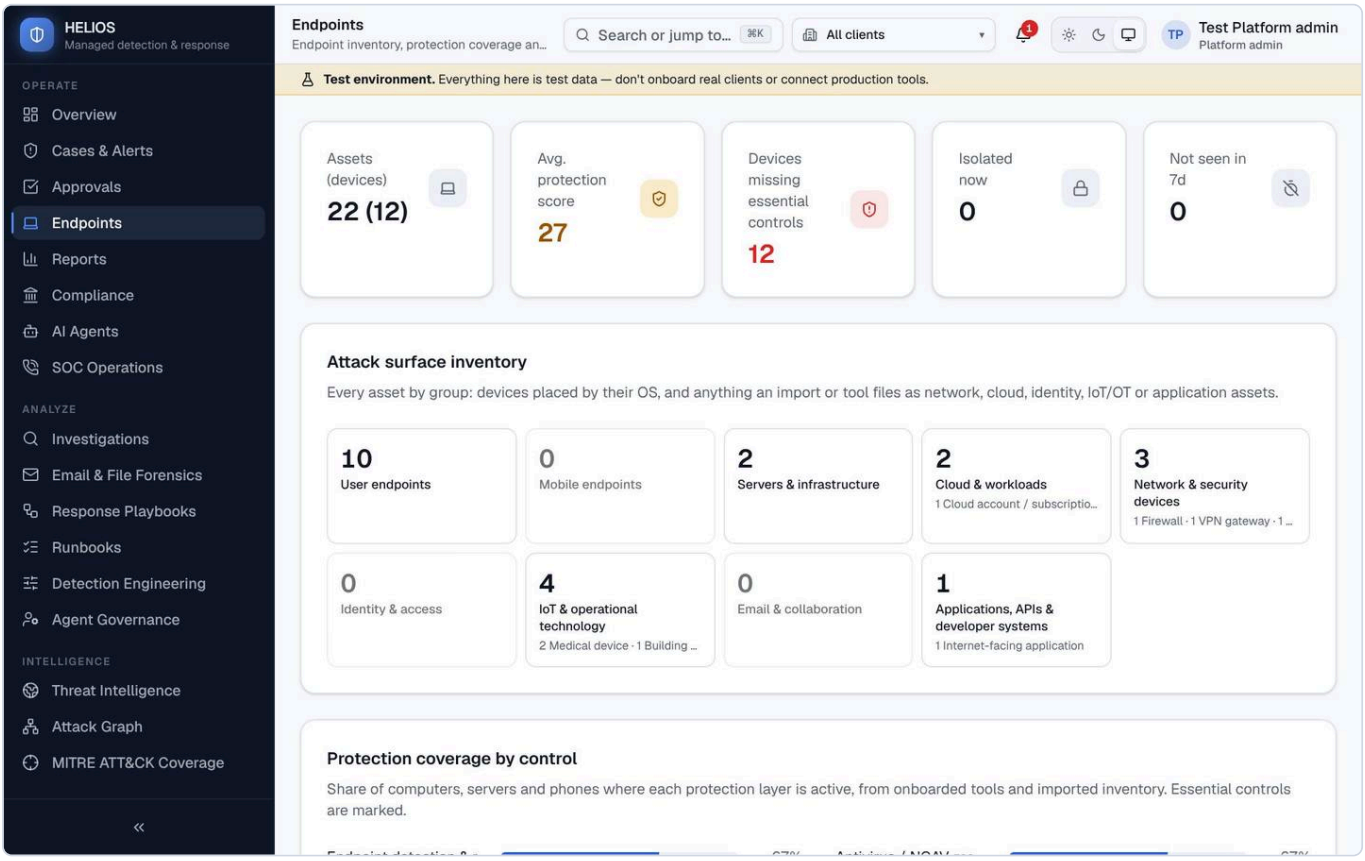


Figure 18. Endpoints (as platform admin).

How to use it

- The tiles count assets, the average protection score, devices missing essential controls, devices isolated now and devices not seen for seven days.
- Attack surface inventory groups every asset; Protection coverage by control shows the share of computers, servers and phones where each protection layer (EDR, antivirus, disk encryption, MFA...) is active, with the essential ones marked.
- Isolate or Release a device from its row. With an EDR connector HELIOS asks the vendor and confirms the device's state; without one it records the change and asks you to make it in the EDR console. The client's rulebook still decides: a never-isolate asset can't be isolated, a crown jewel needs approval.
  Admin, SOC manager, Tier 3

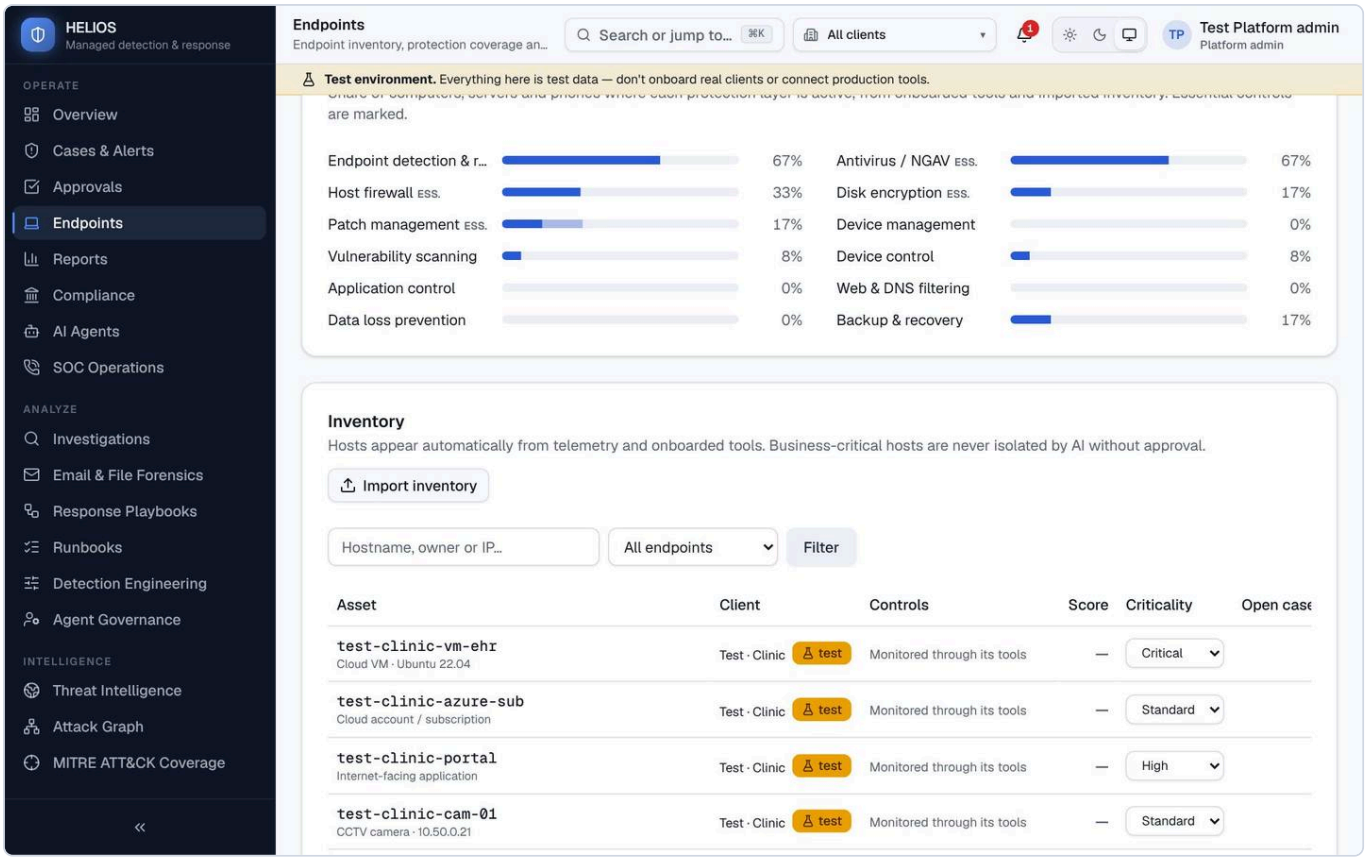


Figure 19. Endpoints, further down the page.

4.6 Reports (clients: Service reports)

How the service performed over a period: volume, response times, SLA compliance, AI performance and analyst workload, each compared with the period before.

Who can open it: Admin, SOC manager, Tier 2, Tier 3, Auditor, Client admin, Client viewer

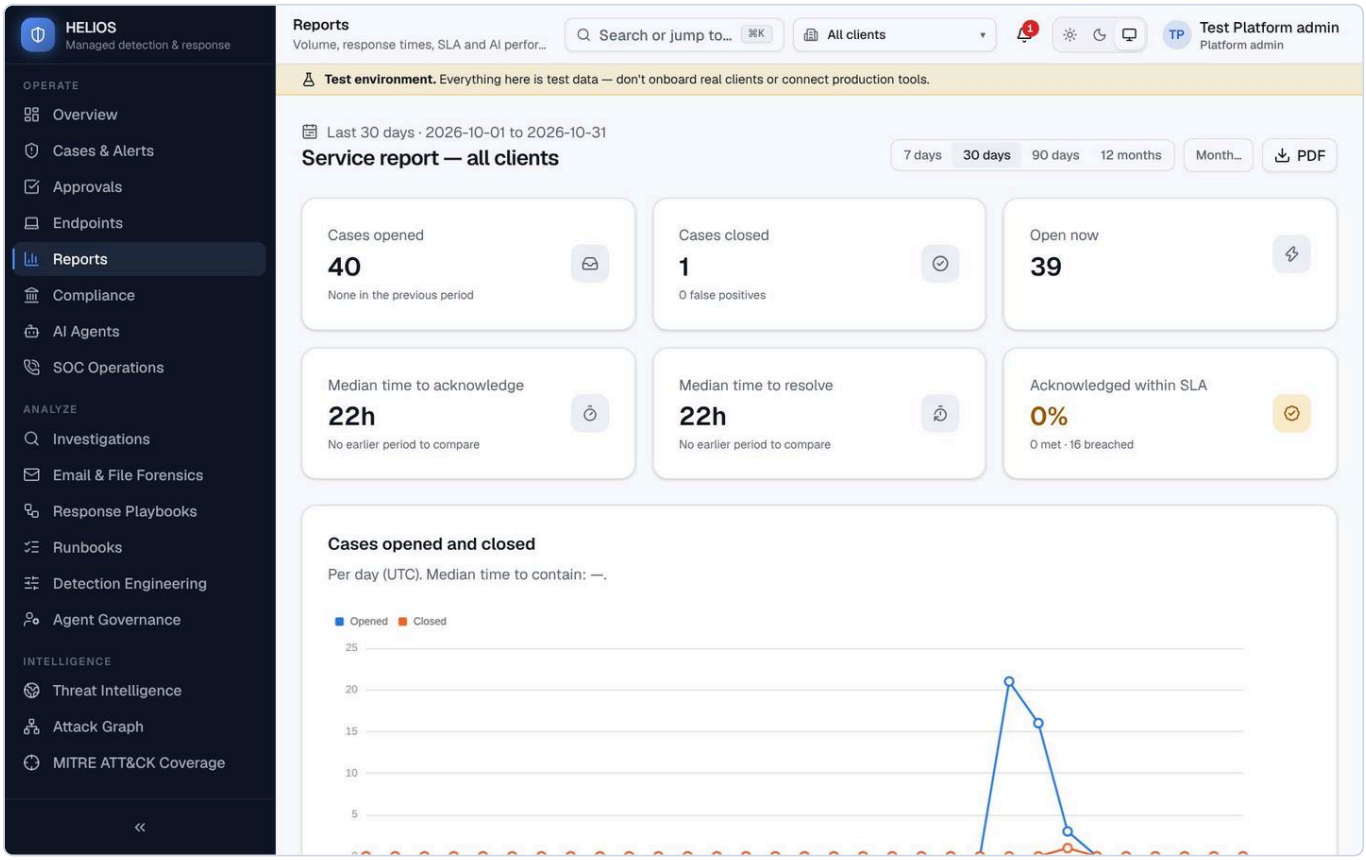


Figure 20. Reports (as platform admin).

How to use it

- Pick a period or a month. The figures include median time to acknowledge, contain and resolve, acknowledgement SLA compliance, the mix by severity, source, domain and client, top ATT&CK techniques and indicators, AI runs and analyst agreement, and containment outcomes.
- Download the service report as a PDF for the client. Admin, SOC manager, Tier 2, Tier 3, Auditor
- You see your own organisation's report, and can download it as a PDF. Client admin, Client viewer

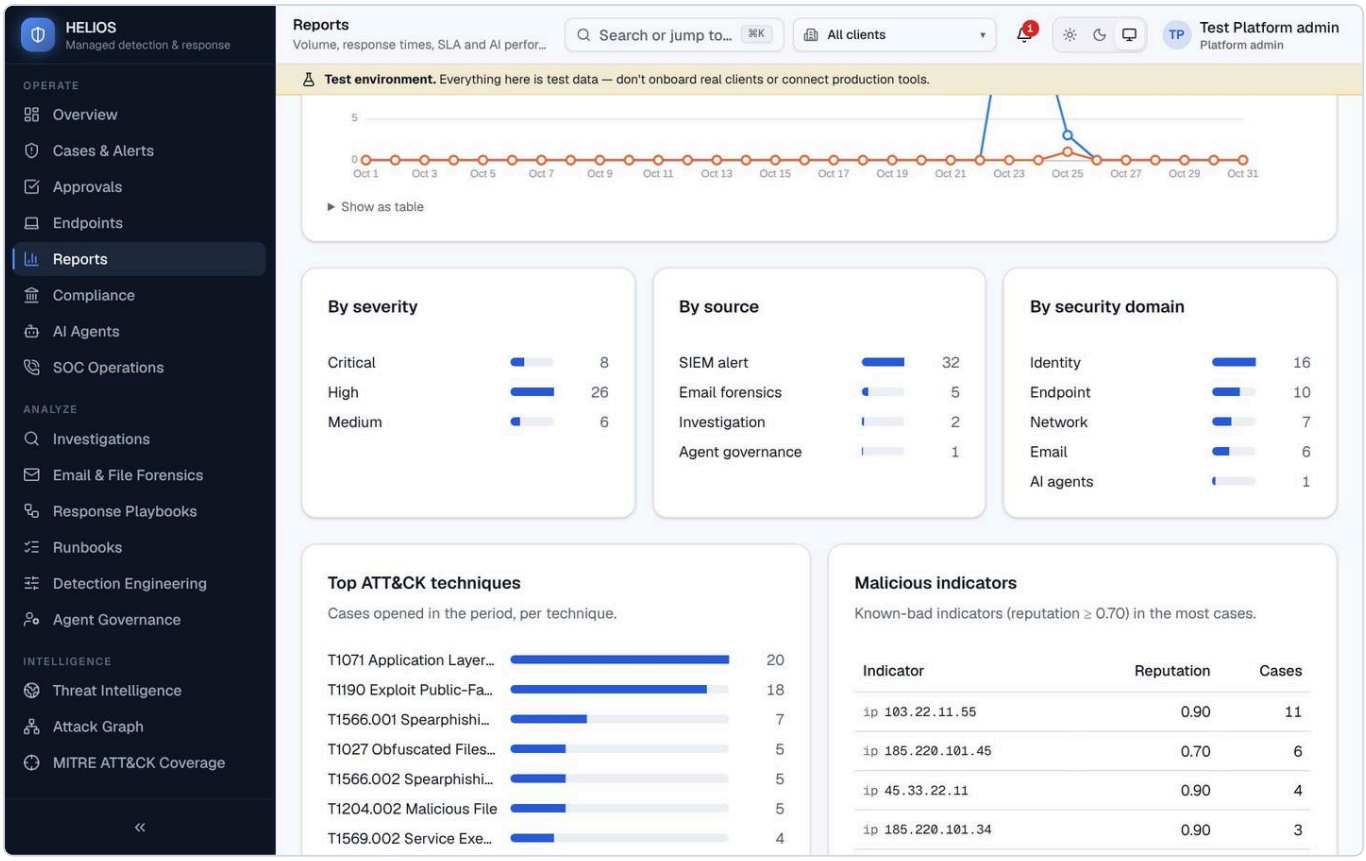


Figure 21. Reports, further down the page.

4.7 Compliance

Regulatory clocks and evidence: CERT-In's 6-hour incident reports, the DPDP breach notices, and the ISO/IEC 27001 evidence map.

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Auditor, Client admin, Client viewer

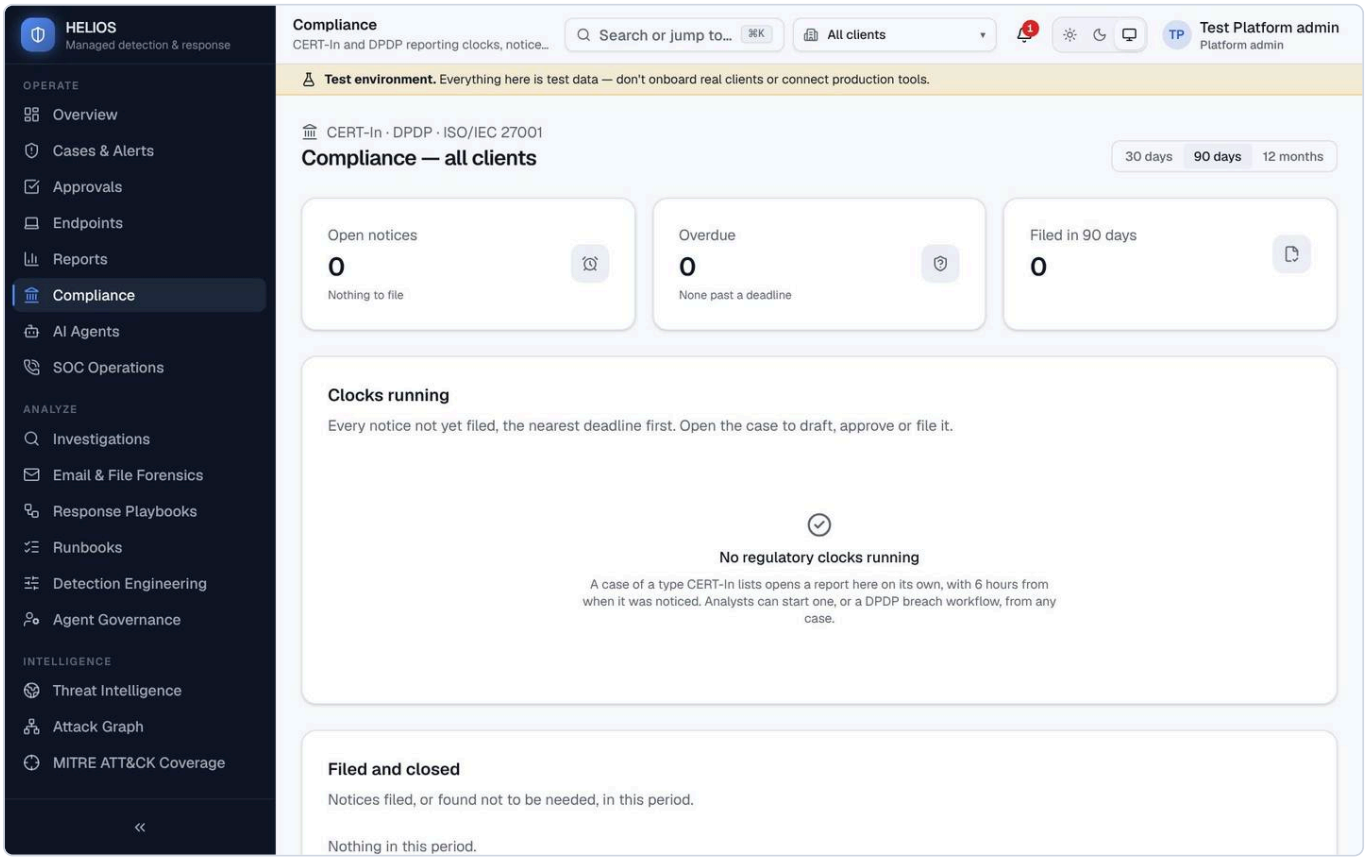


Figure 22. Compliance (as platform admin).

How to use it

- Clocks running lists every notice not yet filed, nearest deadline first. CERT-In: incidents of the 20 listed types are reported within 6 hours of being noticed. DPDP: the Board and each affected person are told without delay, and the Board gets a detailed report within 72 hours.
- Open the case to draft, approve or file a notice. Each notice is drafted from the case, approved by the client, then filed (emailed to CERT-In with its PDF, or recorded with the regulator's reference).
  Admin, SOC manager, Tier 2, Tier 3
- A notice goes to the client for approval before it is filed: approve it here or from Approvals. An edit after approval sends it back. Admin, SOC manager, Client admin
- The ISO 27001 view maps 15 Annex A controls to what HELIOS's records show over the period, and shows gaps (controls with nothing behind them) plainly.
- Switch the period (30 days, 90 days, 12 months) at the top.

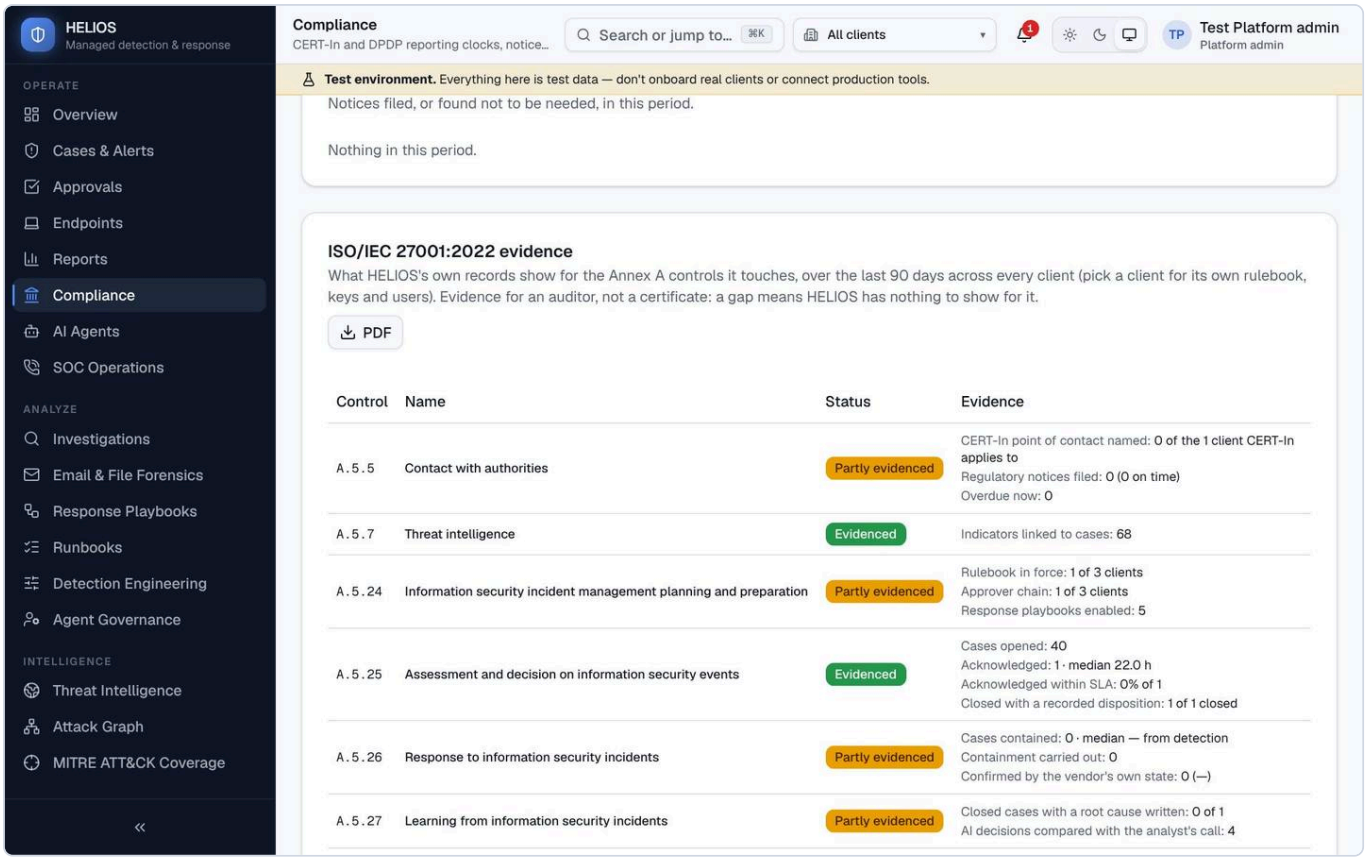


Figure 23. Compliance, further down the page.

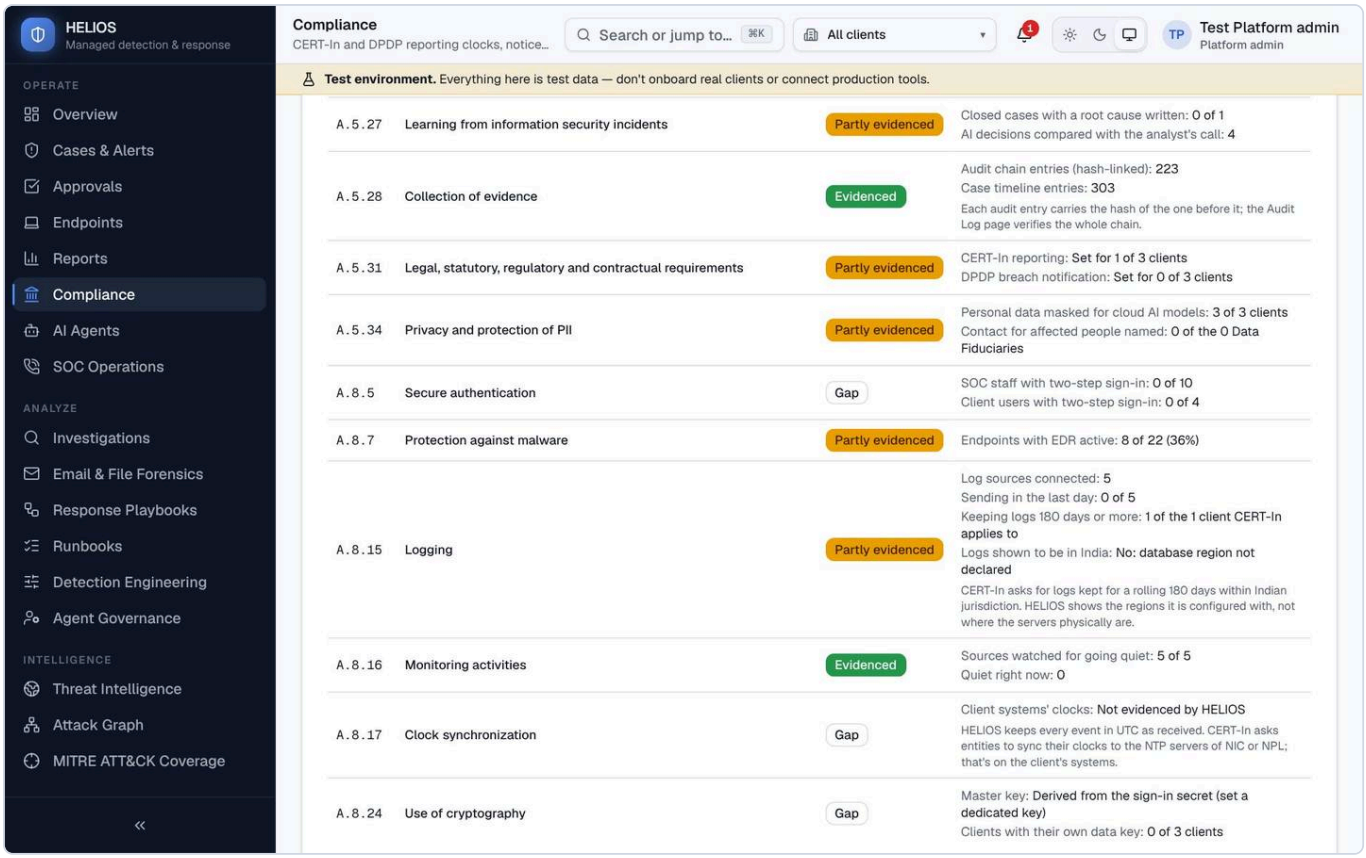


Figure 24. Compliance, further down the page.

4.8 AI Agents

The AI agents that work cases: what they did, how far they may act on their own, which models run them, and how those models scored.

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor

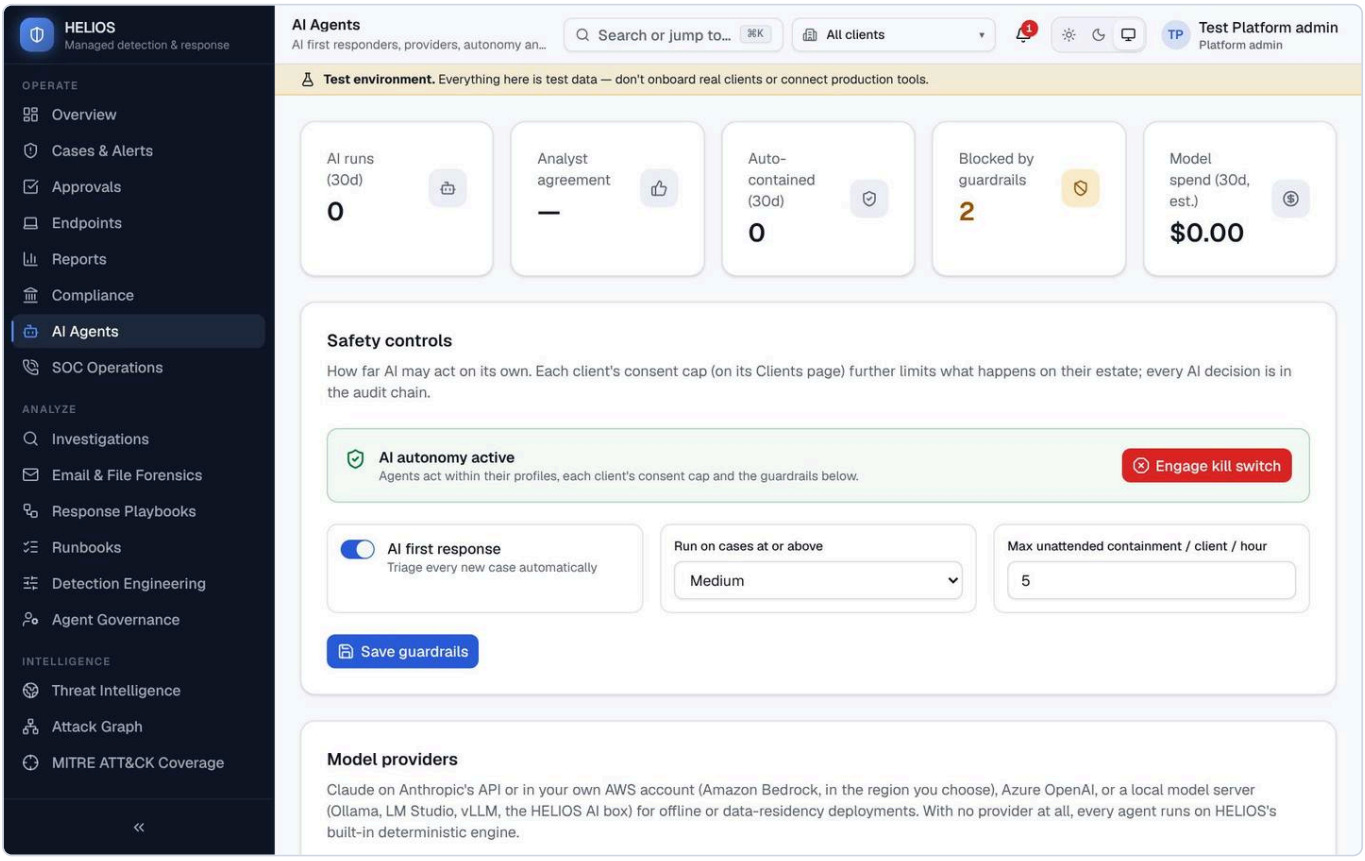


Figure 25. AI Agents (as platform admin).

How to use it

- The tiles show AI runs in the last 30 days, analyst agreement, actions contained automatically, actions the guardrails blocked and the estimated model spend (with the share of input read from the prompt cache).
- Safety controls: Engage kill switch stops all AI action at once; AI first response triages every new case at or above a severity; Max unattended containment caps automatic actions per client per hour. Admin, SOC manager
- Model providers: add Claude (Anthropic's API, or in your own AWS account through Amazon Bedrock), Azure OpenAI, or a local model server (Ollama, LM Studio, vLLM, the HELIOS AI box). Test checks the connection; Make default sets the model every agent uses unless told otherwise. Keys are encrypted and never shown again. Admin, SOC manager
- Agent types: for each agent choose the provider, a model override, the reasoning effort, the autonomy (off, suggest only, contain with approval, auto-contain pre-approved actions) and extra instructions. Admin, SOC manager
- Evaluations score a model on a labelled set (attacks, benign activity, look-alikes and planted instructions); the investigation agent is scored on worlds its tools search. A model a client or user picks only suggests until it passes for that agent. Admin, SOC manager
- The run log lists recent runs with their verdict, model, tokens and outcome.

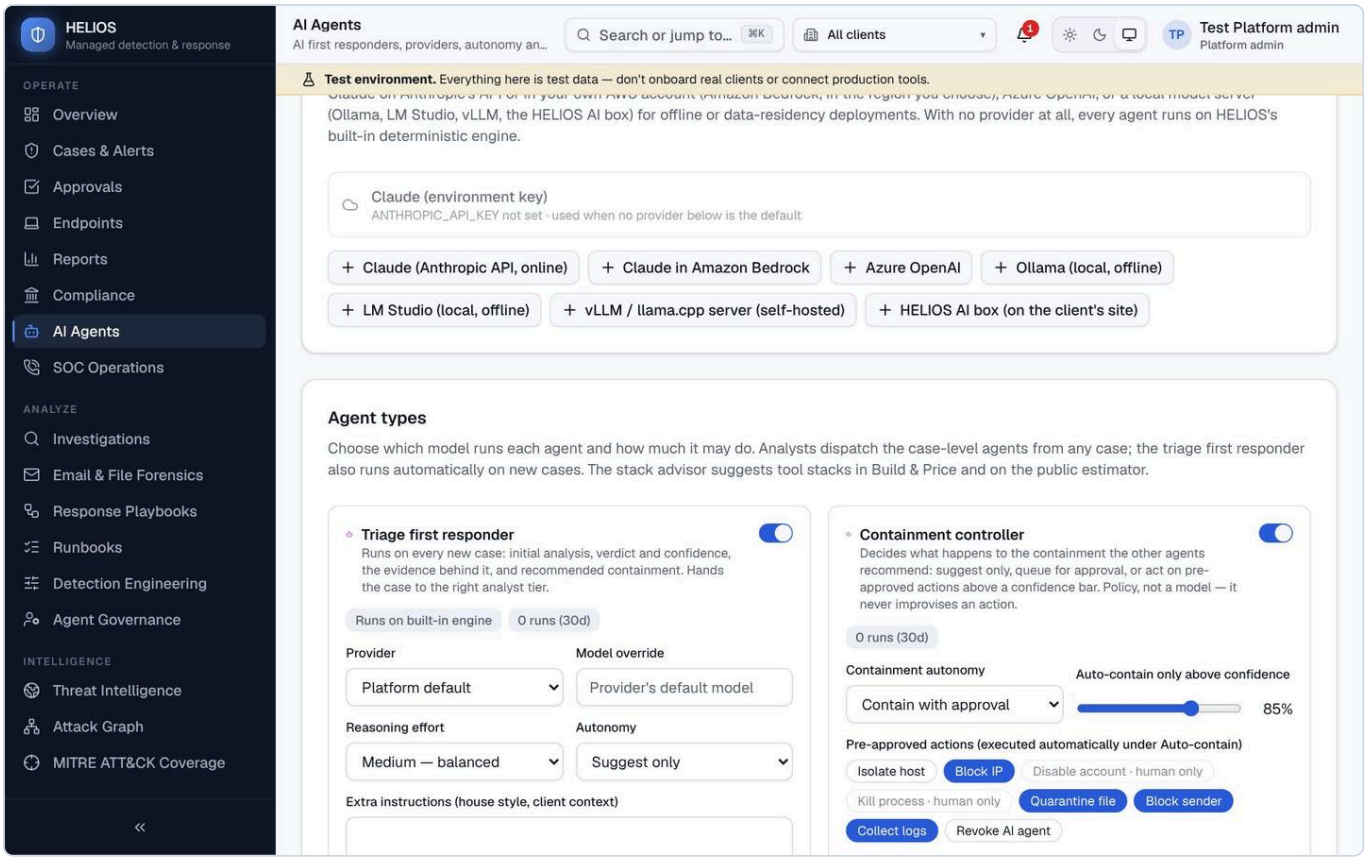


Figure 26. AI Agents, further down the page.

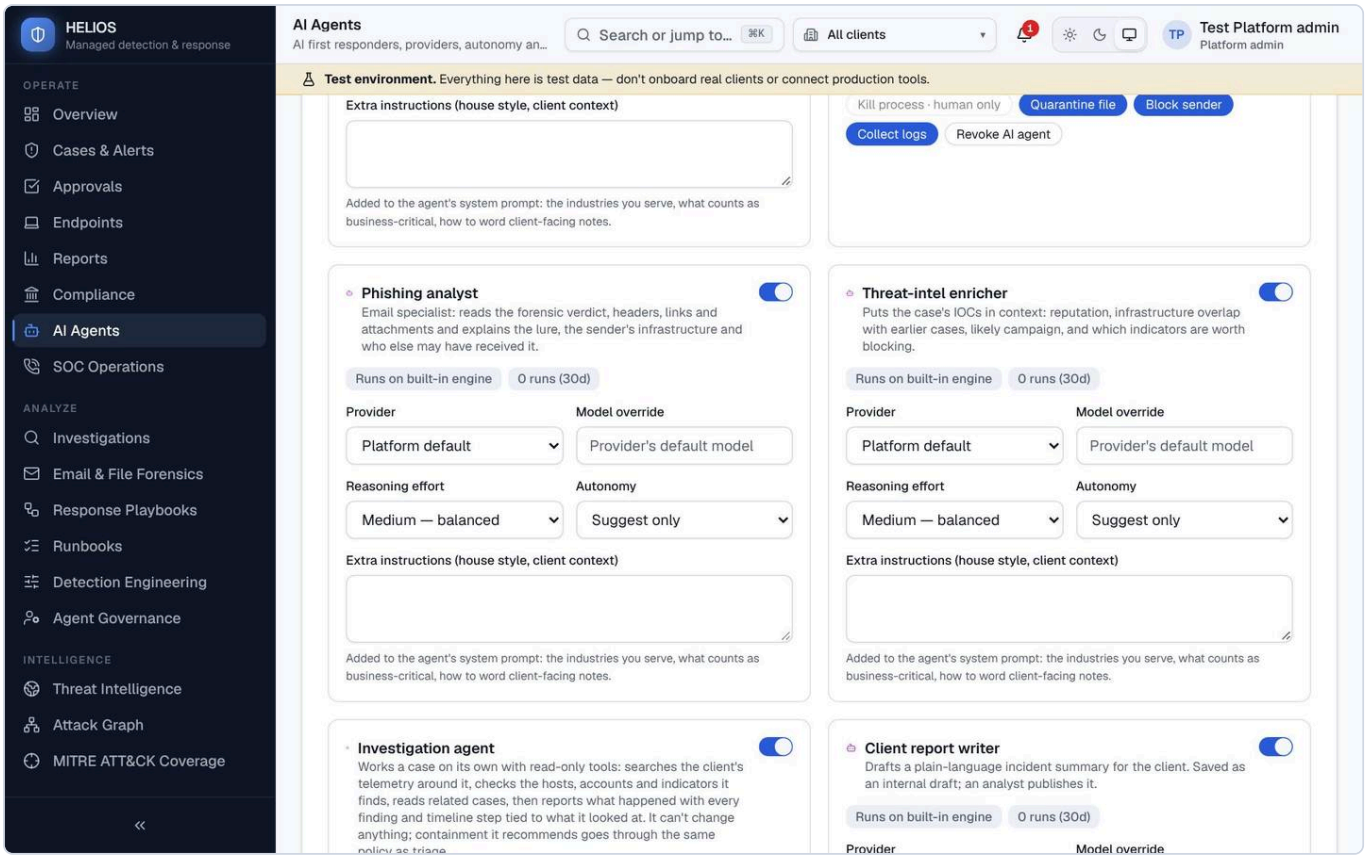


Figure 27. AI Agents, further down the page.

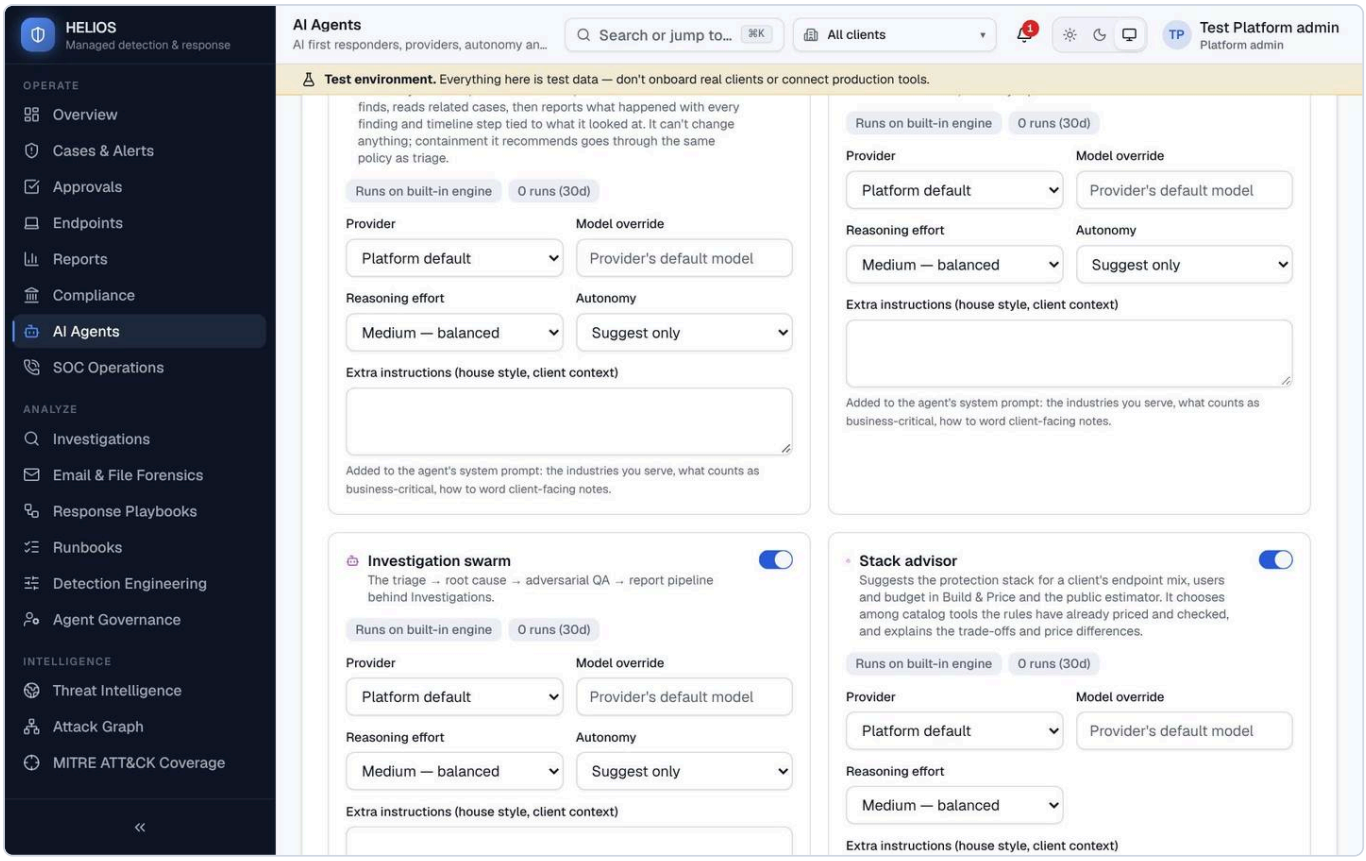


Figure 28. AI Agents, further down the page.

4.9 SOC Operations

Who is on call and the pages they get, the weekly QA of what the AI did on its own, and the daily digests.

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor

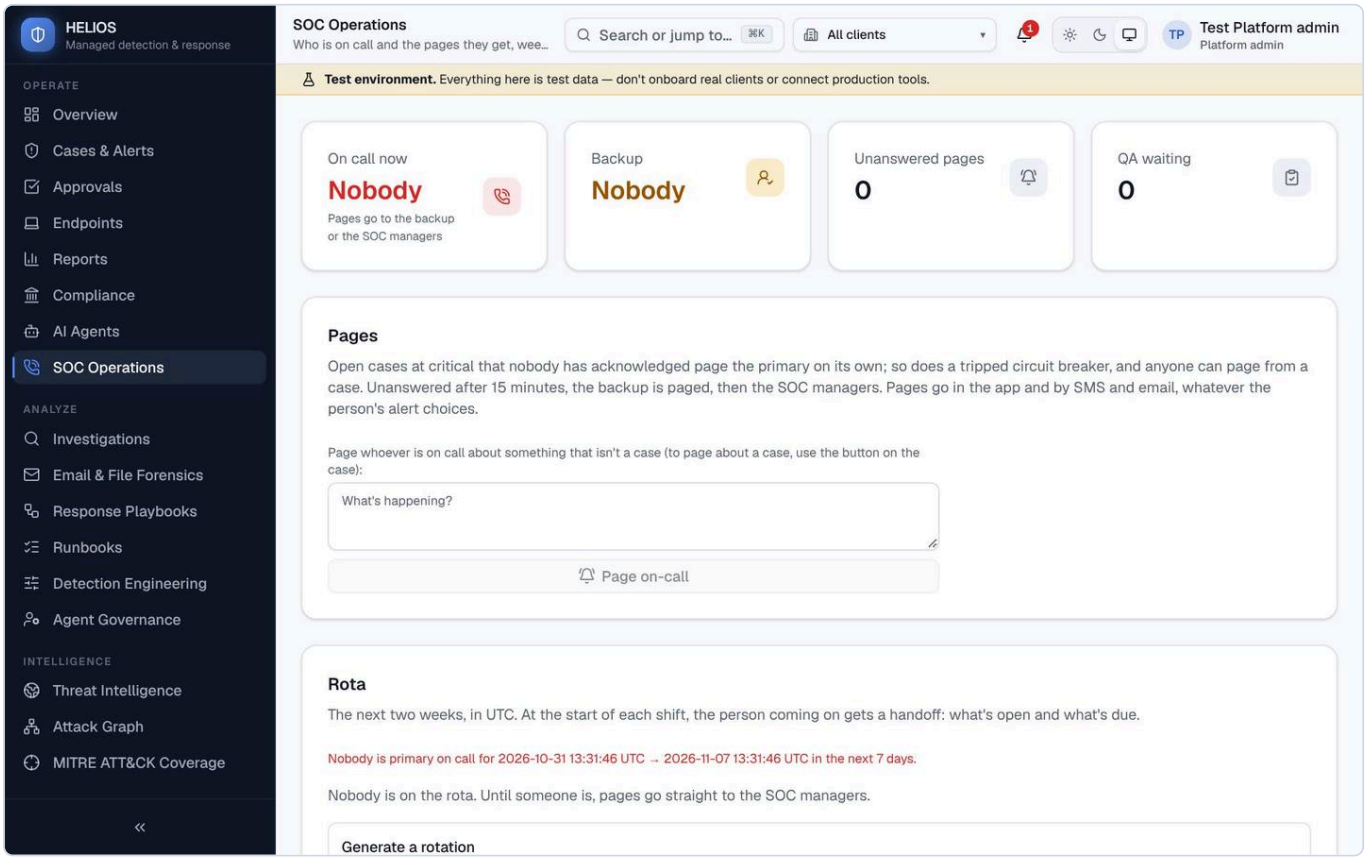


Figure 29. SOC Operations (as platform admin).

How to use it

- The tiles show who is primary and backup on call now, unanswered pages and QA reviews waiting.
- Pages: open critical cases nobody acknowledged page the primary on their own; unanswered after the acknowledgement window (15 minutes by default) the backup is paged, then the SOC managers. Pages go in the app and by SMS and email. Page on-call sends a page about something that isn't a case.
  Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter
- Rota: Generate a rotation from people taking turns (8, 12 or 24-hour shifts, or a week); add cover for a swap or leave. Whoever starts a shift gets a handoff: open high and critical cases, unanswered pages, approvals waiting, notices due, quiet sources. Admin, SOC manager, Tier 3
- QA: each Monday HELIOS samples last week's cases where the AI acted without anyone approving or called a case benign (weighted towards critical cases, new rules and critical assets). Review each one on the case: should the action have run, was the verdict right. A 'shouldn't have run' counts against the AI's autonomy at once. Admin, SOC manager, Tier 3
- Settings: paging severity, acknowledgement window, QA share and floor, and the digest time and time zone.
  Admin, SOC manager, Tier 3

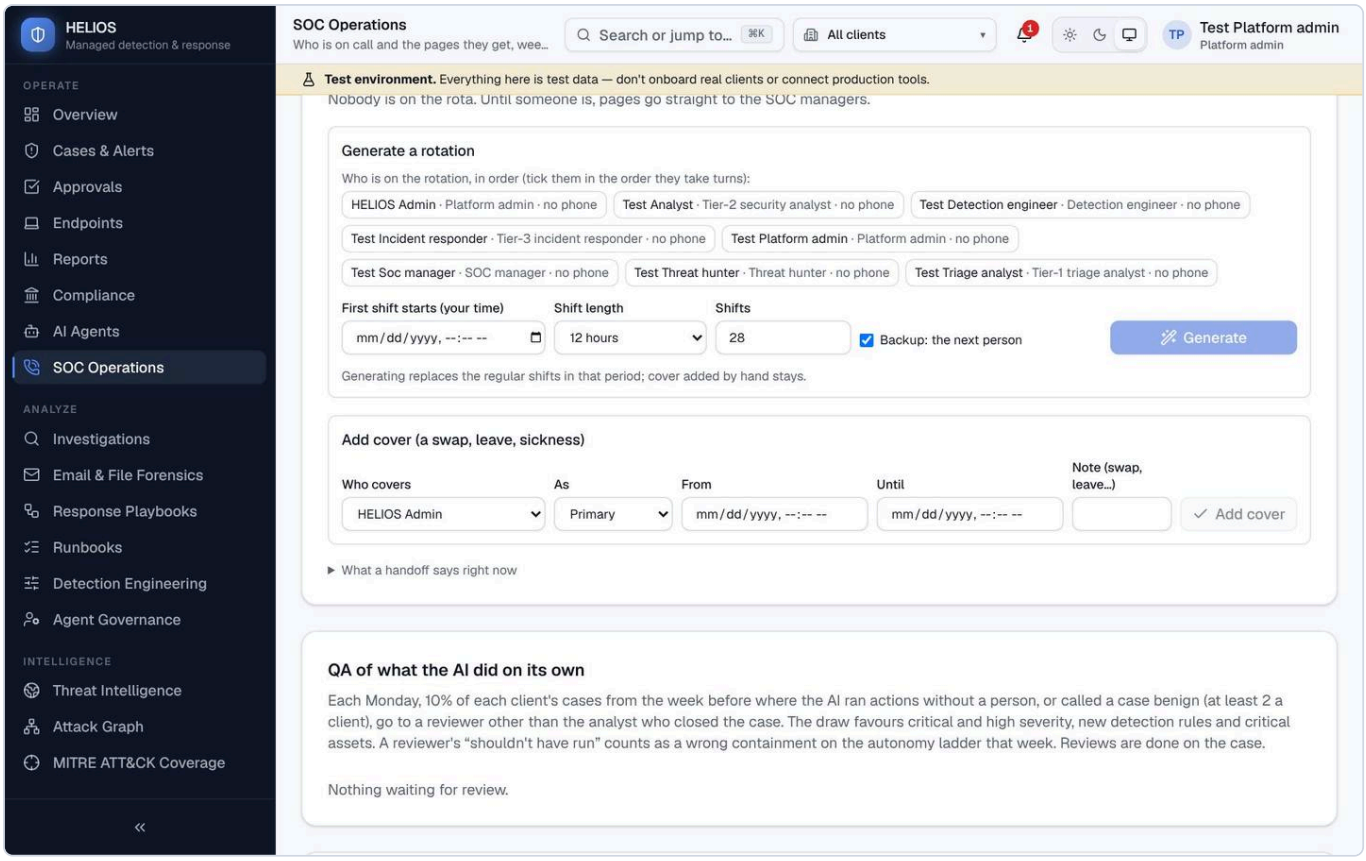


Figure 30. SOC Operations, further down the page.

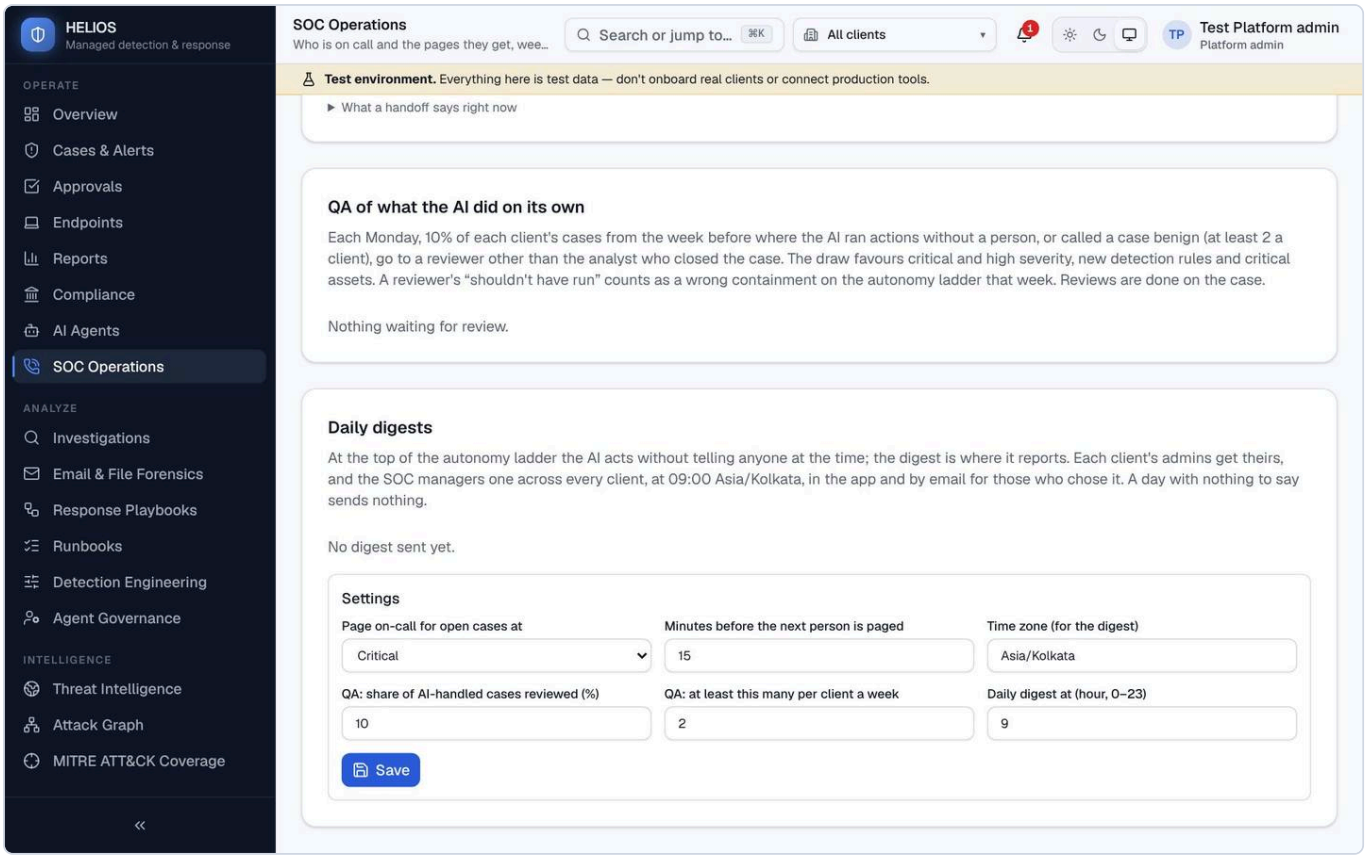


Figure 31. SOC Operations, further down the page.

4.10 Investigations

Upload logs from an incident and get a root-cause analysis: an agent pipeline (triage, root cause, adversarial QA, report) works through them and opens a case with the findings.

Who can open it: Admin, SOC manager, Tier 2, Tier 3, Hunter

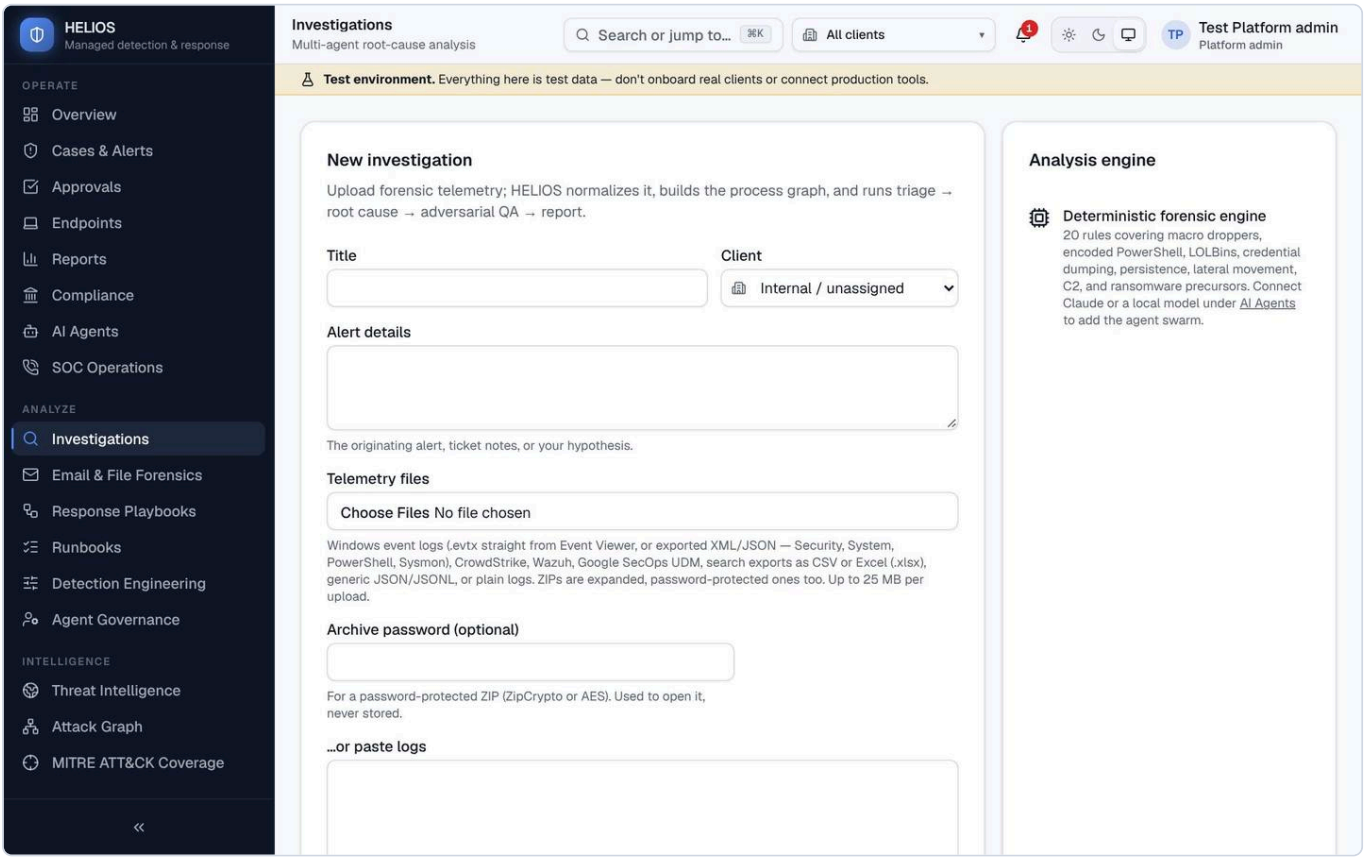


Figure 32. Investigations (as platform admin).

How to use it

- New investigation: a title, the client, the alert details (the originating alert, ticket notes or your hypothesis), and the telemetry files: Windows event logs (.evtx, or exported XML/JSON), EDR and SIEM exports, CSV or Excel, JSON/JSONL, plain logs, or a .zip (password-protected ones too, with the archive password, which isn't stored). Up to 25 MB per upload; or paste the logs.
- HELIOS normalizes the telemetry, builds the process graph and runs triage, root cause, adversarial QA and the report. Without a model it uses its deterministic forensic engine (20 rules for droppers, encoded PowerShell, living-off-the-land binaries, credential dumping, persistence, lateral movement, C2 and ransomware precursors).
- Open a past investigation to read its timeline, root cause, the adversarial QA's challenges and the report.

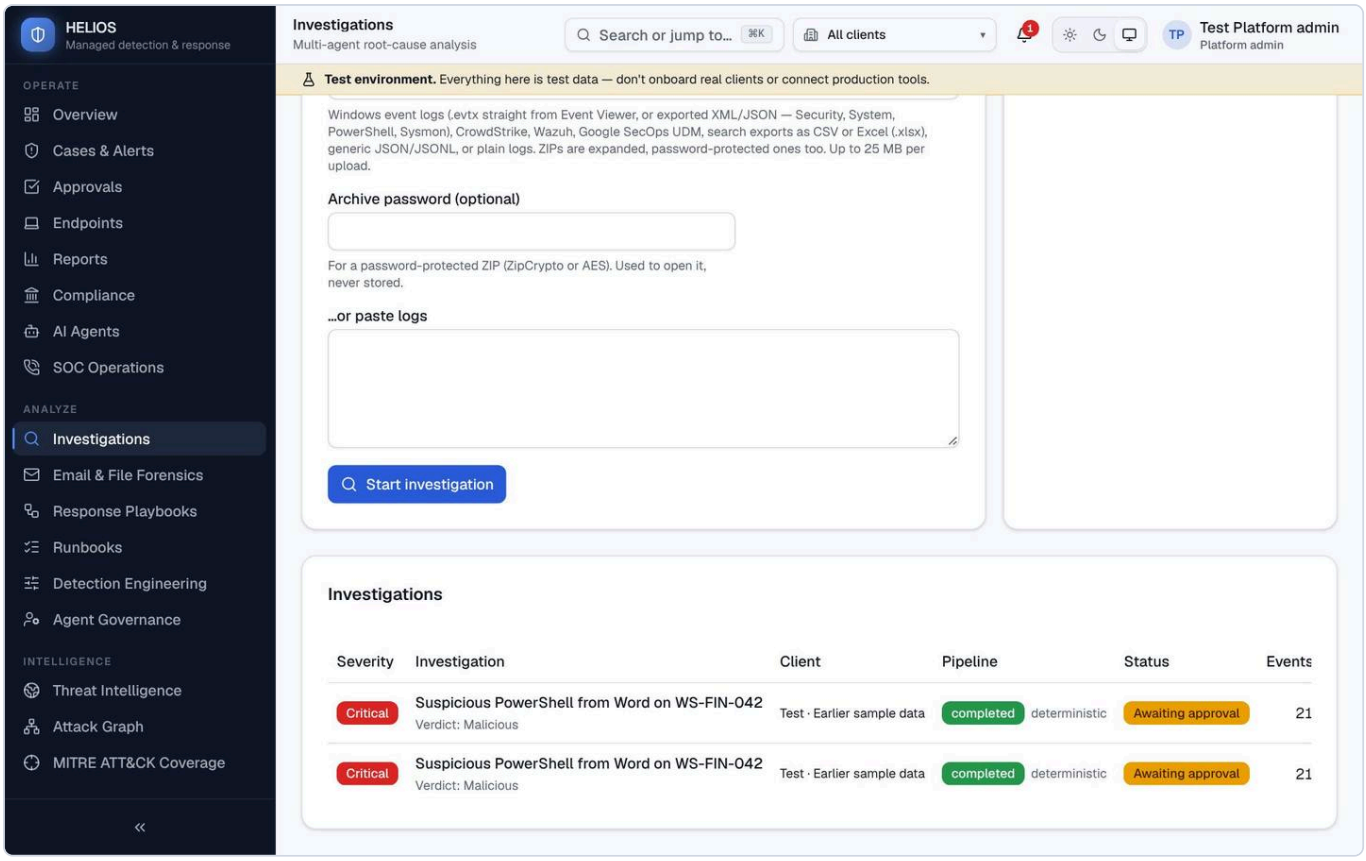


Figure 33. Investigations, further down the page.

4.11 Email & File Forensics

Submit a suspicious email or file for analysis: header authentication, links, attachments, macros, archives and images are examined and scored to a verdict.

Who can open it: Admin, SOC manager, Tier 2, Tier 3, Hunter

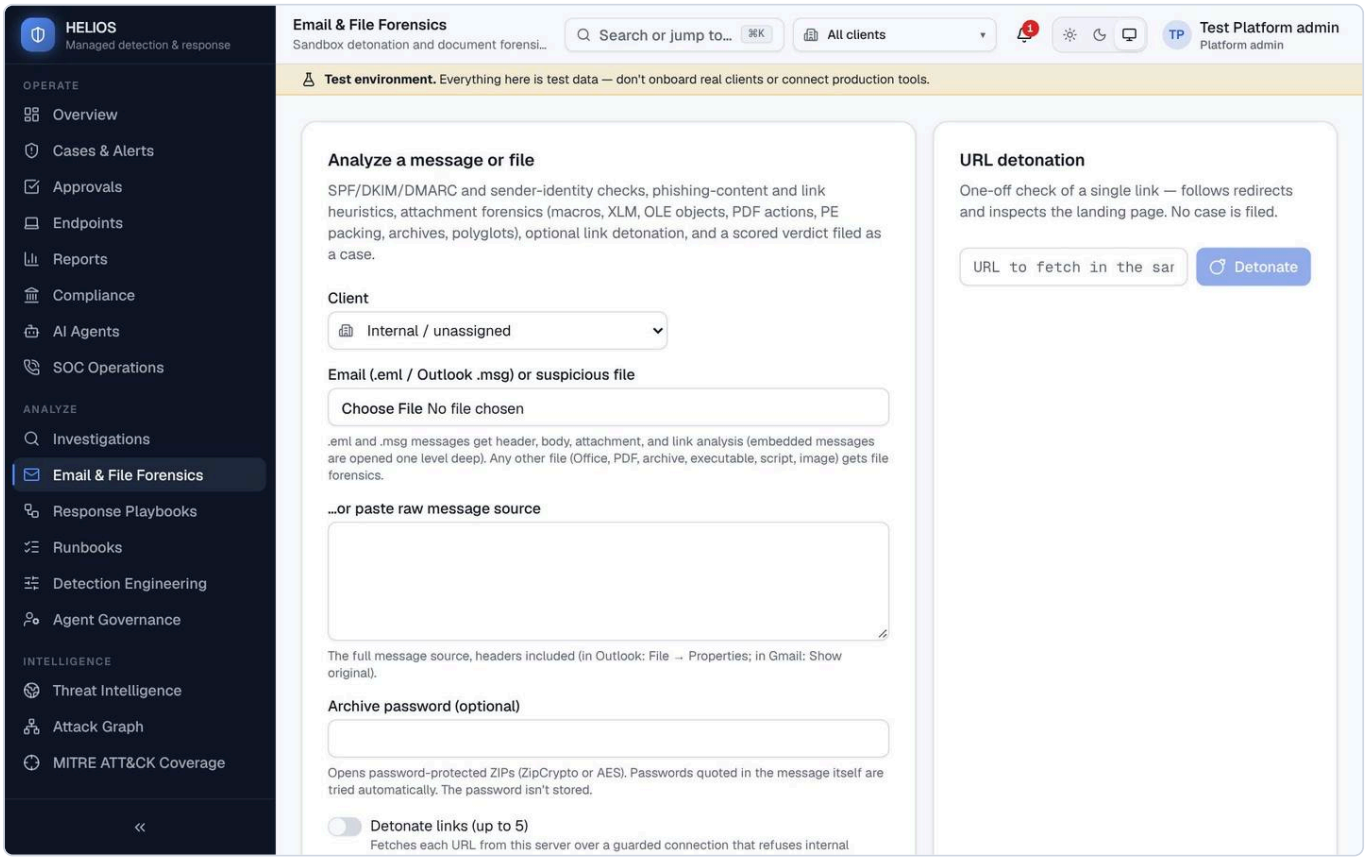


Figure 34. Email & File Forensics (as platform admin).

How to use it

- Analyze a message or file: choose the client, then the .eml or Outlook .msg (or any suspicious file), or paste the raw message source. Give an archive password if it's a protected ZIP (it isn't stored), and switch on Detonate links (up to 5) if you want links fetched through the guarded connection.
- HELIOS checks the sender's authentication (SPF, DKIM, DMARC) and identity, phishing content and links, attachments (macros, OLE objects, PDF actions, packing, archives, polyglots) and text and QR codes in images. URL detonation on the right checks a single link without filing a case.
- The verdict comes from the total score across the header, content, attachment, sandbox, intel and sender checks, against the suspicious and malicious thresholds set in Settings. A malicious result opens a case, where the message can be purged from mailboxes and the sender blocked.

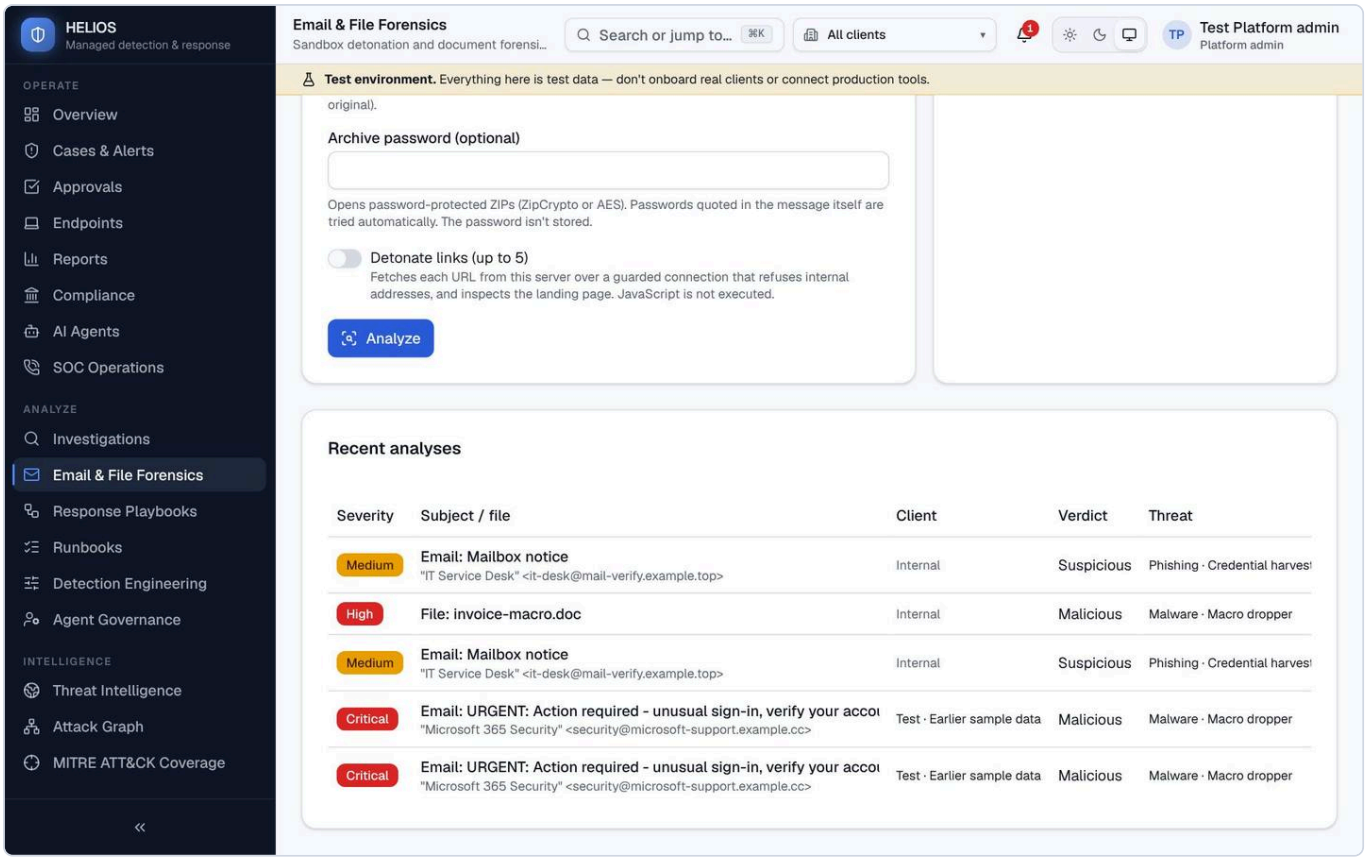


Figure 35. Email & File Forensics, further down the page.

4.12 Response Playbooks

Automated response workflows: what triggers them and the steps they run (containment, collecting logs, notifying, opening tickets).

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor

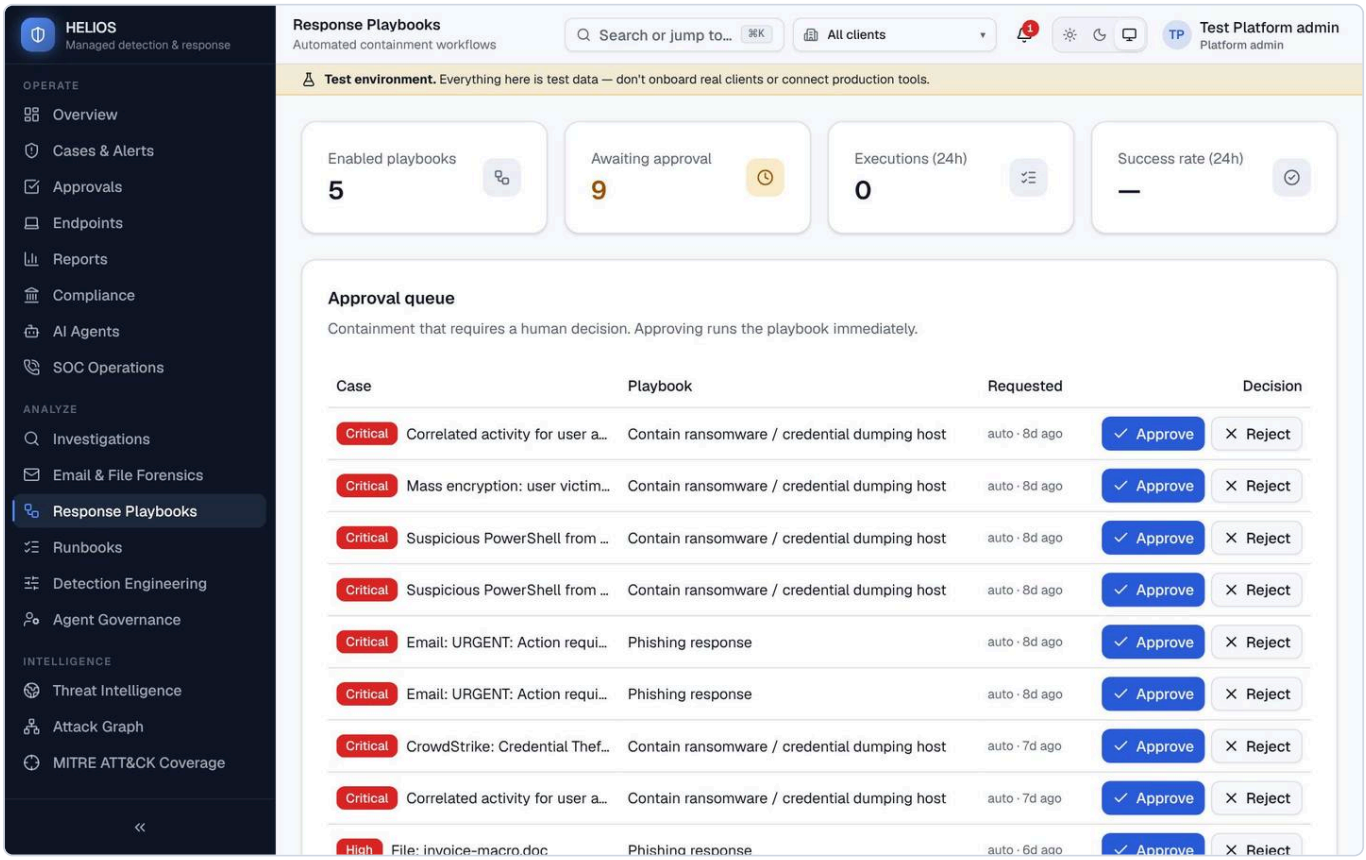


Figure 36. Response Playbooks (as platform admin).

How to use it

- Each playbook shows its trigger, its steps and whether it is enabled. Its runs appear on the cases they ran on; steps that need approval wait in Approvals, and steps without a connector are left to do by hand.
- Create or edit a playbook: name, trigger (severity, source, technique), and an ordered list of steps with their parameters. Enable it when it's ready. Admin, SOC manager, Detection eng.

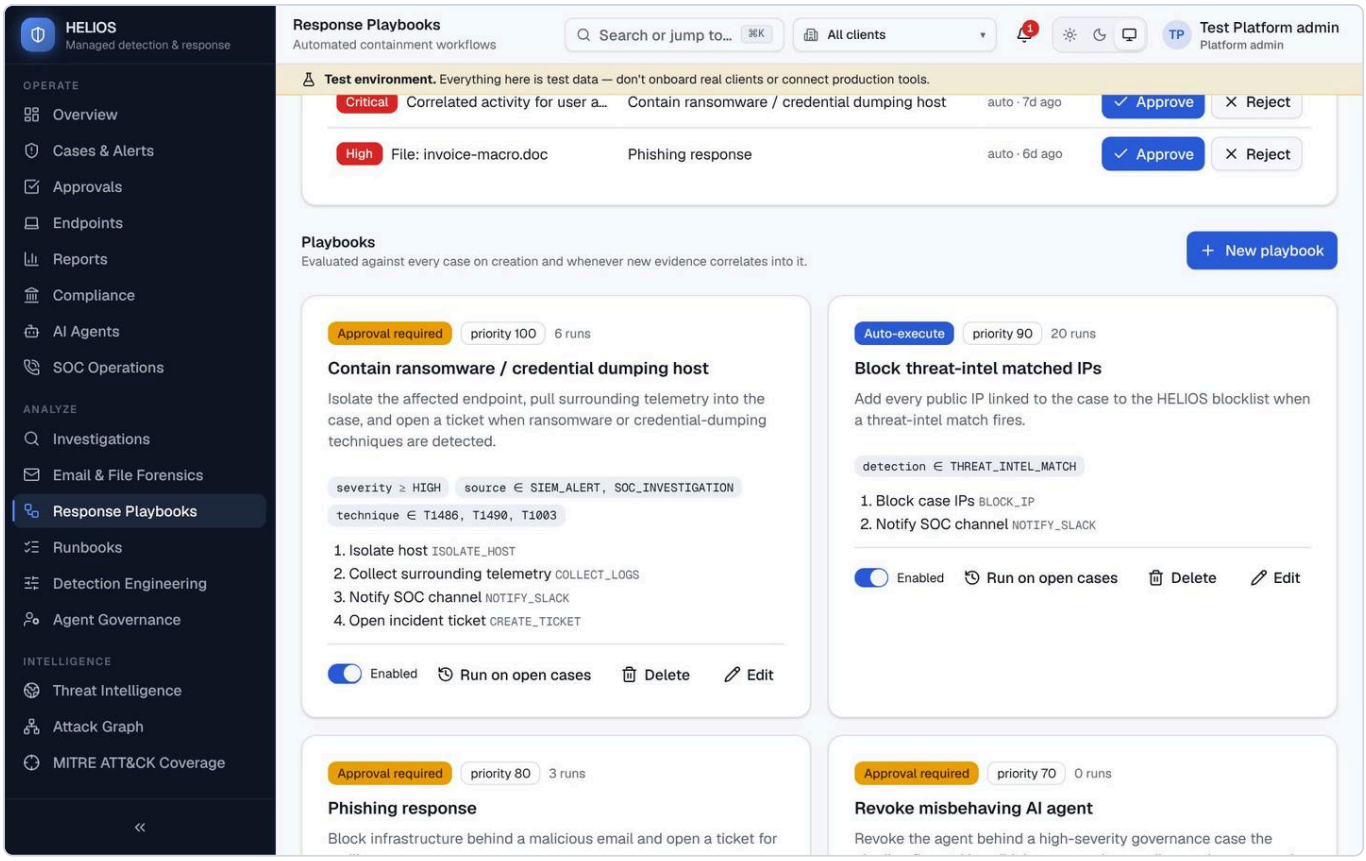


Figure 37. Response Playbooks, further down the page.

4.13 Runbooks

Procedures for analysts, attached to the cases they match and worked as checklists on the case.

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor

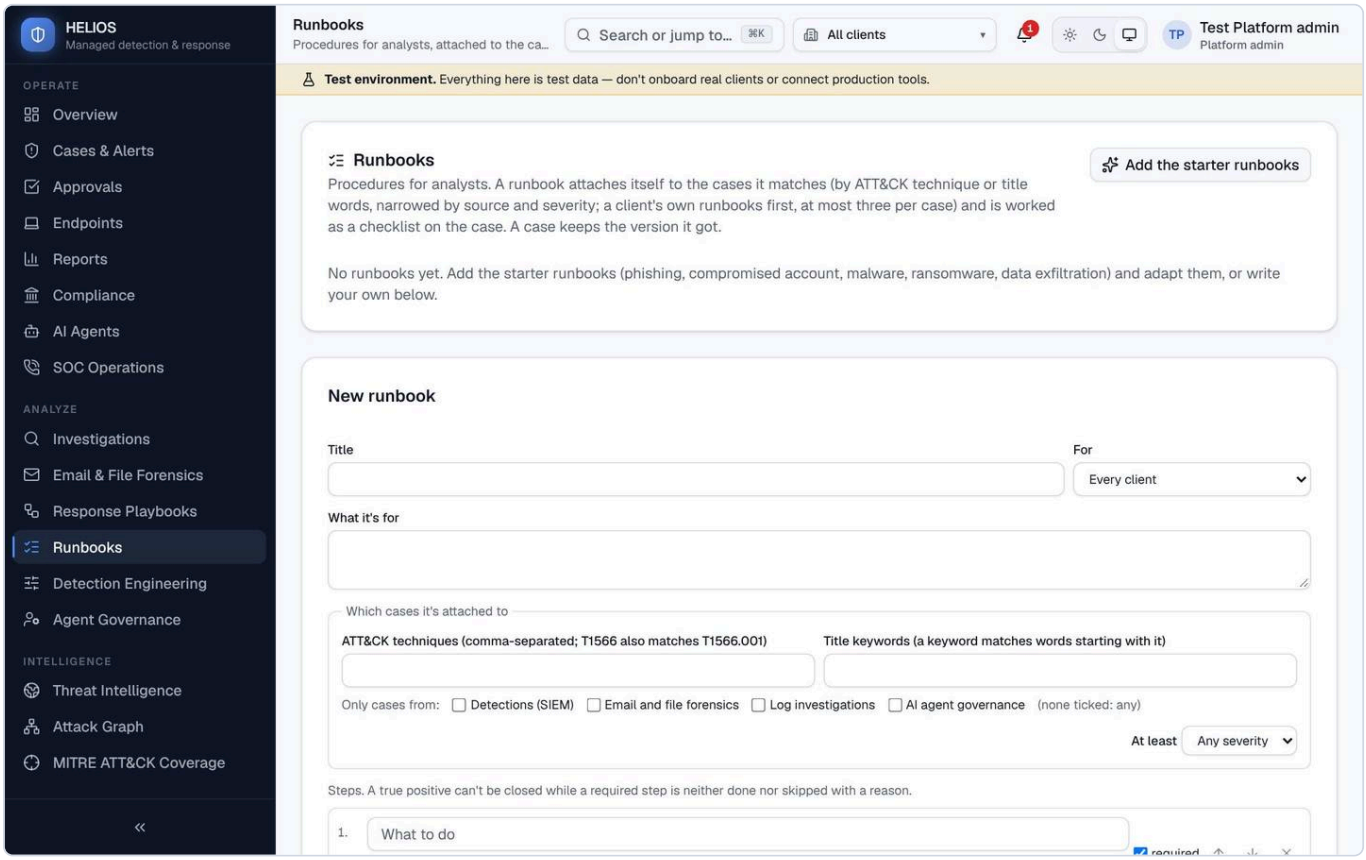


Figure 38. Runbooks (as platform admin).

How to use it

- A runbook matches cases by ATT&CK technique or title words, narrowed by source and minimum severity. Up to three matching runbooks attach to a case when it is opened, the client's own first.
- New runbook: a title, which client it's for (or every client), what it's for, the ATT&CK techniques and title keywords it matches, the sources and minimum severity, and its steps (tick required for steps a true positive can't close without). Add the starter runbooks to begin from phishing, compromised account, malware, ransomware and data exfiltration. Editing makes a new version; cases already attached keep the steps they had. Admin, SOC manager, Tier 3

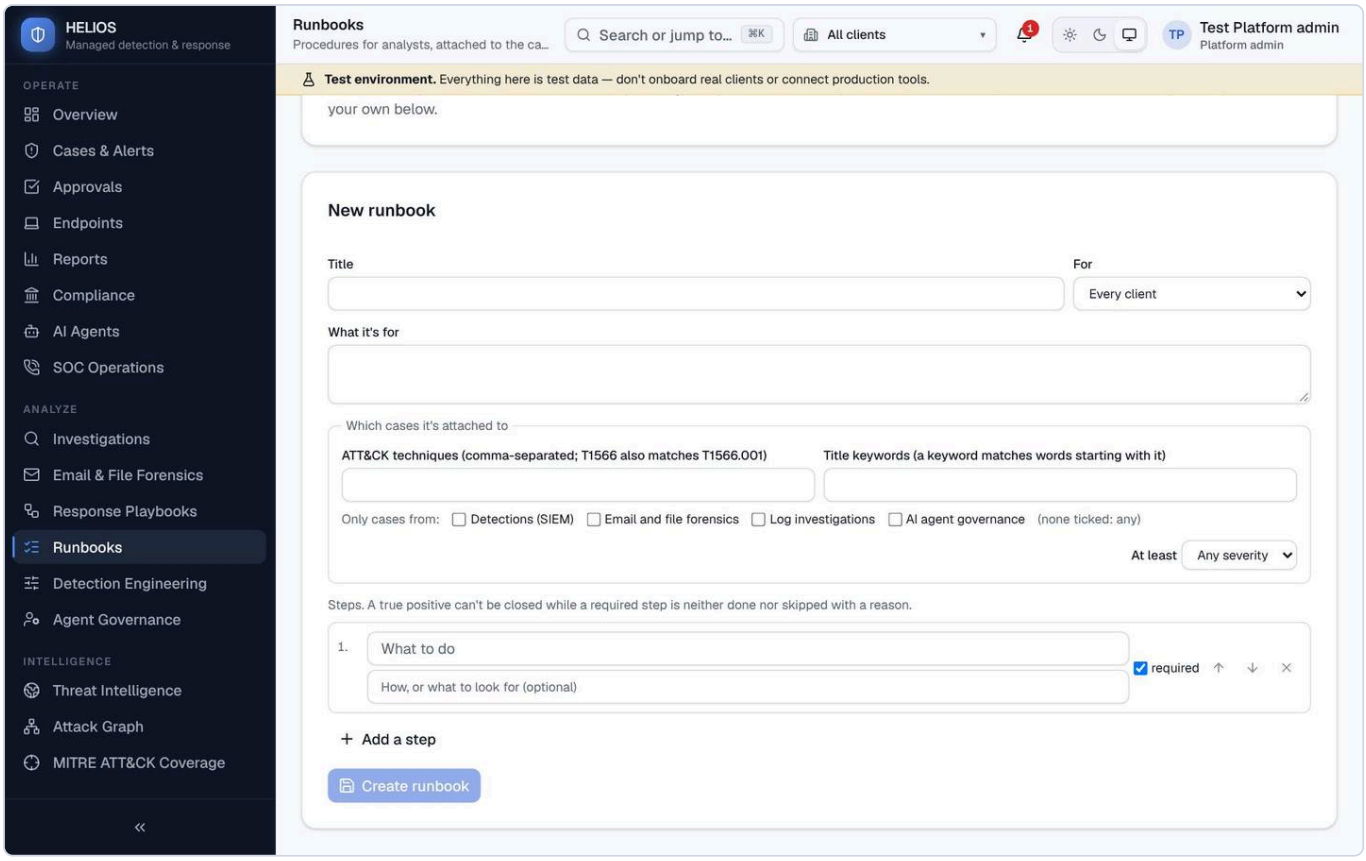


Figure 39. Runbooks, further down the page.

4.14 Detection Engineering

The detectors that turn telemetry into cases: the built-in detectors, imported Sigma rules tested before they go live, and per-client tuning.

Who can open it: Admin, SOC manager, Detection eng.

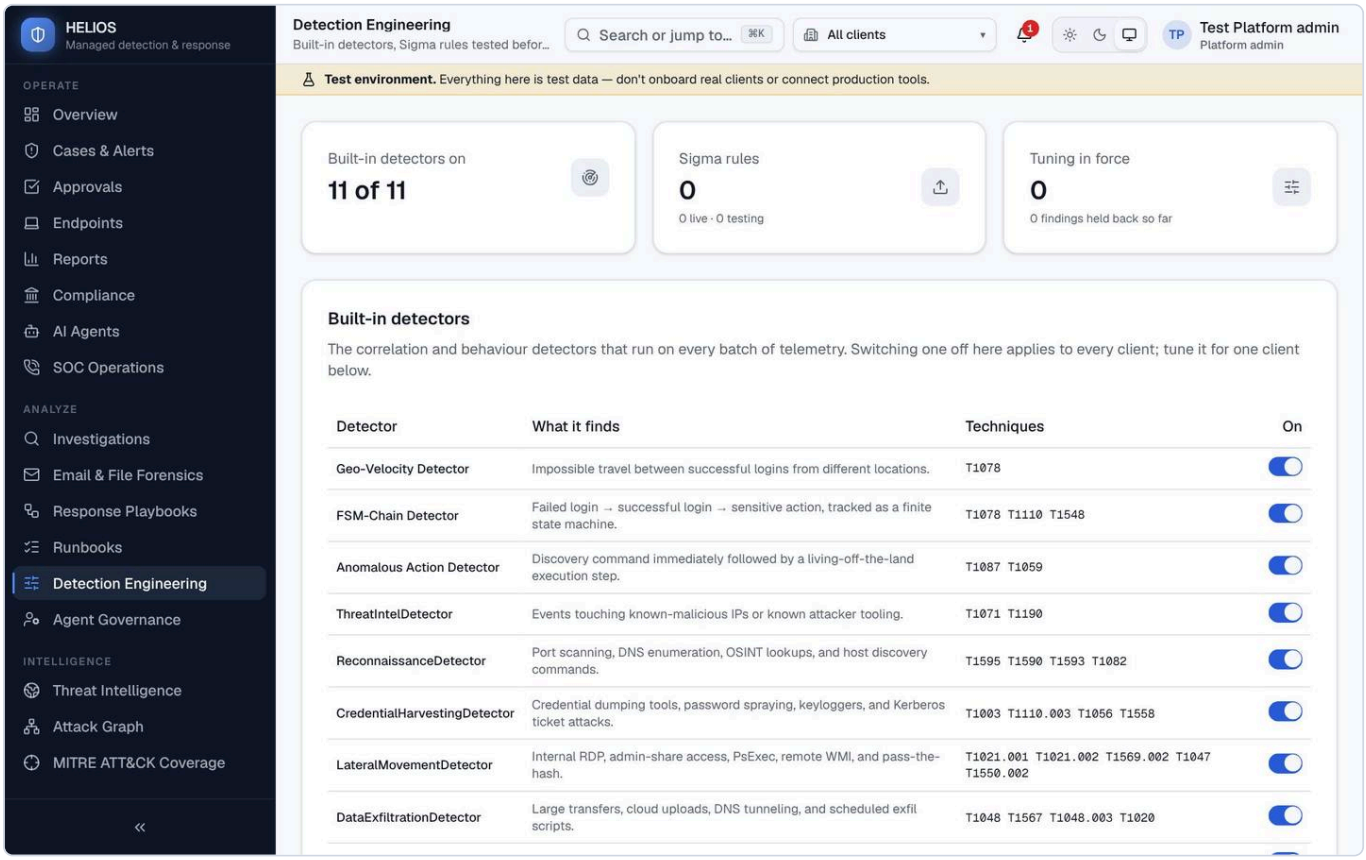


Figure 40. Detection Engineering (as platform admin).

How to use it

- Built-in detectors: switch one off for every client here (tune for one client below instead where you can).
- Import a Sigma rule: it is compiled into a matcher (anything it can't evaluate faithfully is refused with the reason), backtested on recent history, run in testing (matches counted, nothing opened) and then made live.
- Tune per client: switch a detector or rule off there, leave out known-good hosts, accounts or processes, or change the severity, each with a reason and an optional expiry. The count shows what tuning held back.

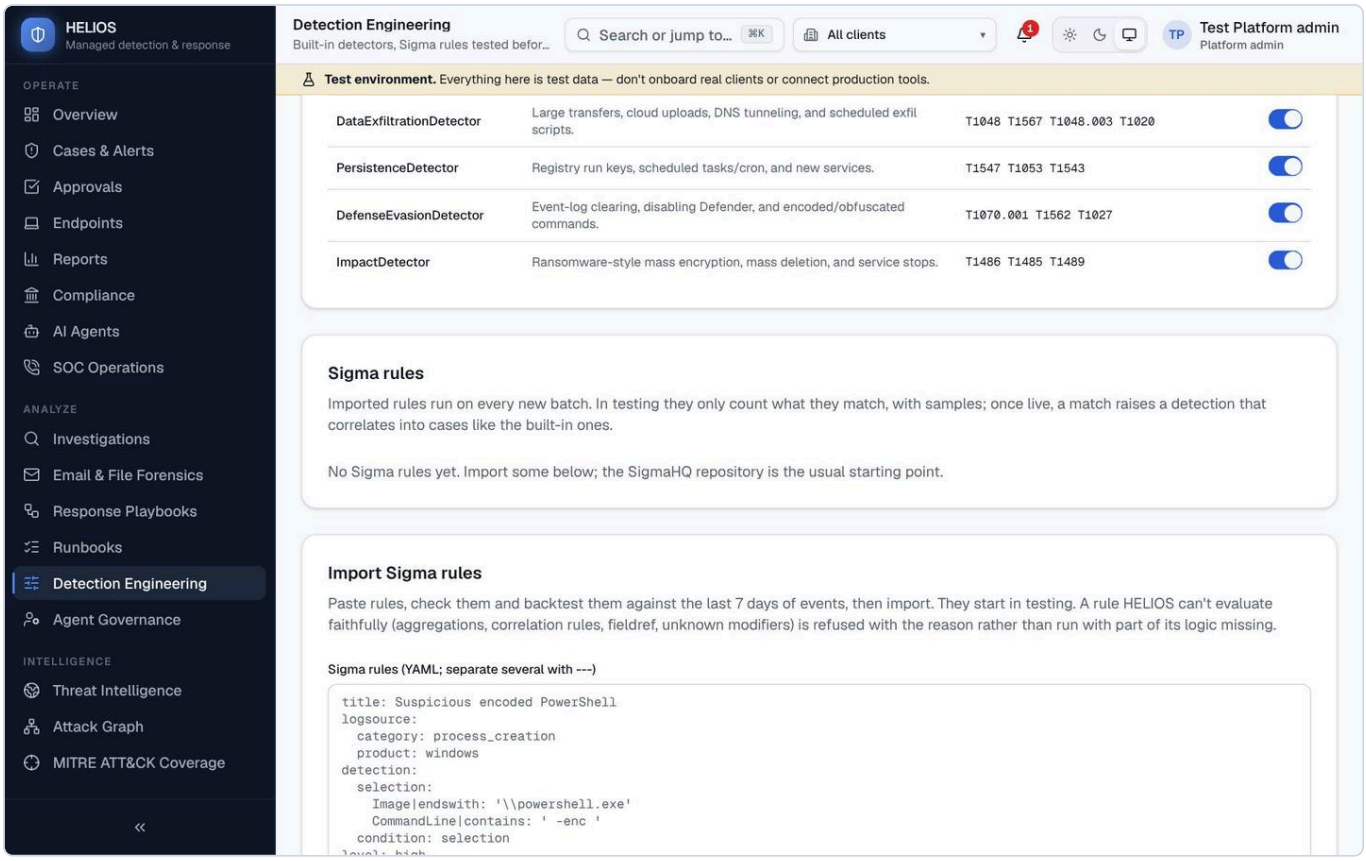


Figure 41. Detection Engineering, further down the page.

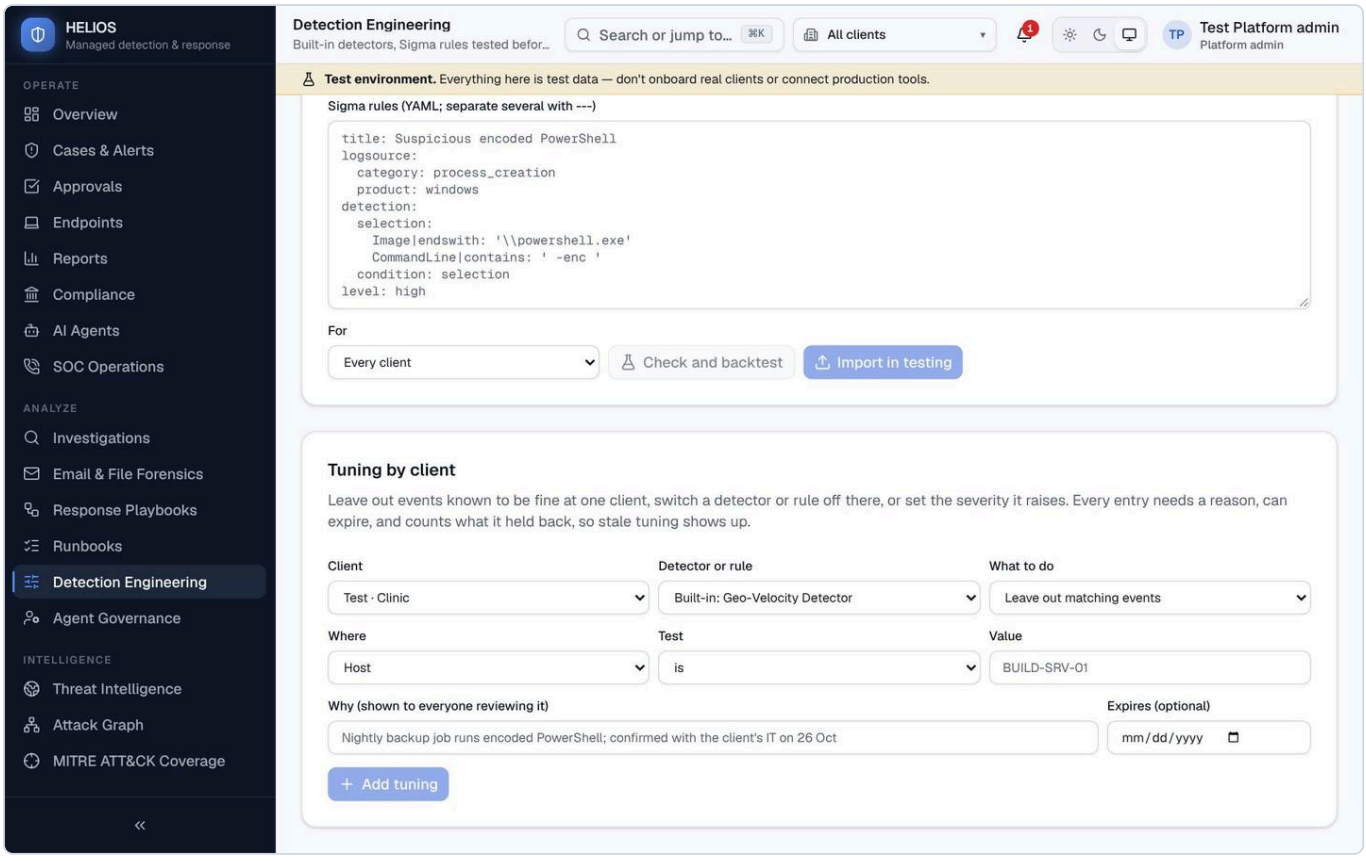


Figure 42. Detection Engineering, further down the page.

4.15 Agent Governance

Govern the AI agents your clients run: identities and tokens, the policies they act under, their trust, and revocation.

Who can open it: Admin, SOC manager, Tier 2, Tier 3

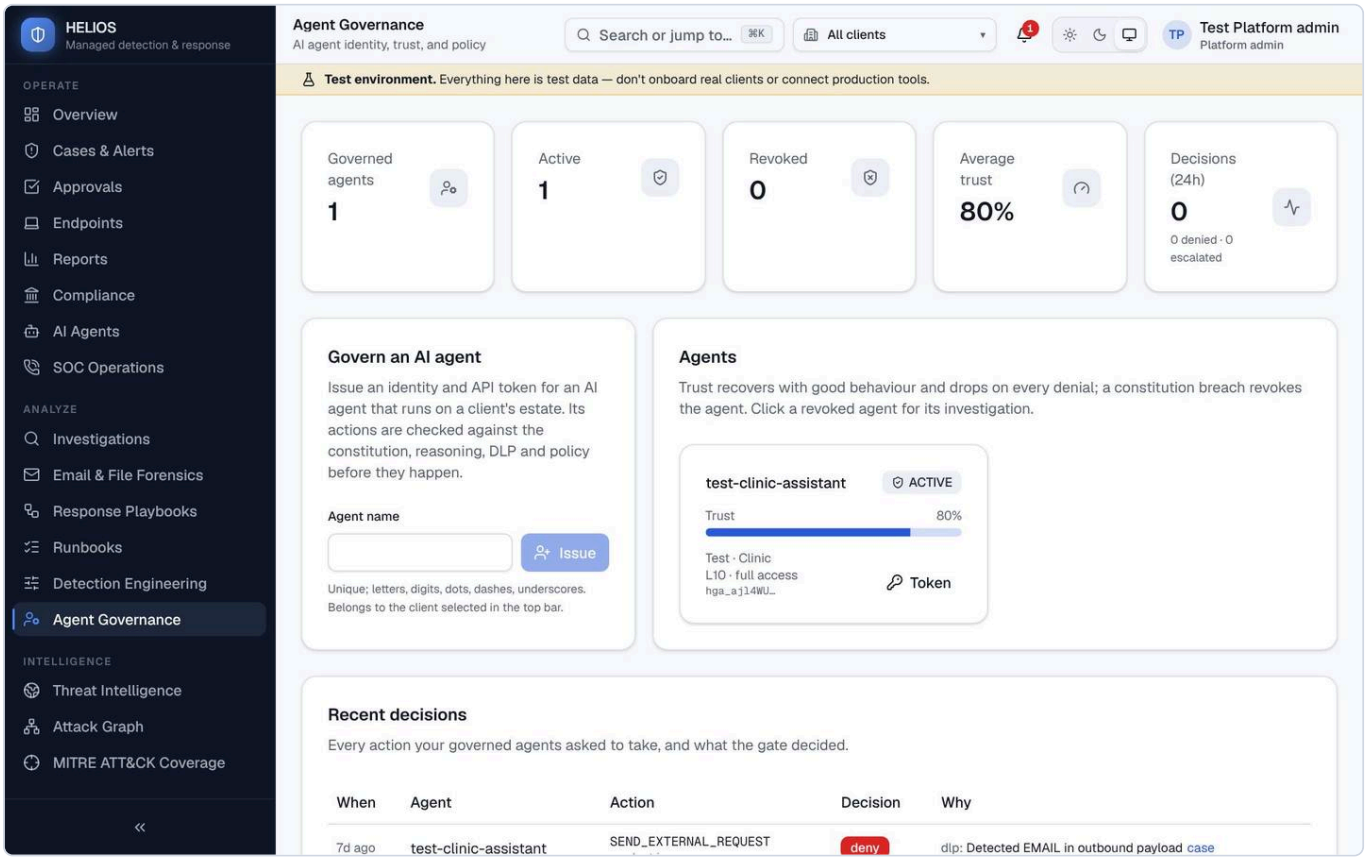


Figure 43. Agent Governance (as platform admin).

How to use it

- Govern an AI agent: enter the agent's name and Issue, for the client selected in the top bar. Its token is shown once. The agent asks HELIOS before each action; constitution, reasoning, data-loss and policy checks decide, and Recent decisions shows each request and why it was allowed or denied.
- Trust recovers with good behaviour and drops on every denial.
- A breach revokes the agent and opens a case. Revoke or restore an agent by hand here or from its case.

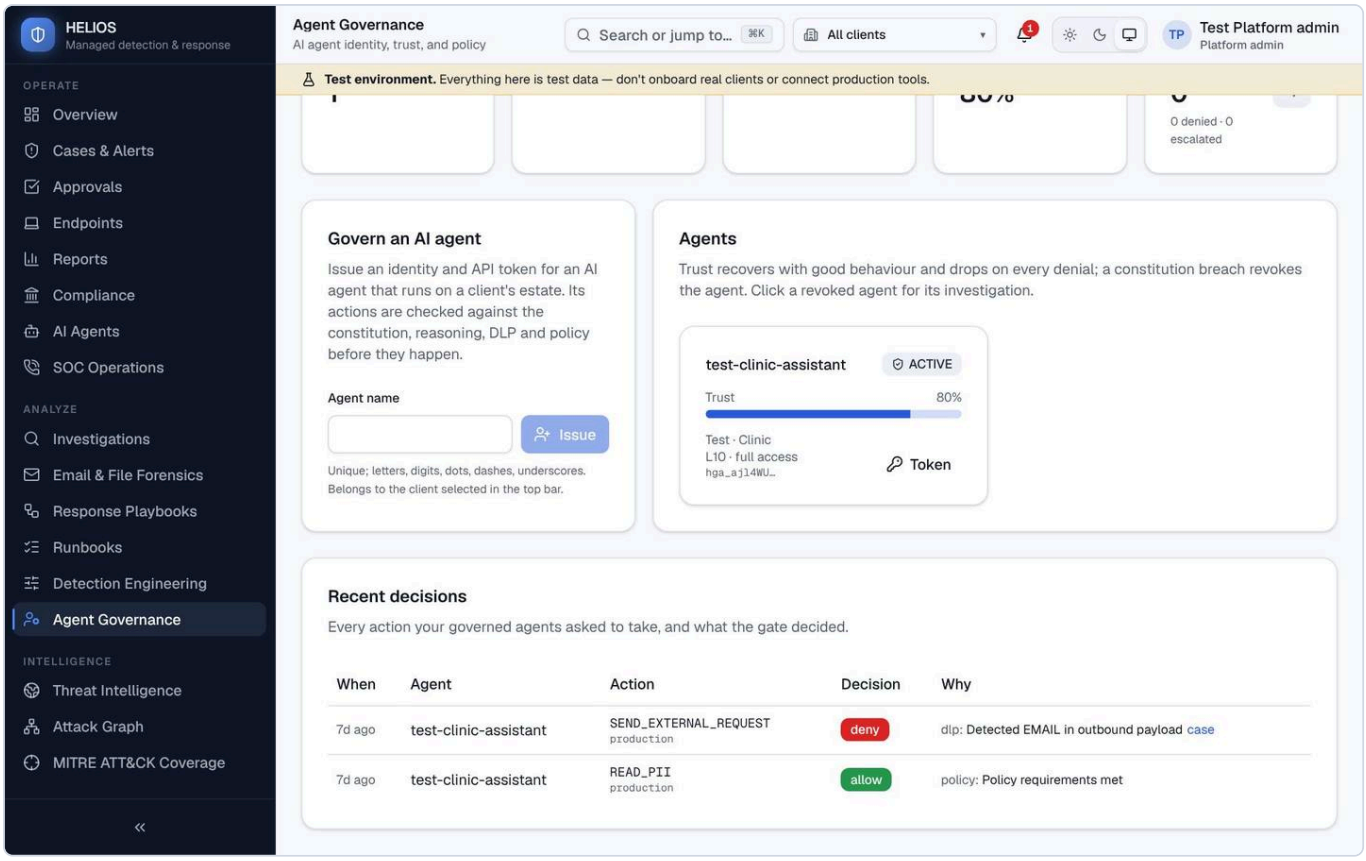


Figure 44. Agent Governance, further down the page.

4.16 Threat Intelligence

Look up indicators (IP, domain, URL, file hash, email address) against the SOC's indicator store, the configured reputation providers and the threat feeds.

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor

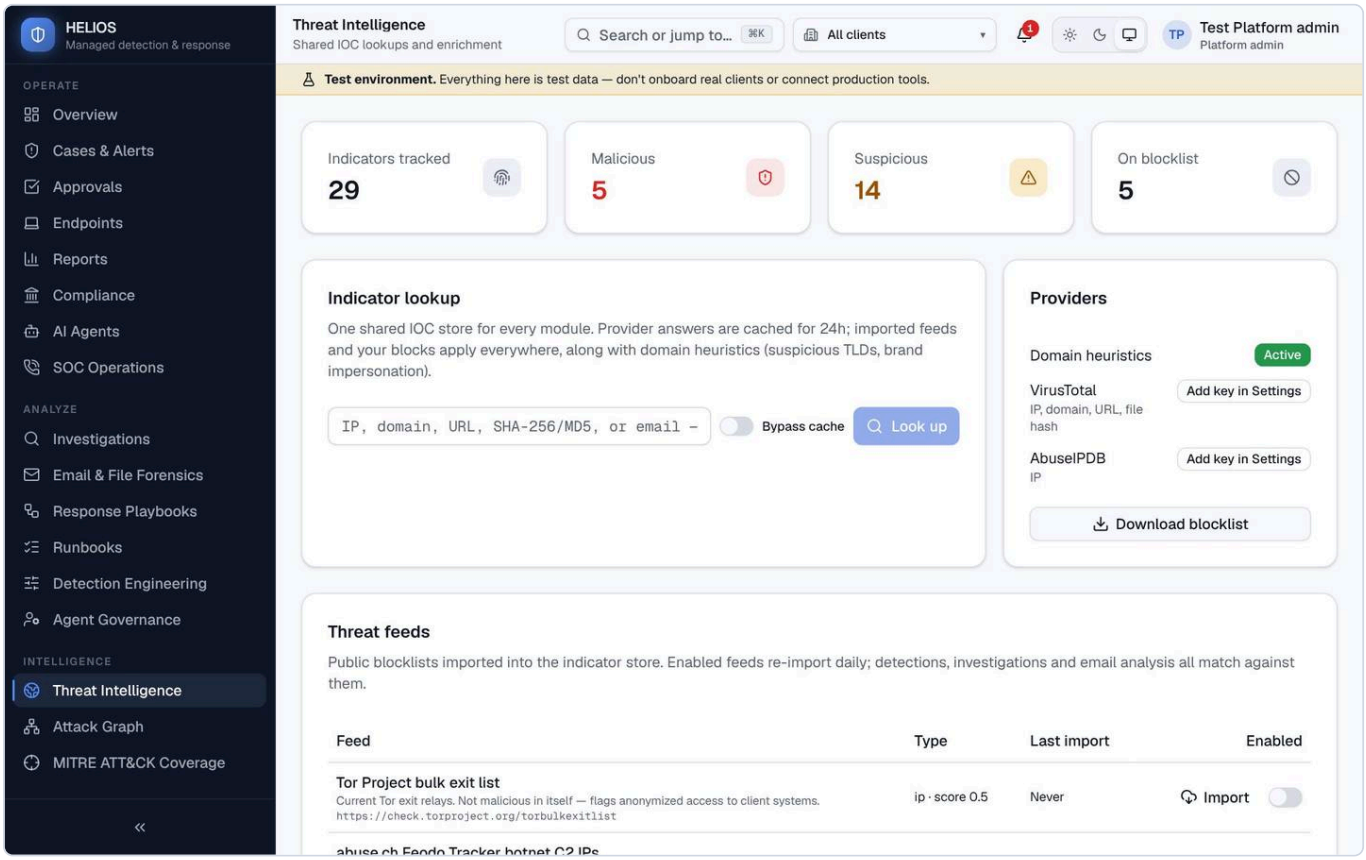


Figure 45. Threat Intelligence (as platform admin).

How to use it

- Paste an indicator (defanged forms like hxxp and [.] are fine) and Look up. The result shows the verdict, score, sources, why, and for an IP where it is (country, city and network, from the server's GeoIP database). Results are cached for 24 hours; Bypass cache forces a fresh lookup.
- Block or unblock an indicator: the blocklist feeds detections and firewalls that pull it. Enable and import threat feeds. Admin, SOC manager, Tier 2, Tier 3, Hunter

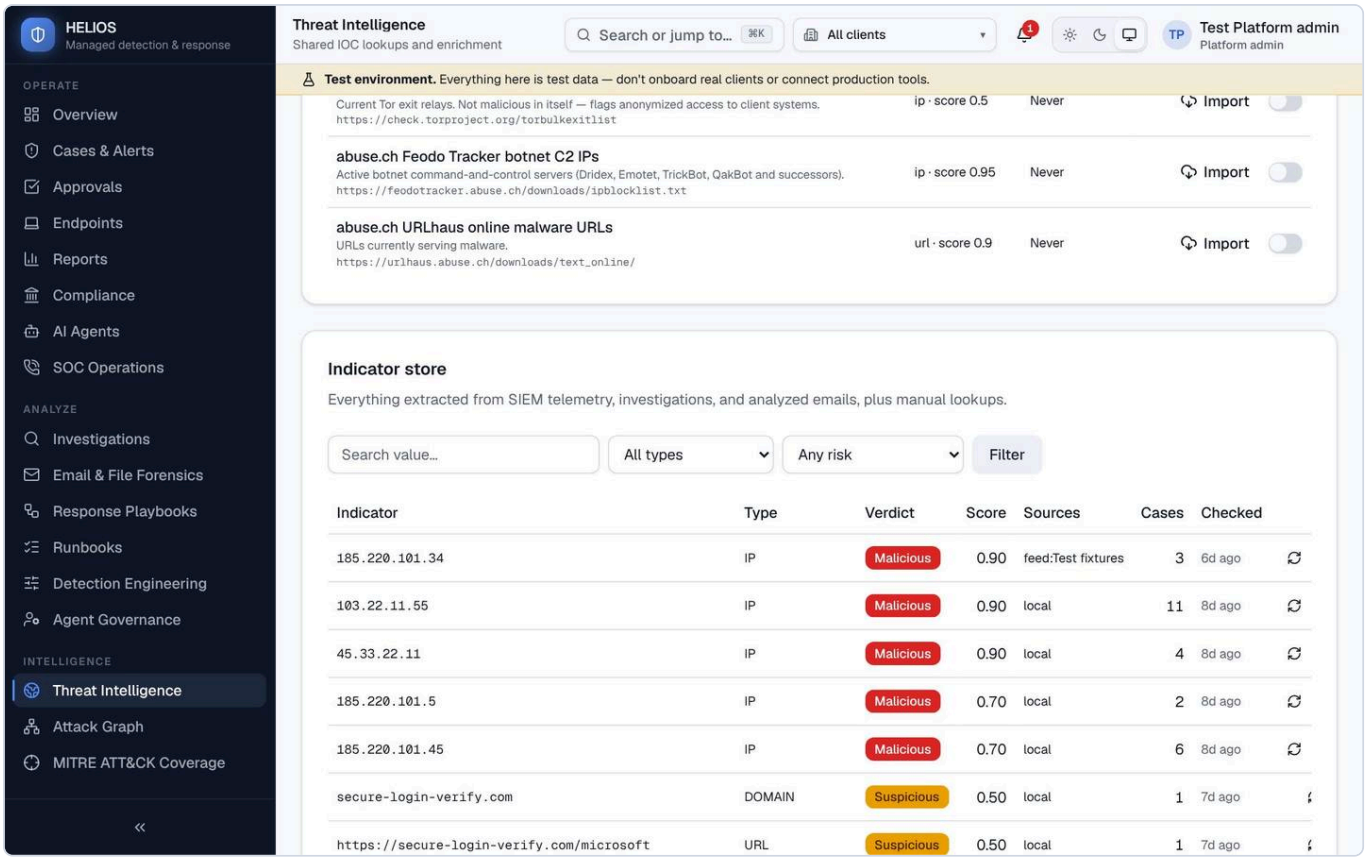


Figure 46. Threat Intelligence, further down the page.

4.17 Attack Graph

Cases joined by the hosts, accounts, addresses, indicators and agents they share. An entity is an attack chain when its cases together reach more ATT&CK tactics than any one alone.

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor, Client admin, Client viewer

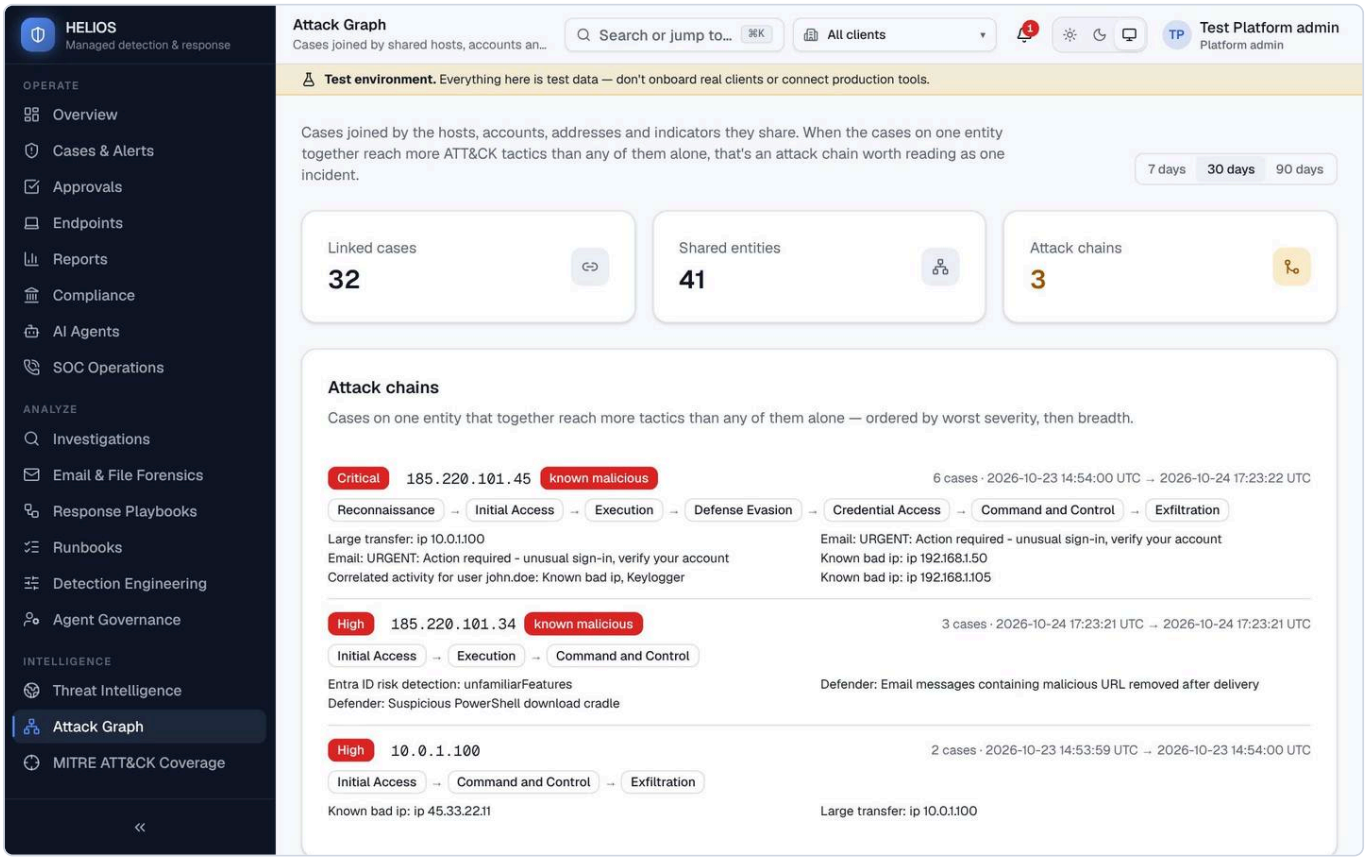


Figure 47. Attack Graph (as platform admin).

How to use it

- Hover or click a node to see the cases behind it; follow chains across tactics to see an intrusion that several smaller cases make up.

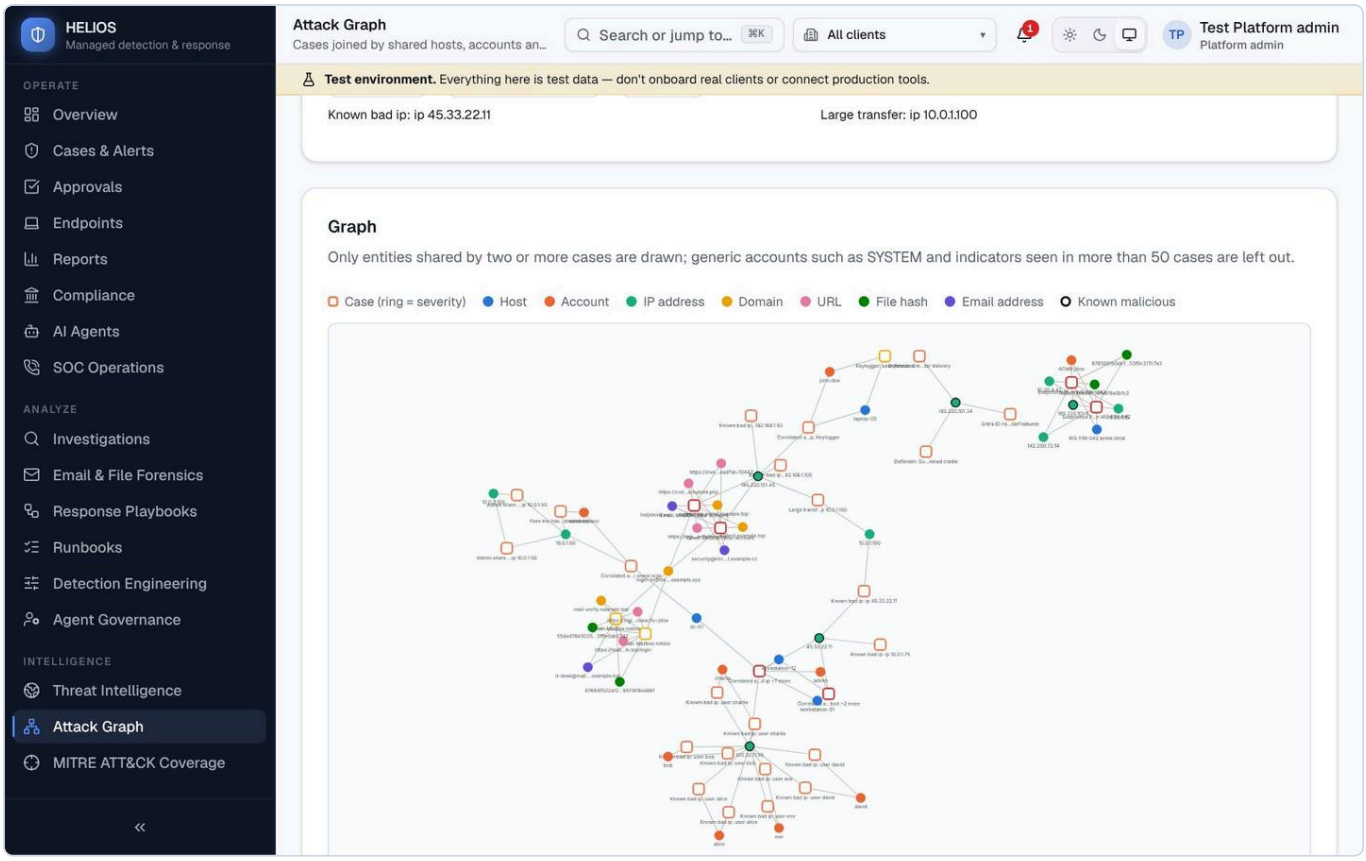


Figure 48. Attack Graph, further down the page.

4.18 MITRE ATT&CK Coverage

Which ATT&CK techniques HELIOS can detect, across built-in detectors, Sigma rules and onboarded tools, and which it has seen.

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor

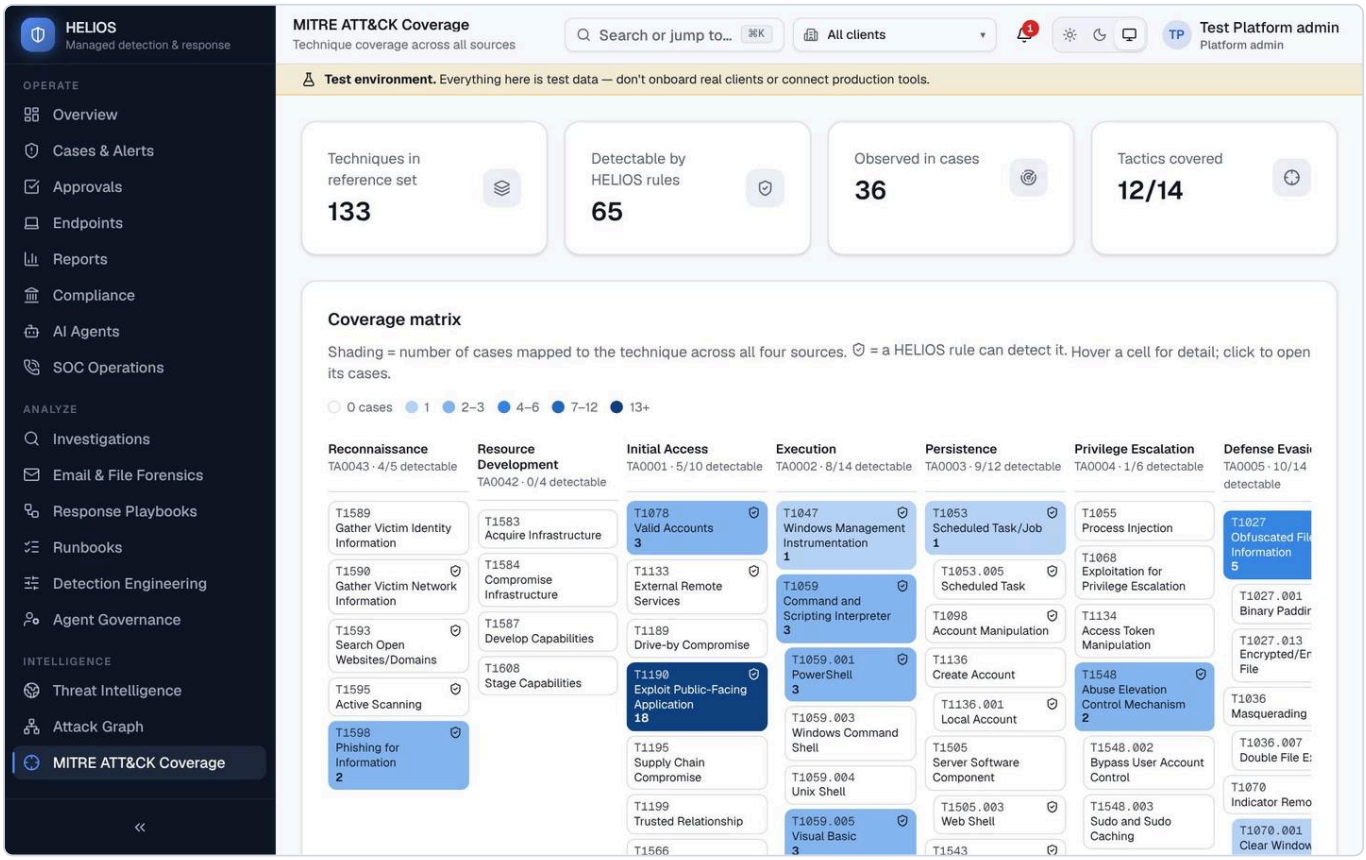


Figure 49. MITRE ATT&CK Coverage (as platform admin).

How to use it

- Read coverage by tactic and technique; gaps show where detection is missing.
- Switch built-in detectors on and off from here too. Admin, SOC manager, Detection eng.

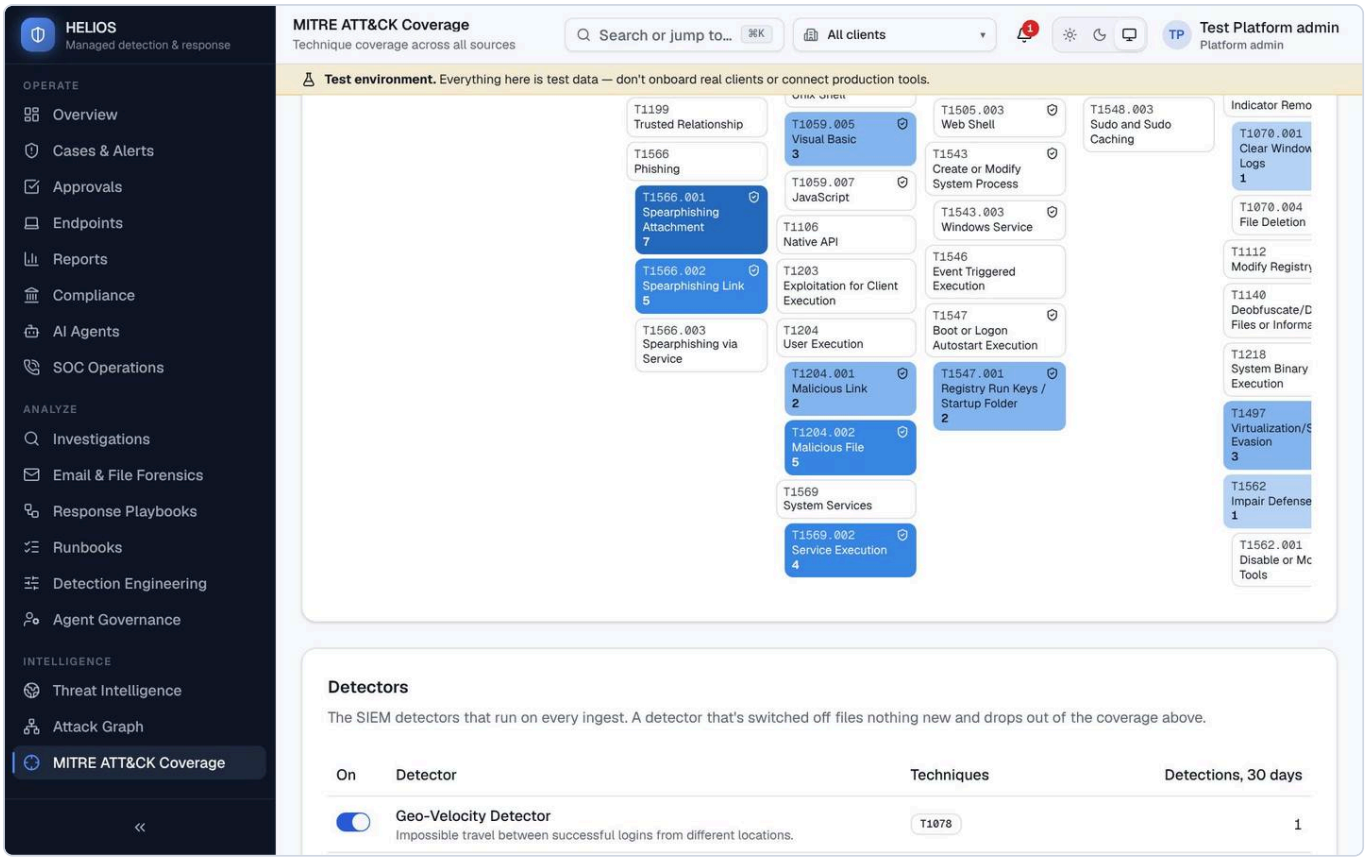


Figure 50. MITRE ATT&CK Coverage, further down the page.

4.19 Tools & Integrations (clients: Security tools)

The security tools onboarded for each client: how their logs reach HELIOS and how HELIOS acts through them.

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor, Account mgr, Client admin

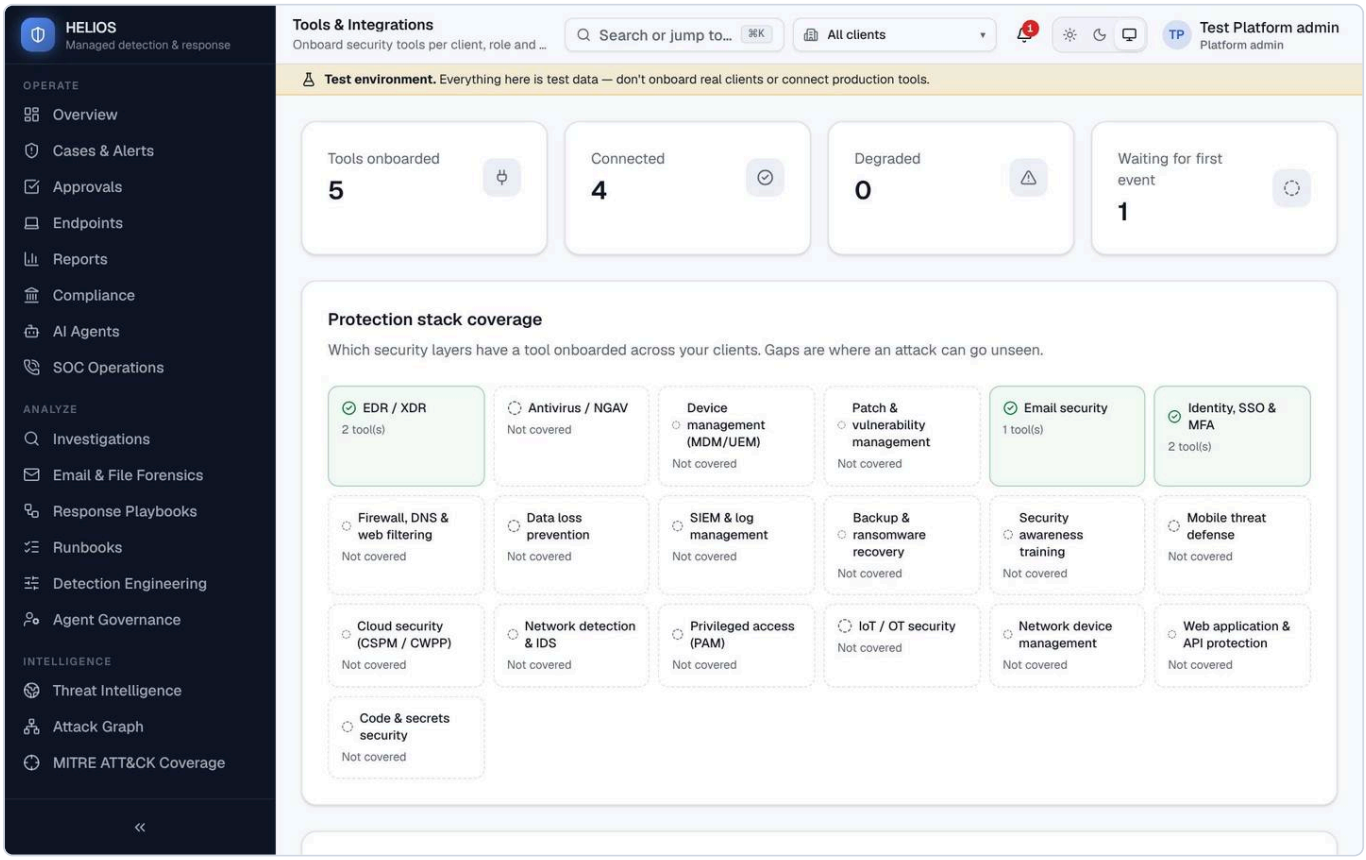


Figure 51. Tools & Integrations (as platform admin).

How to use it

- The tiles count tools onboarded, connected, degraded and waiting for their first event. Protection stack coverage shows which security layers have a tool across your clients; gaps are where an attack can go unseen.
- Each tool shows how it sends logs (push to its ingest URL, HELIOS pulling from the vendor's API, or the HELIOS forwarder), its source health, and whether a response connector can act through it.
- Onboard a tool for a client: pick it from the catalog, enter its read-only credentials (encrypted with the client's own key), test the connection, set the collectors running, and turn on the response connector (dry-run first). Generate the forwarder configuration for syslog, Windows event logs and files. Replay records waiting in the dead-letter queue. Admin, SOC manager, Detection eng., Client admin
- A source silent longer than its limit opens a case: attackers often stop logging first. A client can't go live while a source is dead.

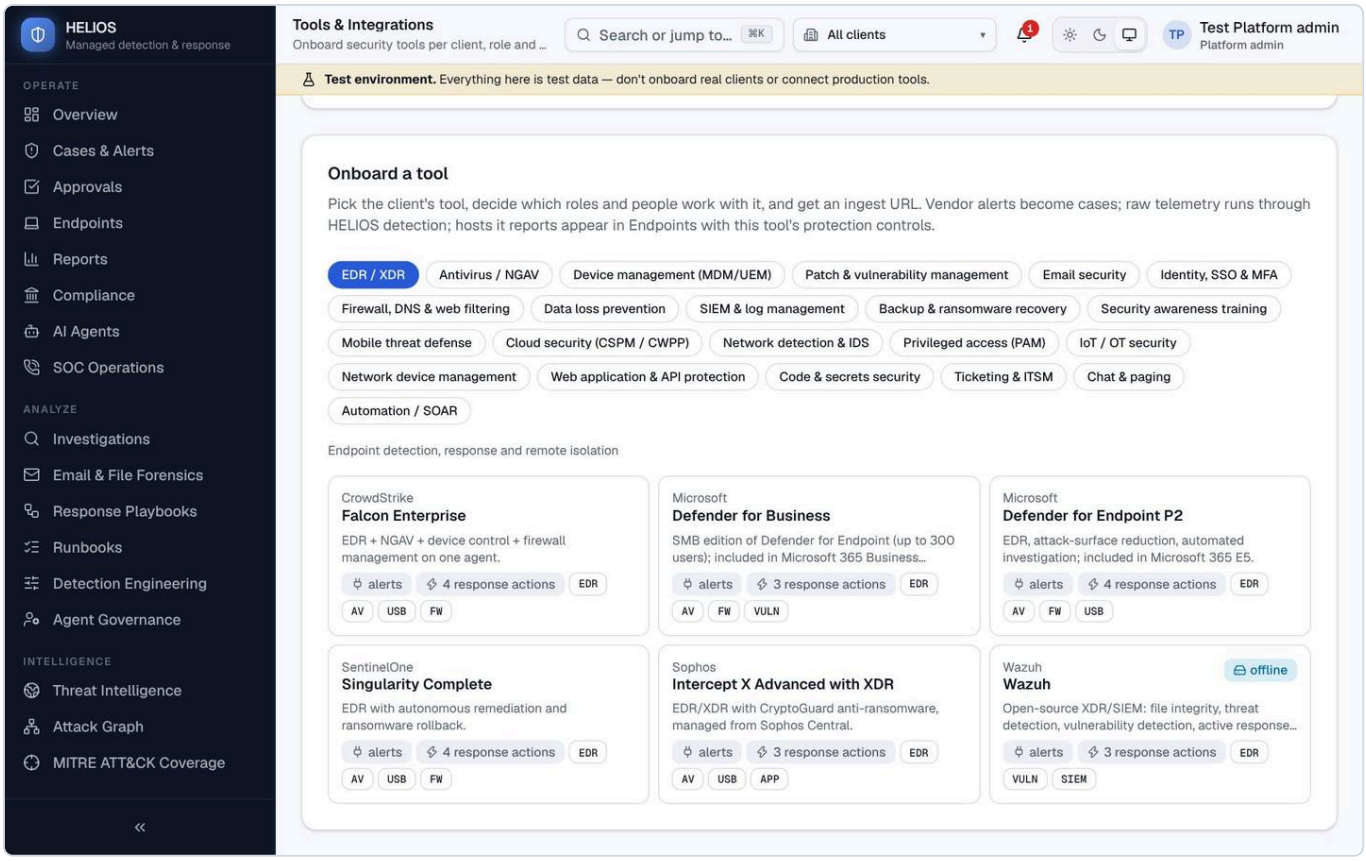


Figure 52. Tools & Integrations, further down the page.

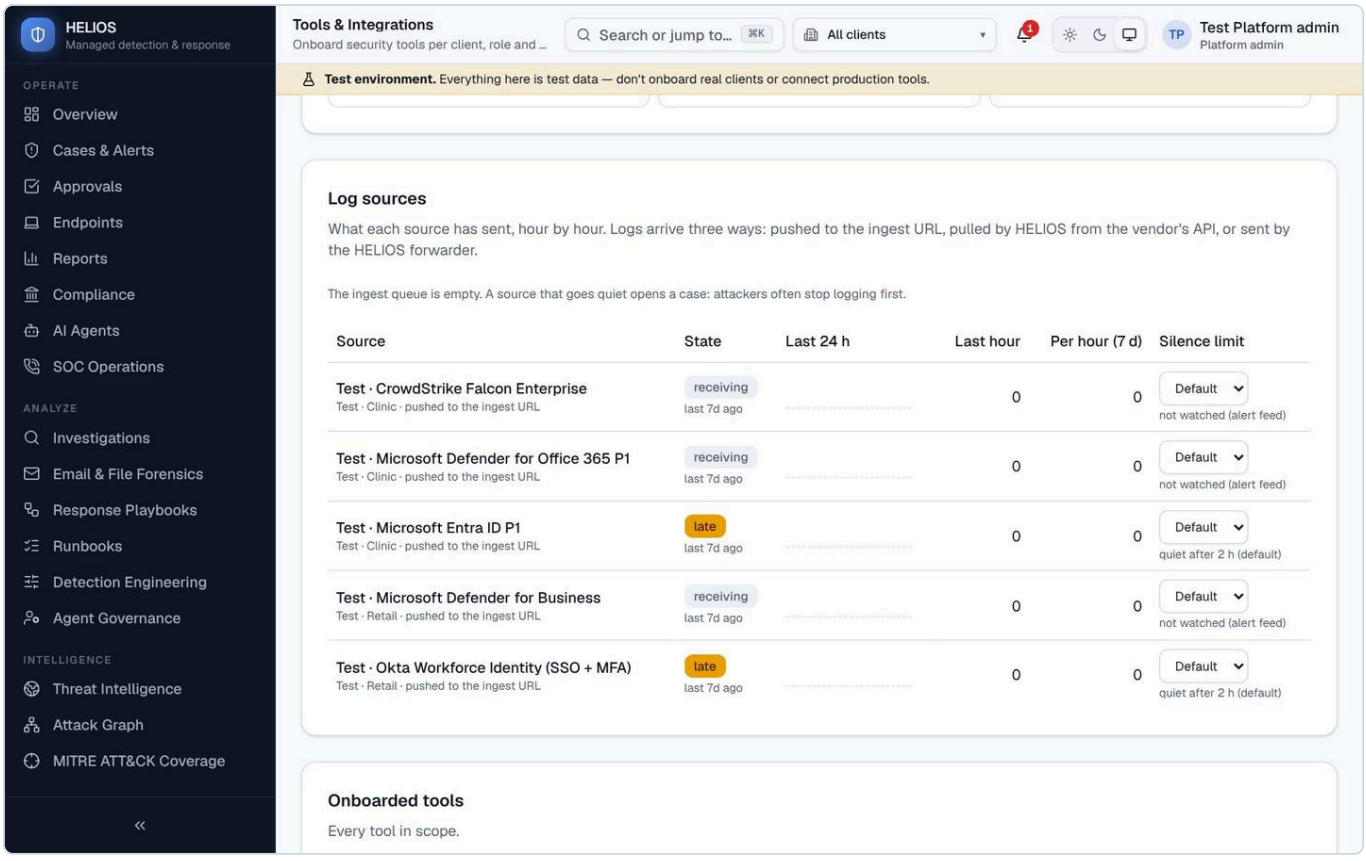


Figure 53. Tools & Integrations, further down the page.

4.20 Rulebooks (clients: Our rulebook)

Each client's signed rules for what HELIOS may do on its estate. The rules only ever restrict: protected assets and accounts, which actions run automatically, need approval or never happen, blast-radius limits, business hours and change freezes, the approver chain, AI data handling and CERT-In contacts.

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor, Account mgr, Client admin, Client viewer

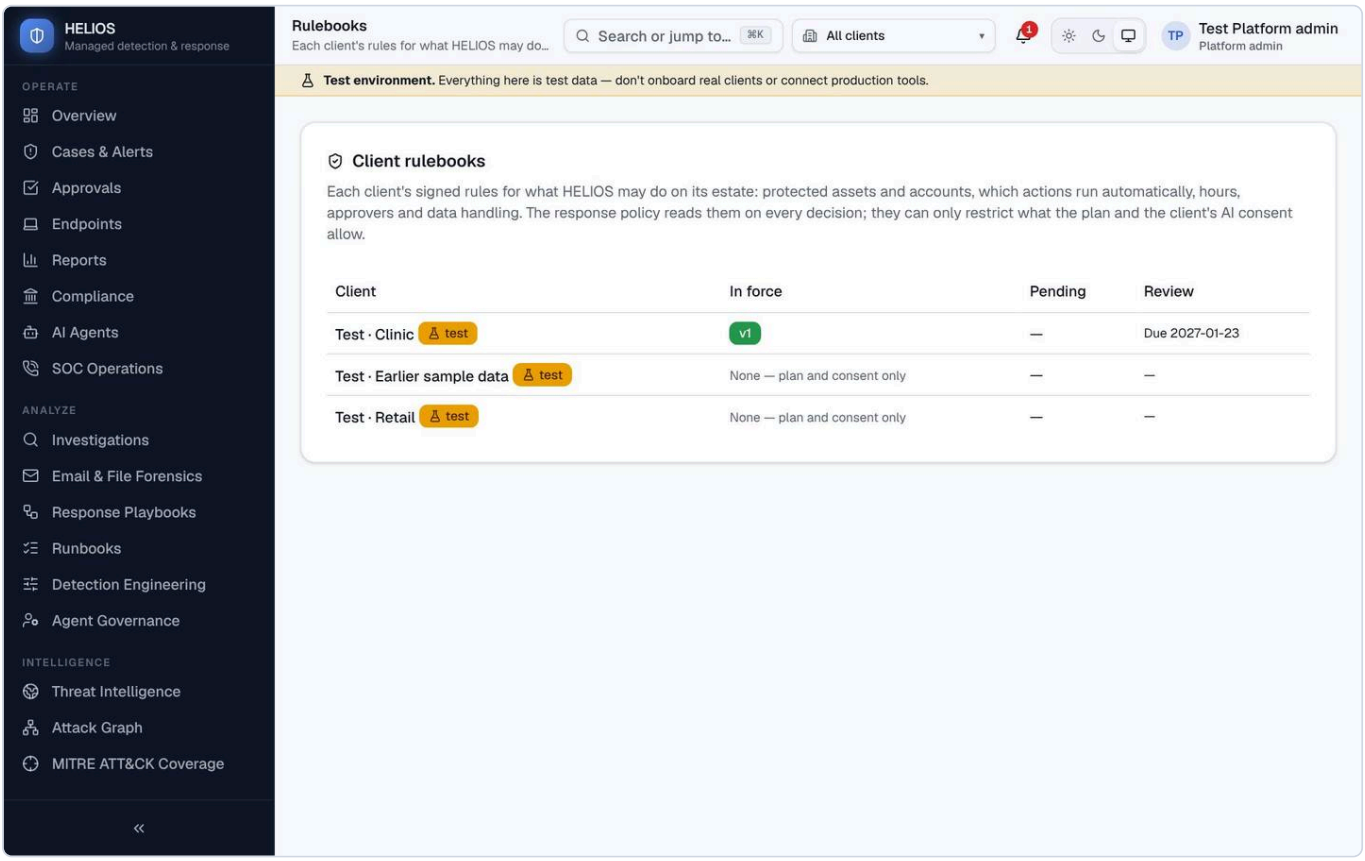


Figure 54. Rulebooks (as platform admin).

How to use it

- Pick the client at the top. The page shows the version in force, its hash and when it is due for review.
  Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor, Account mgr
- The tabs: In force (the rules now applying), Edit, Dry run, Allowlist, Versions, AI models, Autonomy and Policy as code.
- Edit drafts a change, from an industry template or the version in force. Dry run replays the last 30 days of AI proposals under the draft and probes each action. Versions compares any two versions side by side.
  Admin, SOC manager, Detection eng., Account mgr, Client admin
- Sign the draft to put it in force. Client admins sign their own; staff activate only on the client's recorded instruction, naming it. Admin, SOC manager, Client admin
- Allowlist: known-good hosts, IPs and accounts, each with an owner, a reason and an expiry. They open no cases, and AI containment against them is only suggested.
  Admin, SOC manager, Detection eng., Account mgr, Client admin
- Policy as code: export or import the rulebook as YAML, or keep it in Git (GitHub, GitLab or an https URL): a changed file becomes a draft that still needs signing here.
  Admin, SOC manager, Detection eng., Account mgr, Client admin
- AI models: which models may read the client's evidence (any, region-locked or on-premises only), the client's own providers (bring your own key), a provider per agent, and the monthly AI budget.
  Admin, SOC manager, Detection eng., Account mgr, Client admin
- Autonomy: the AI's autonomy ladder per action type for this client, and promotions waiting for approval.

- You can read the rules HELIOS works under on your estate; your client admin changes and signs them.
  Client viewer

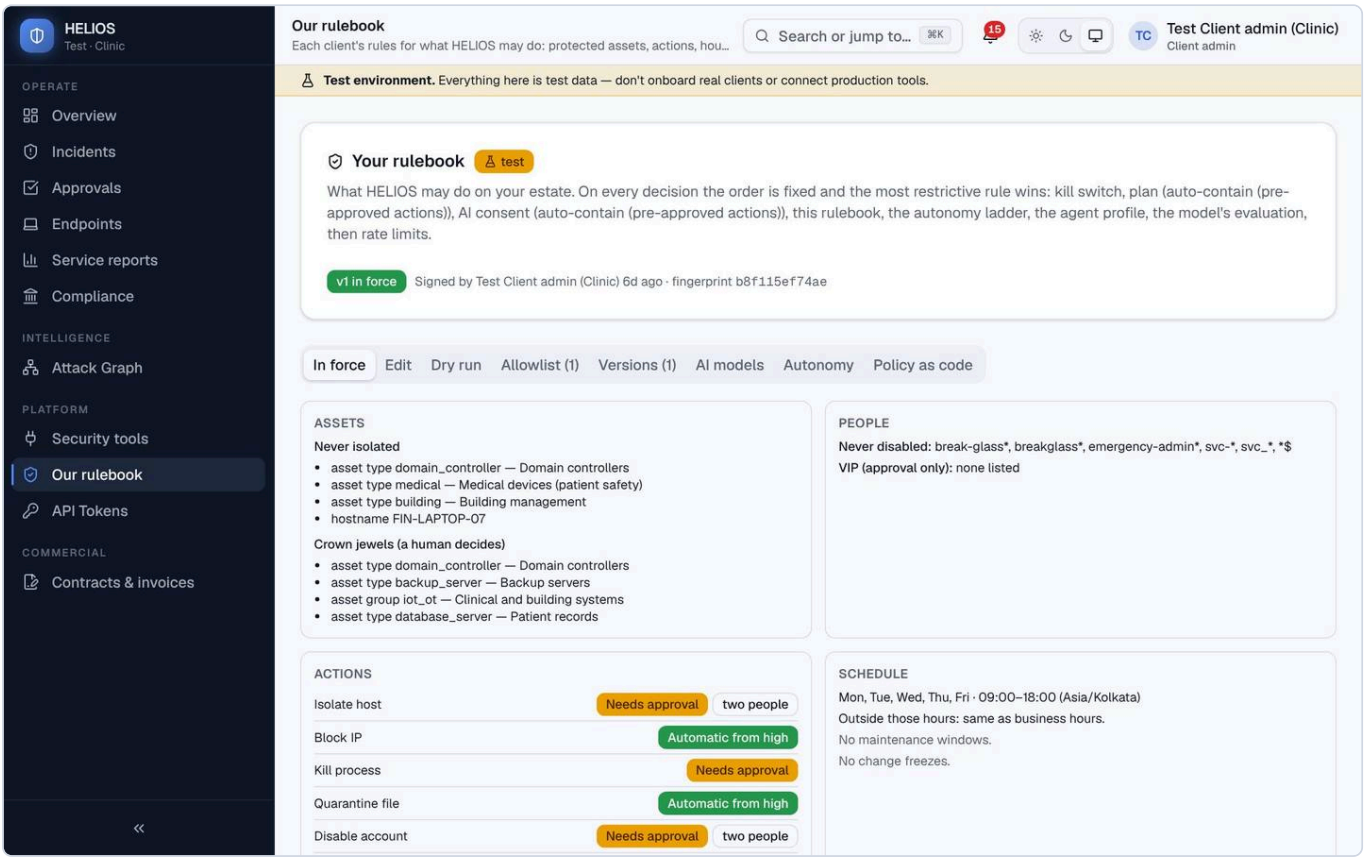


Figure 55. The client's view: Our rulebook (as client admin).

4.21 A client's rulebook

The rulebook page for one client (here the test client Clinic).

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor, Account mgr

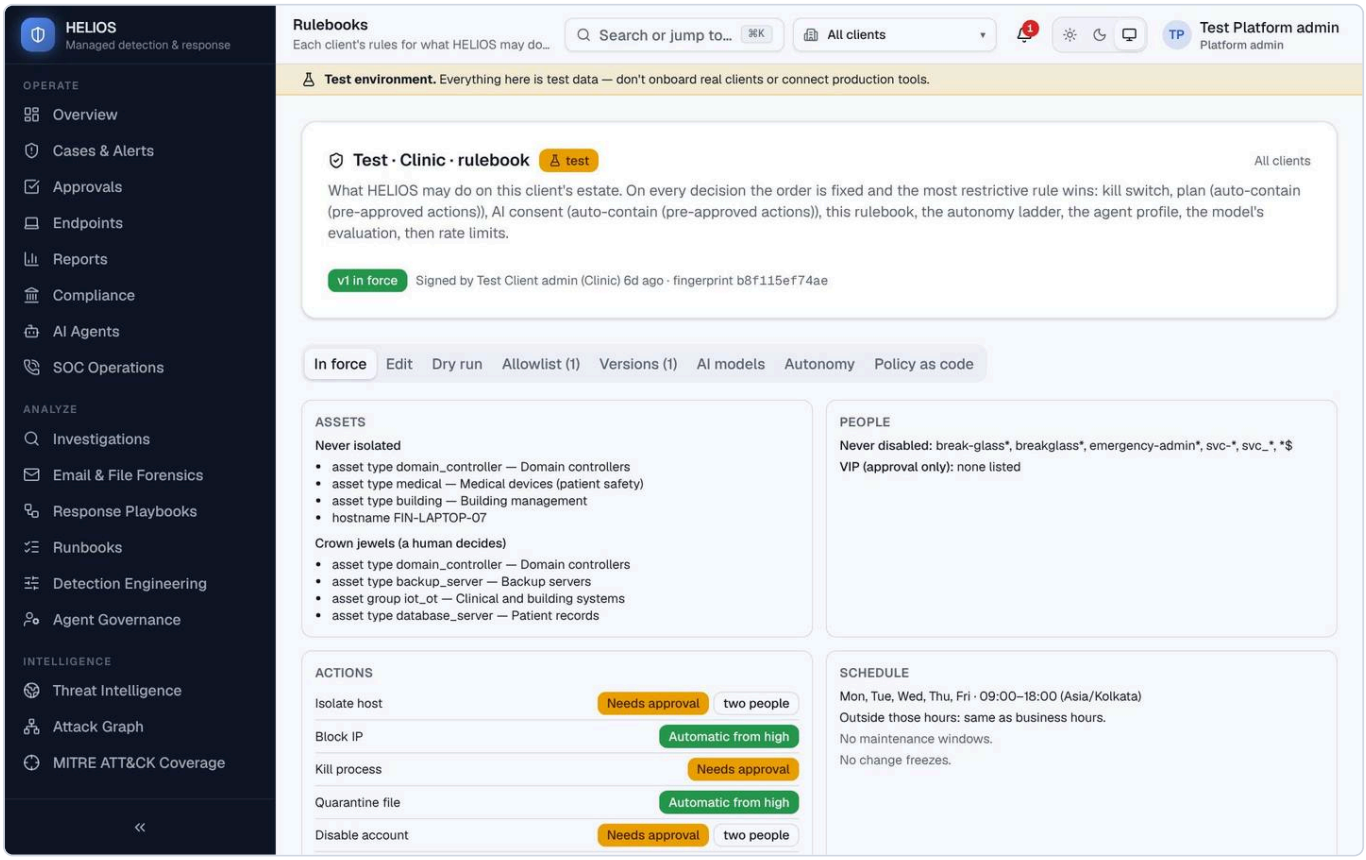


Figure 56. A client's rulebook (as platform admin).

How to use it

- In force shows the assets (never isolated, crown jewels), the people (never disabled, VIPs), each action's mode (automatic from a severity, needs approval, two people), the schedule, the approver chain, and data handling and obligations. The other tabs are as described above.

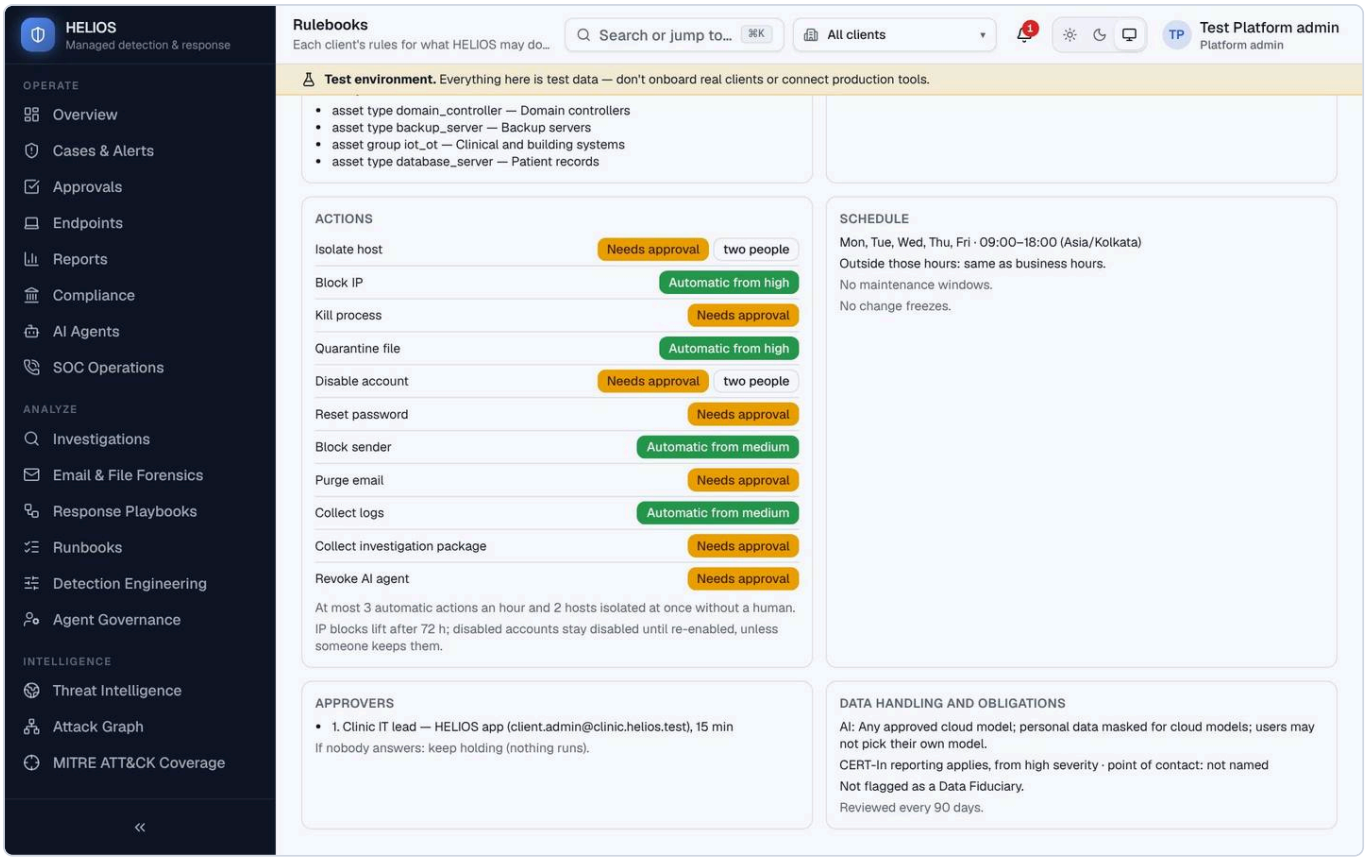


Figure 57. A client's rulebook, further down the page.

4.22 Clients

The client organisations (tenants): their plan and SLA, status, contacts, and how far they consent to AI acting on their estate.

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor, Account mgr

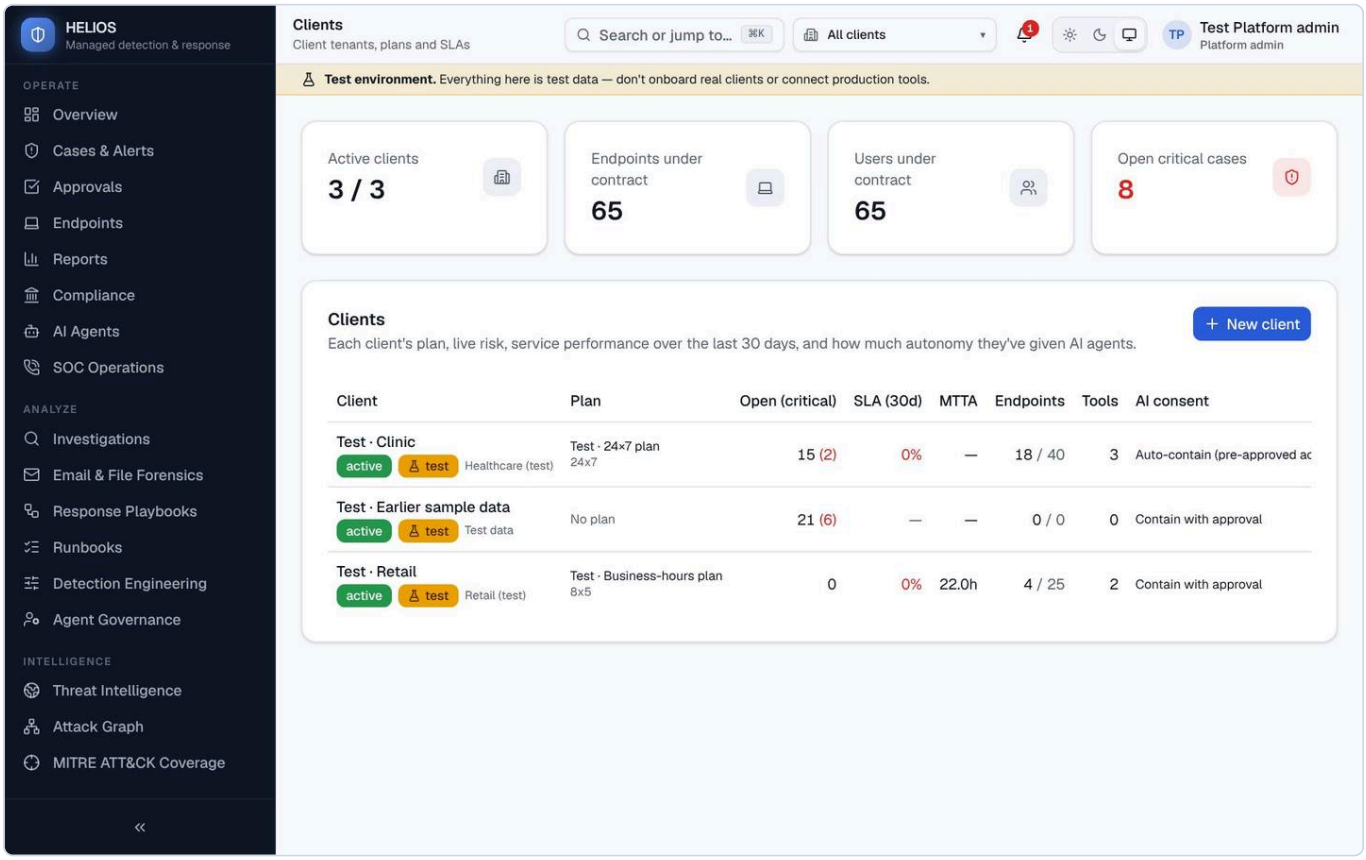


Figure 58. Clients (as platform admin).

How to use it

- Each client shows its plan, status (onboarding, active, suspended), licensed endpoints and users, and test clients are badged.
- Add or edit a client: name, industry, contacts, plan, licensed counts, and the AI autonomy cap the client has consented to (it caps every agent on their estate). A client moves from onboarding to active only once every data source has sent something in the last day. Admin, SOC manager, Account mgr

4.23 A client

One client's page: plan and SLA, contacts, consent, onboarding status, tools, users and data keys.

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor, Account mgr

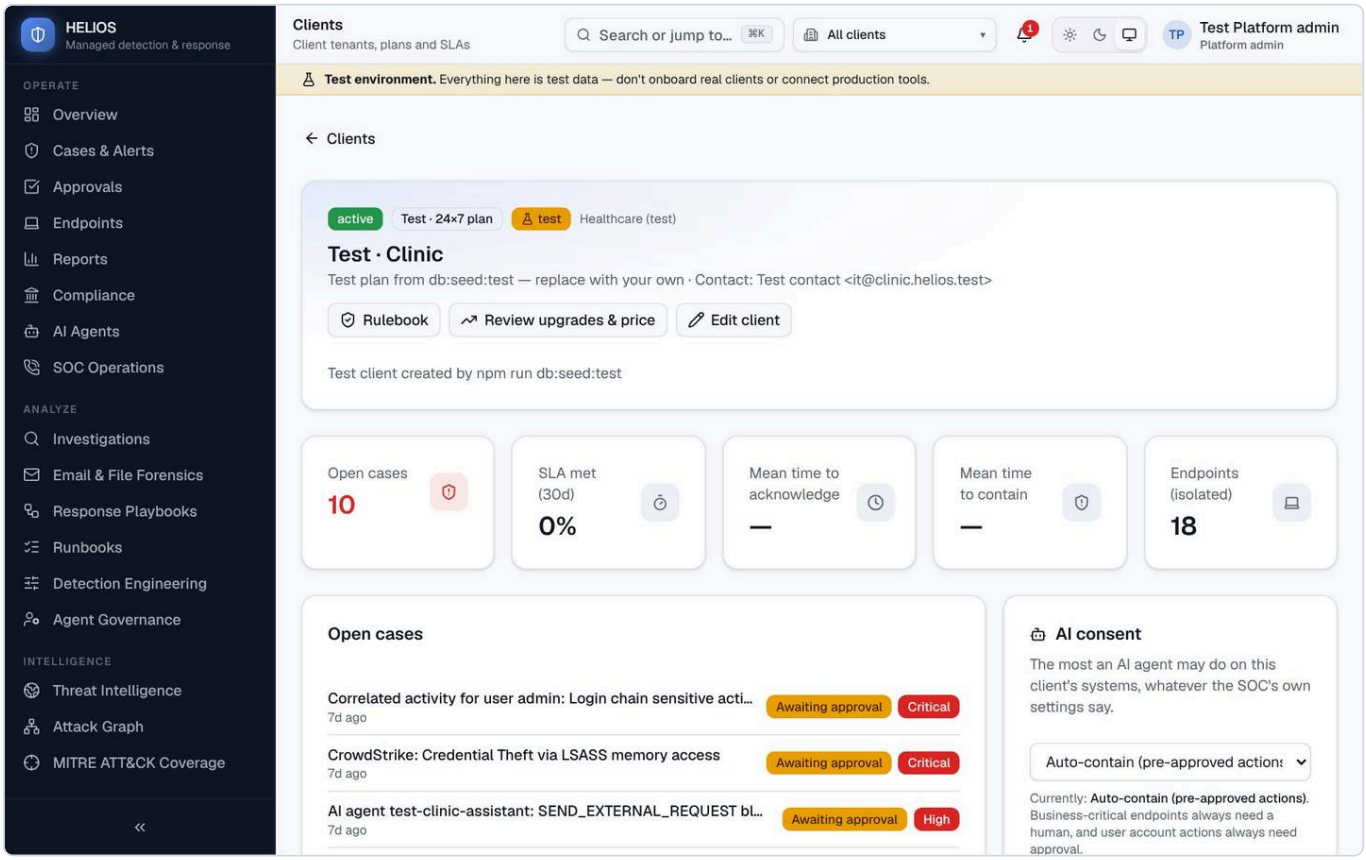


Figure 59. A client (as platform admin).

How to use it

- The page shows the client's open cases, SLA met, mean time to acknowledge and contain, endpoints, and buttons for its Rulebook, Review upgrades & price, and Edit client.
- AI consent: the most an AI agent may do on the client's systems, whatever the SOC's own settings say. Set it as the client agreed. Admin, SOC manager, Account mgr
- Encryption key: Rotate key re-seals the client's credentials under a new data key; Destroy keys (for an offboarded, suspended client) makes its stored credentials unreadable for good, and asks you to type the client's name. Only platform admins can. Admin

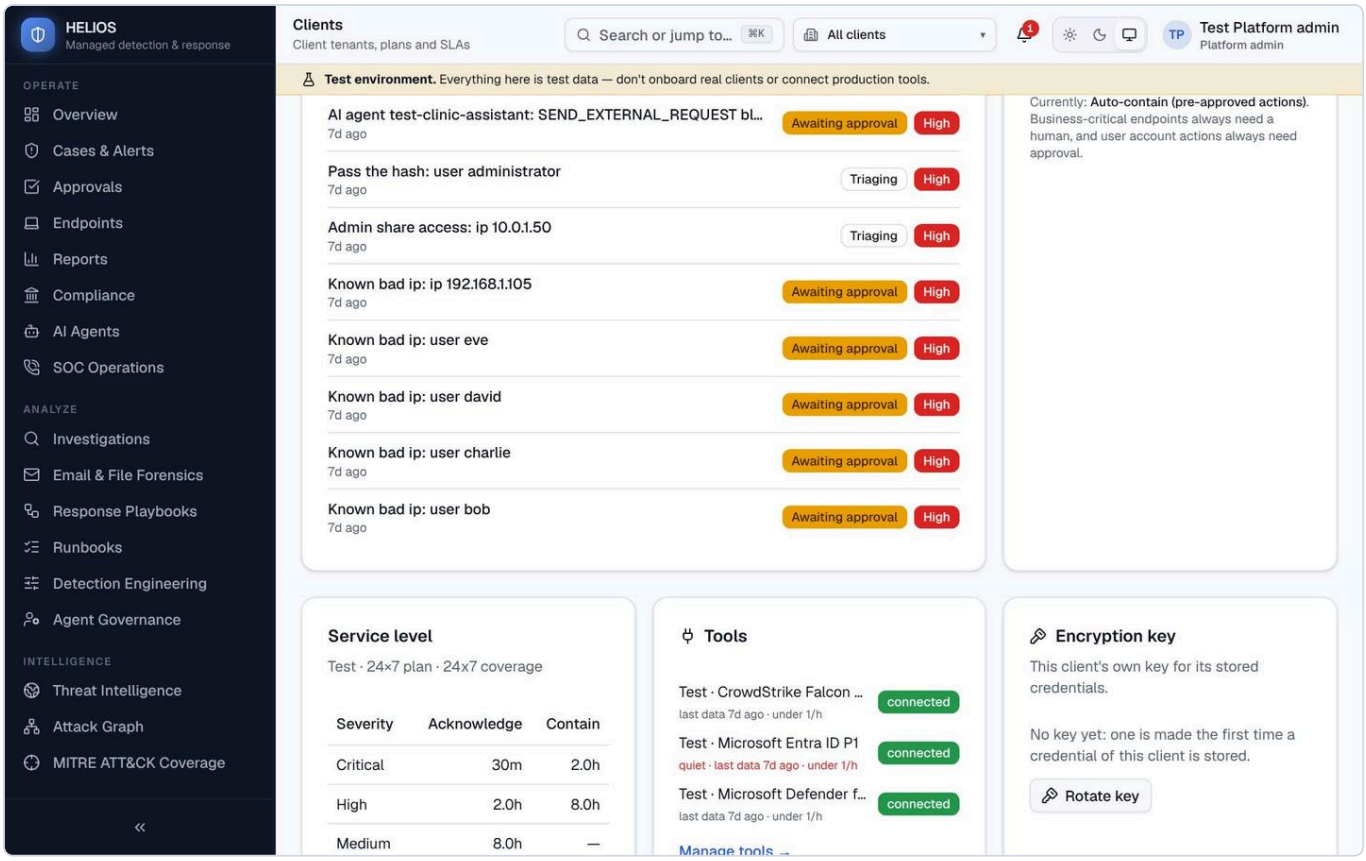


Figure 60. A client, further down the page.

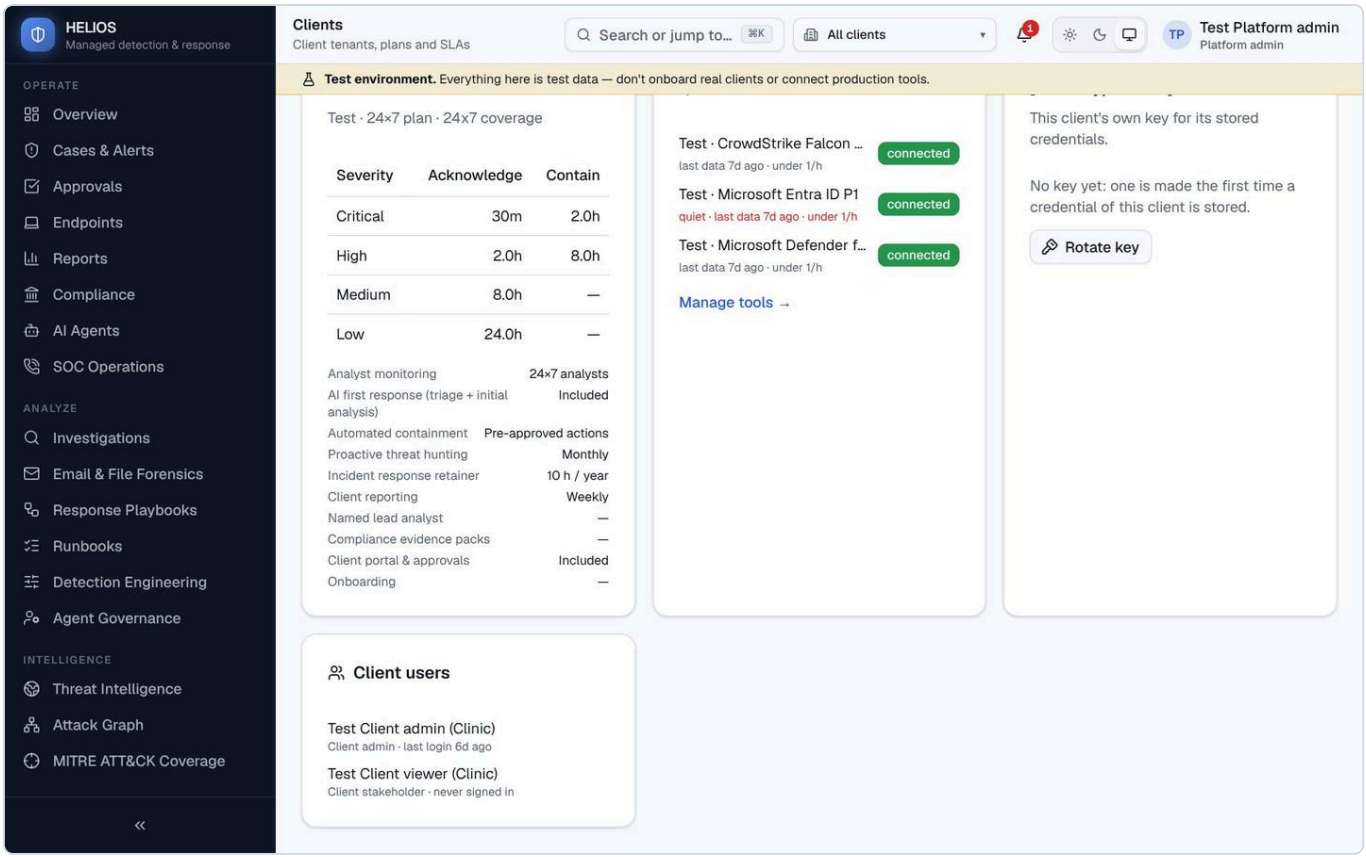


Figure 61. A client, further down the page.

4.24 Team & Roles

The people who use HELIOS, their roles, the security domains (queues) analysts work, and what each role can see and do.

Who can open it: Admin

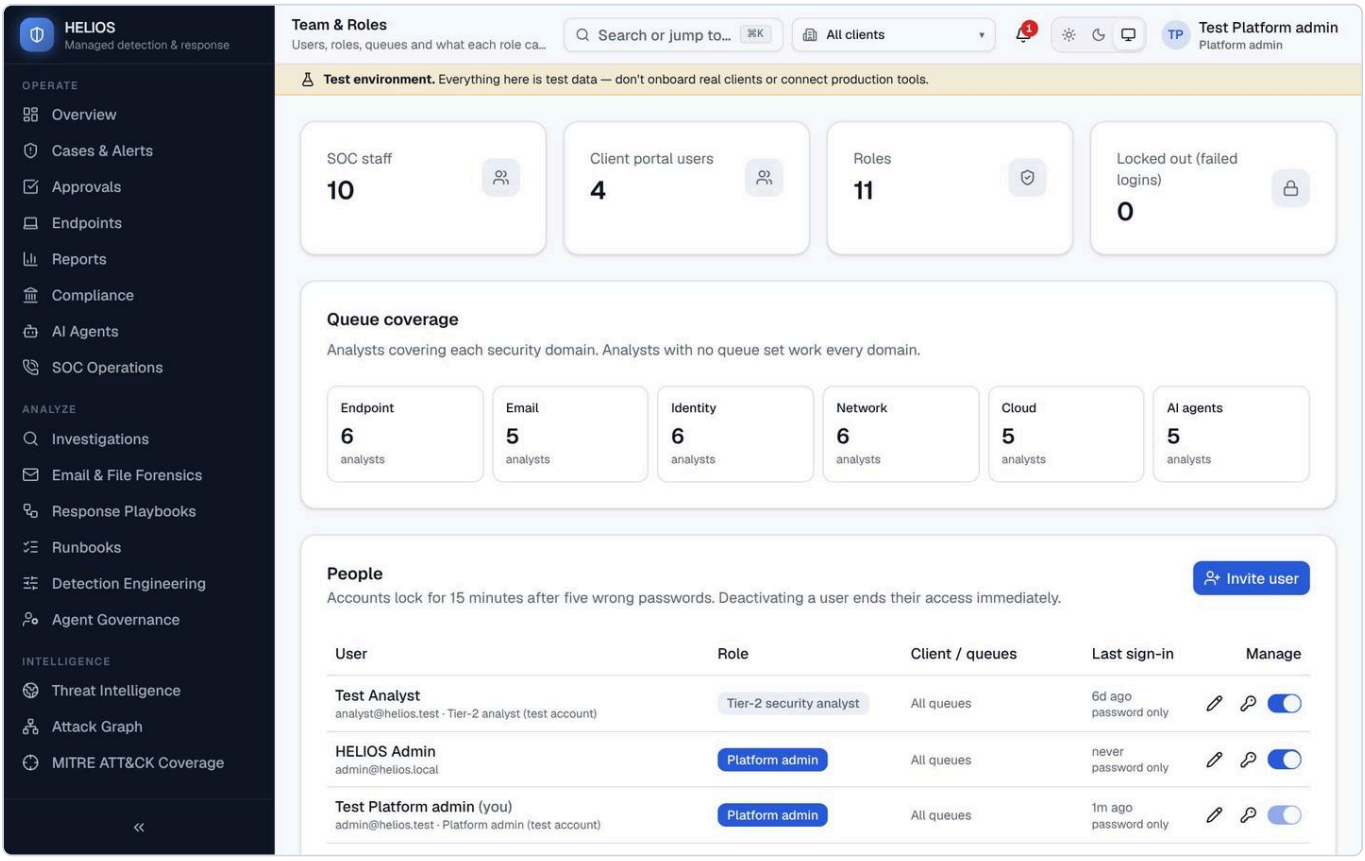


Figure 62. Team & Roles (as platform admin).

How to use it

- Invite user: name, email, role, and for client users their organisation. HELIOS shows a temporary password once; pass it to the person securely. Limit an analyst to security domains to give them those queues only.
- On each person's row: the pencil edits the role, organisation and queues; the key resets the password; the switch deactivates the account. Changes apply on the person's next request. Reset two-step sign-in for someone who lost their phone.
- Queue coverage shows how many analysts cover each security domain. Accounts lock for 15 minutes after five wrong passwords; the Locked out tile counts them.
- The role matrix shows every permission each role has.

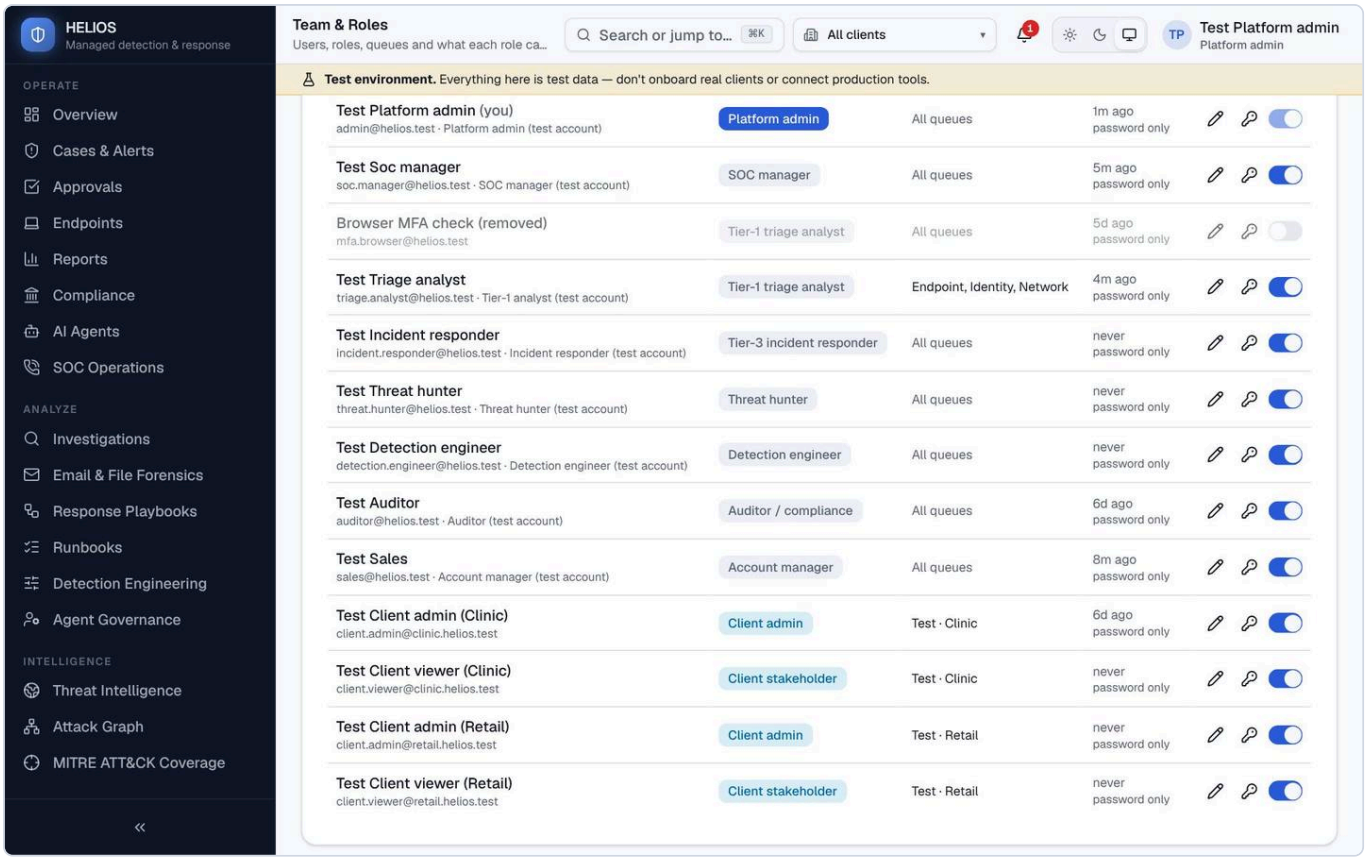


Figure 63. Team & Roles, further down the page.

4.25 Data Retention

Where each client's logs are kept and for how long, the encrypted archive, and legal holds.

Who can open it: Admin, SOC manager, Auditor

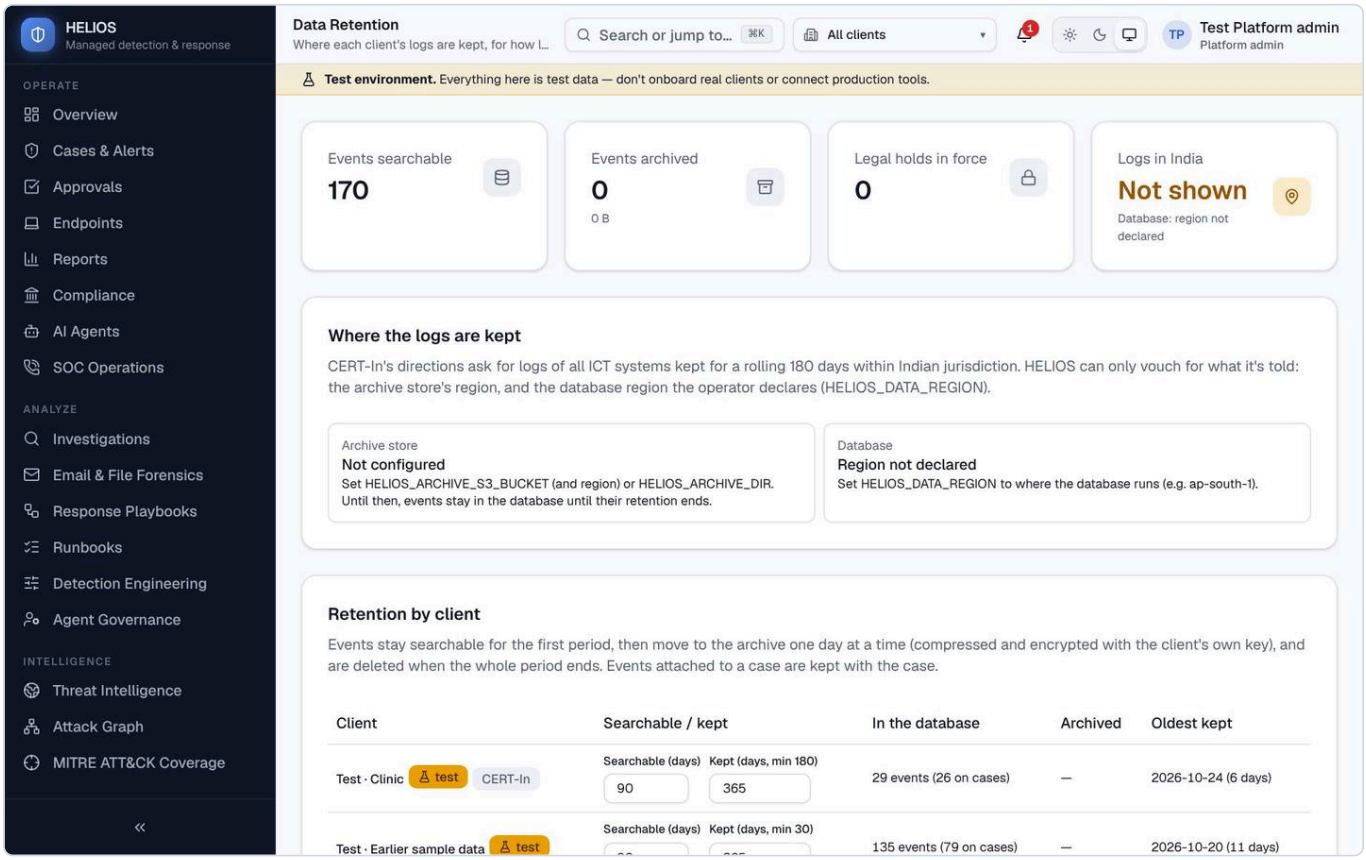


Figure 64. Data Retention (as platform admin).

How to use it

- Retention by client: Searchable (days) and Kept (days). Where CERT-In's directions apply, Kept can't go below 180. Events attached to a case are kept with the case.
- The page says whether the logs are shown to be in India (the database region and the archive store's region), from what the server is configured with.
- Legal holds stop deletion over a date range (optionally tied to a case); placing and releasing need a reason. Archives download decrypted, and each download is audited.

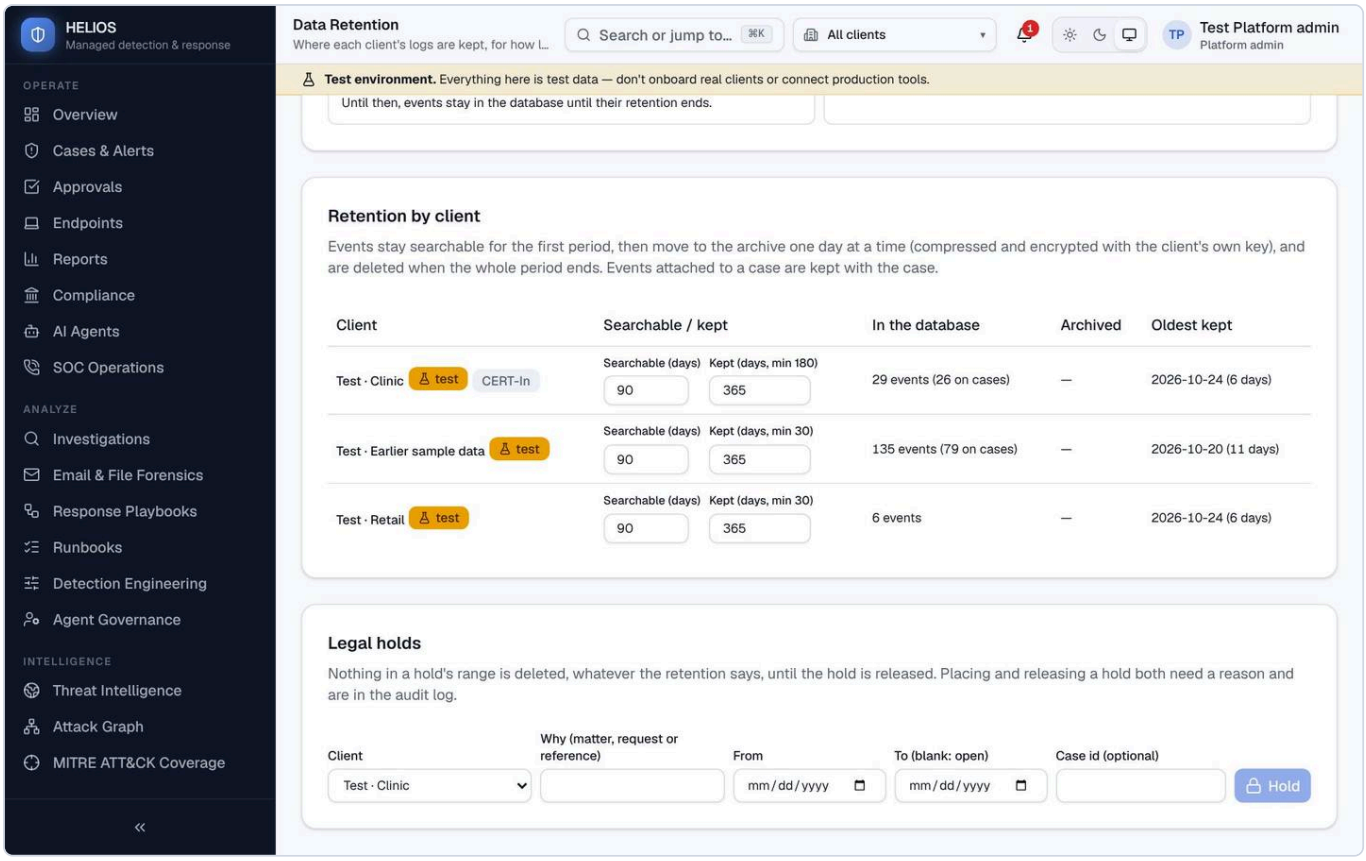


Figure 65. Data Retention, further down the page.

4.26 Audit Log

The hash-chained record of every action in HELIOS: who did what, when, to which case or object.

Who can open it: Admin, SOC manager, Auditor

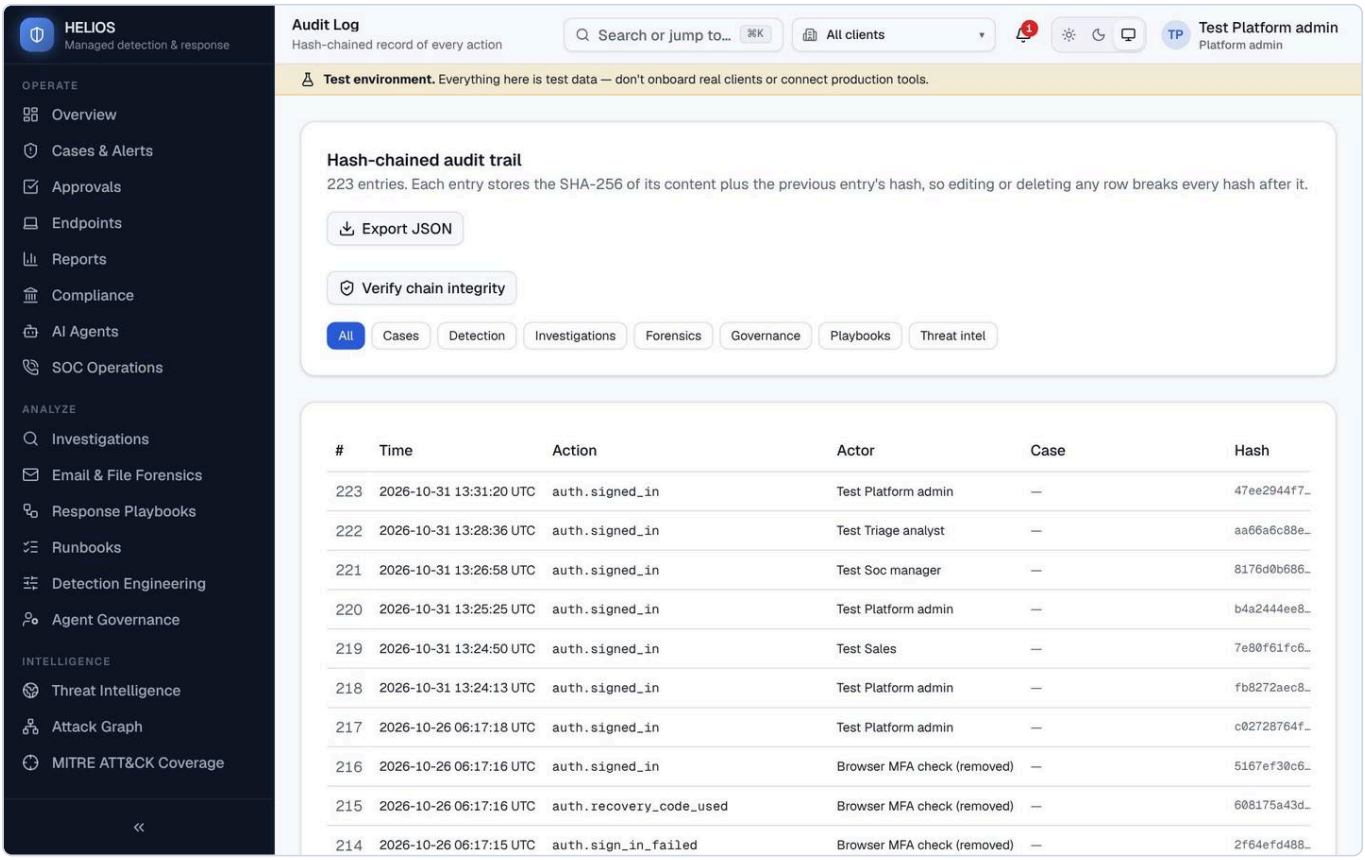


Figure 66. Audit Log (as platform admin).

How to use it

- Each entry stores the SHA-256 of its content plus the previous entry's hash, so editing or deleting any row breaks every hash after it. Verify chain integrity recomputes them all and names the first altered entry if there is one.
- Filter by area: cases, detection, investigations, forensics, governance, playbooks, threat intel.
- Export JSON exports the chain for an auditor or a regulator.

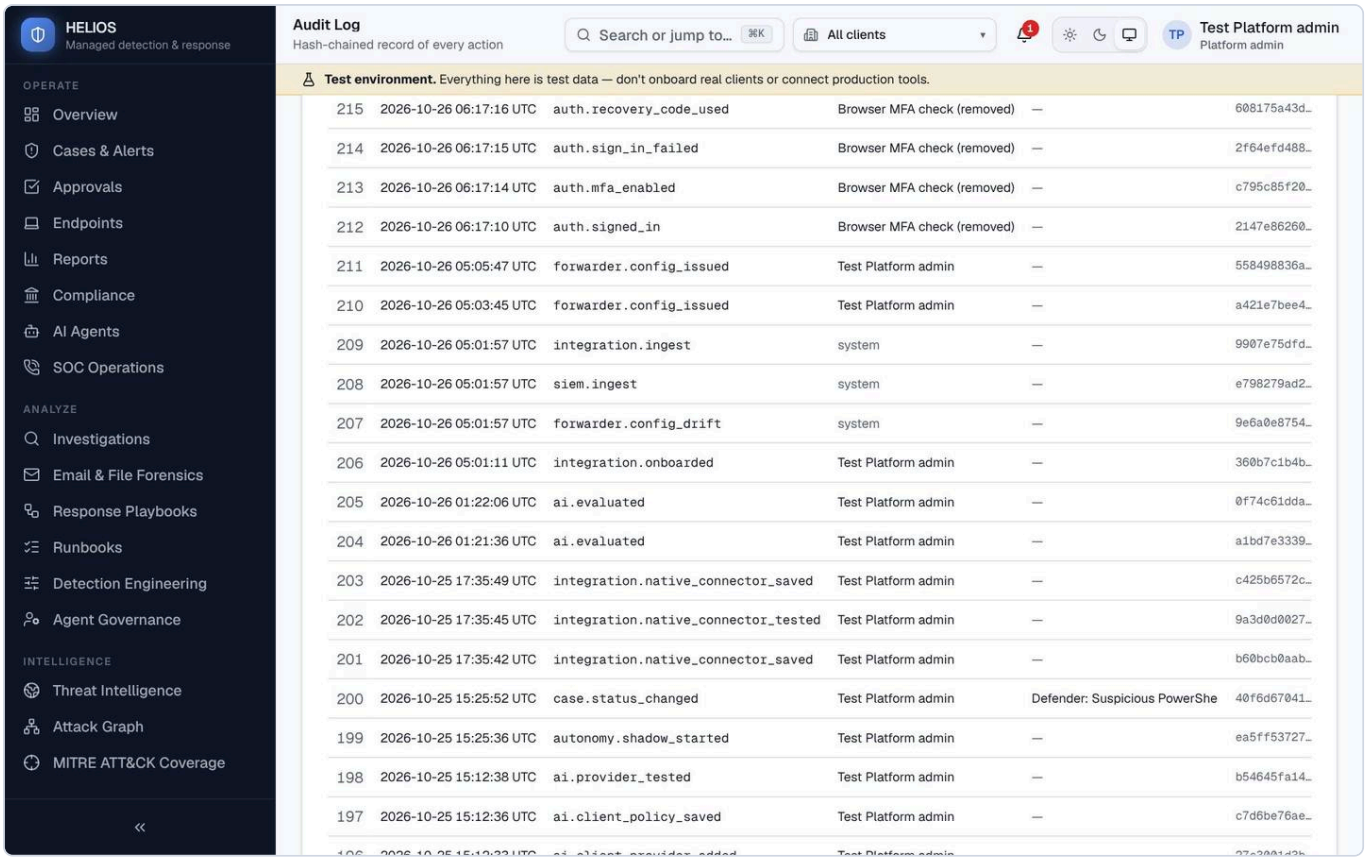


Figure 67. Audit Log, further down the page.

4.27 API Tokens

Personal tokens for the REST API, for ticketing systems, SOAR and client portals. A token acts as you: same role, client and queues.

Who can open it: Admin, SOC manager, Tier 2, Tier 3, Hunter, Detection eng., Auditor, Client admin

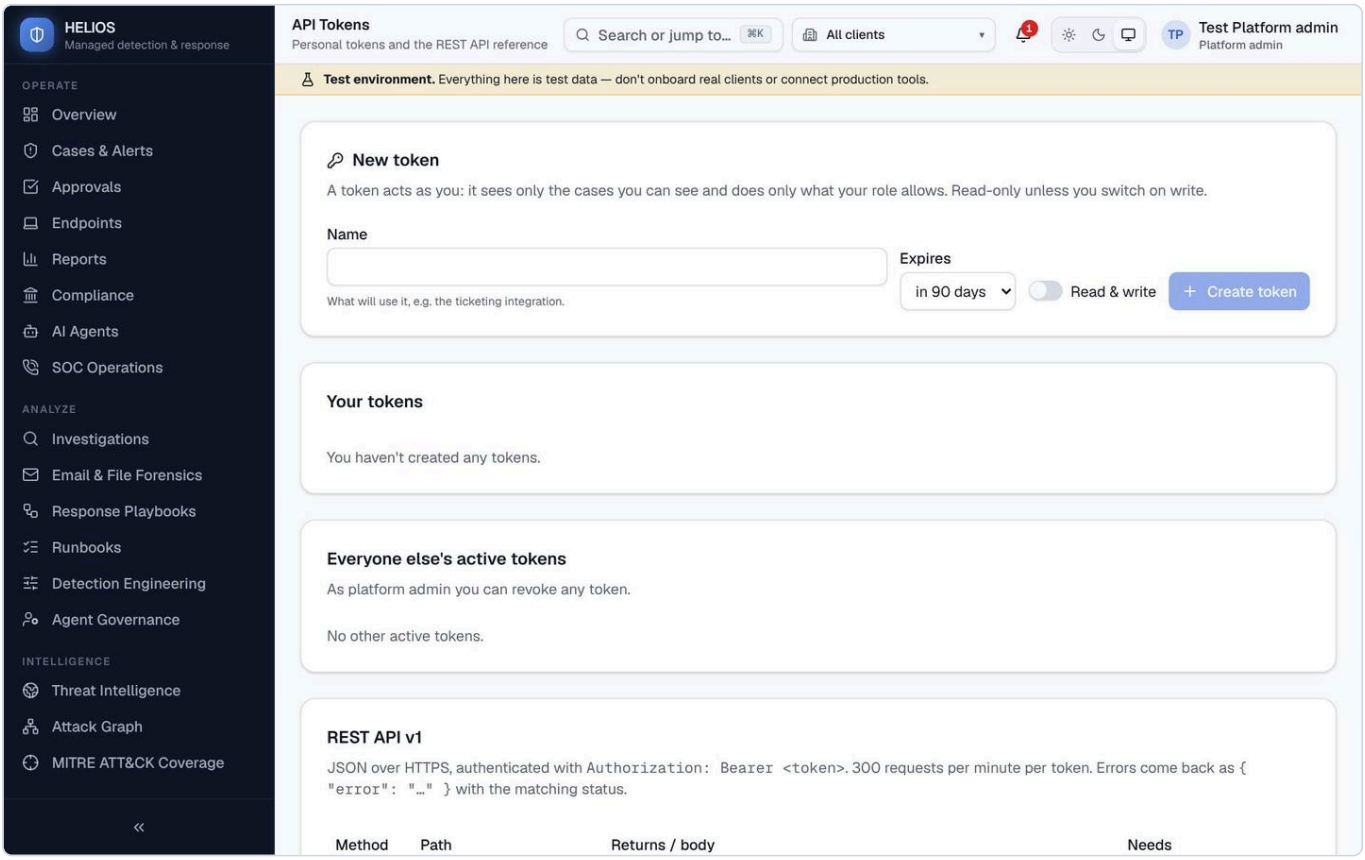


Figure 68. API Tokens (as platform admin).

How to use it

- New token: give it a name (what will use it), an expiry (90 days by default), and switch on Read & write only if it must change things. Create token shows it once; copy it then. Your tokens lists yours to revoke.
- As platform admin you also see everyone else's active tokens and can revoke any of them. Admin
- The page includes the API reference: endpoints, parameters and examples. Calls are limited to 300 a minute per token, and every change through the API is audited.

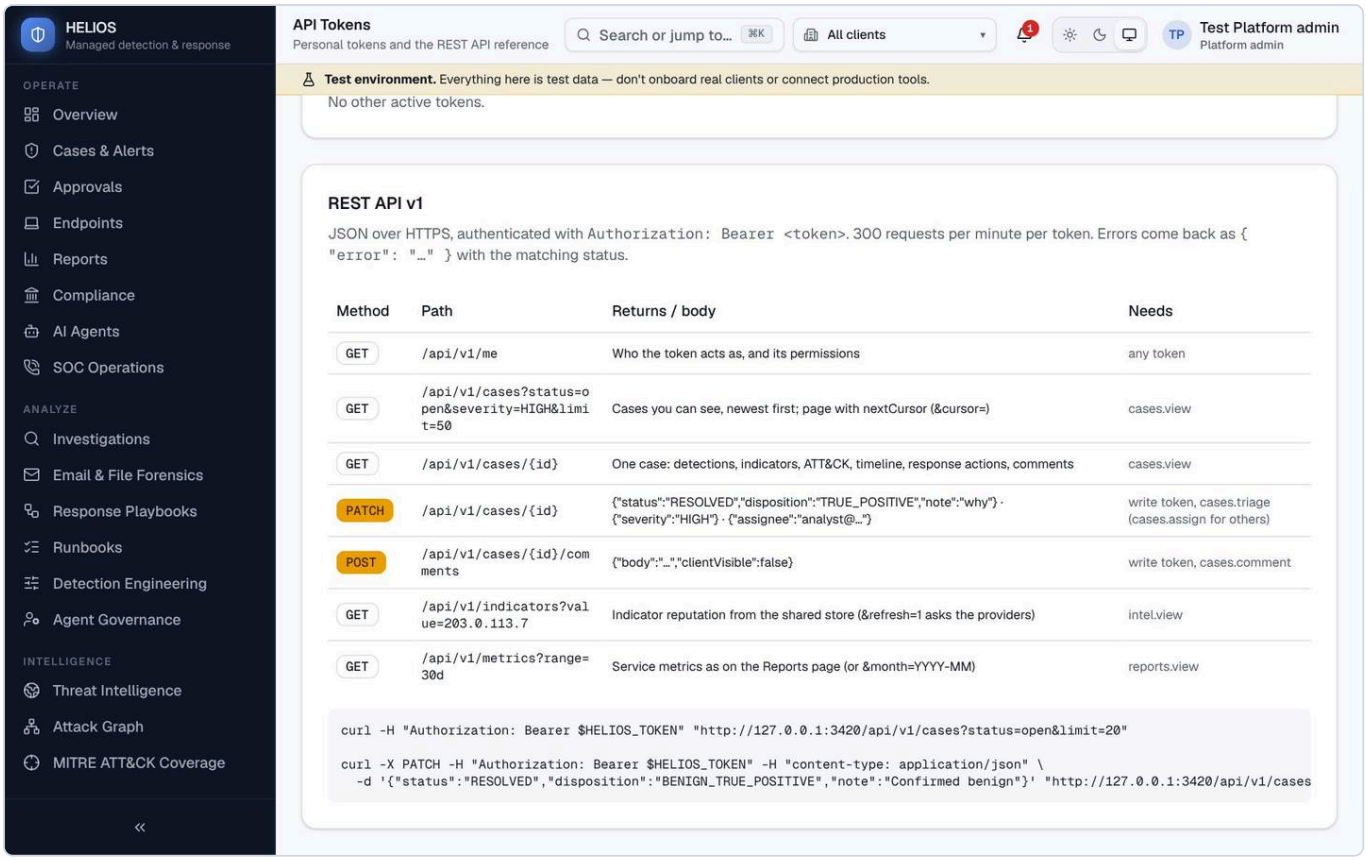


Figure 69. API Tokens, further down the page.

4.28 Settings

Platform-wide settings: environment, sign-in and encryption, company profile, public website, alert channels, provider keys, forensics thresholds and IP geolocation.

Who can open it: Admin, SOC manager

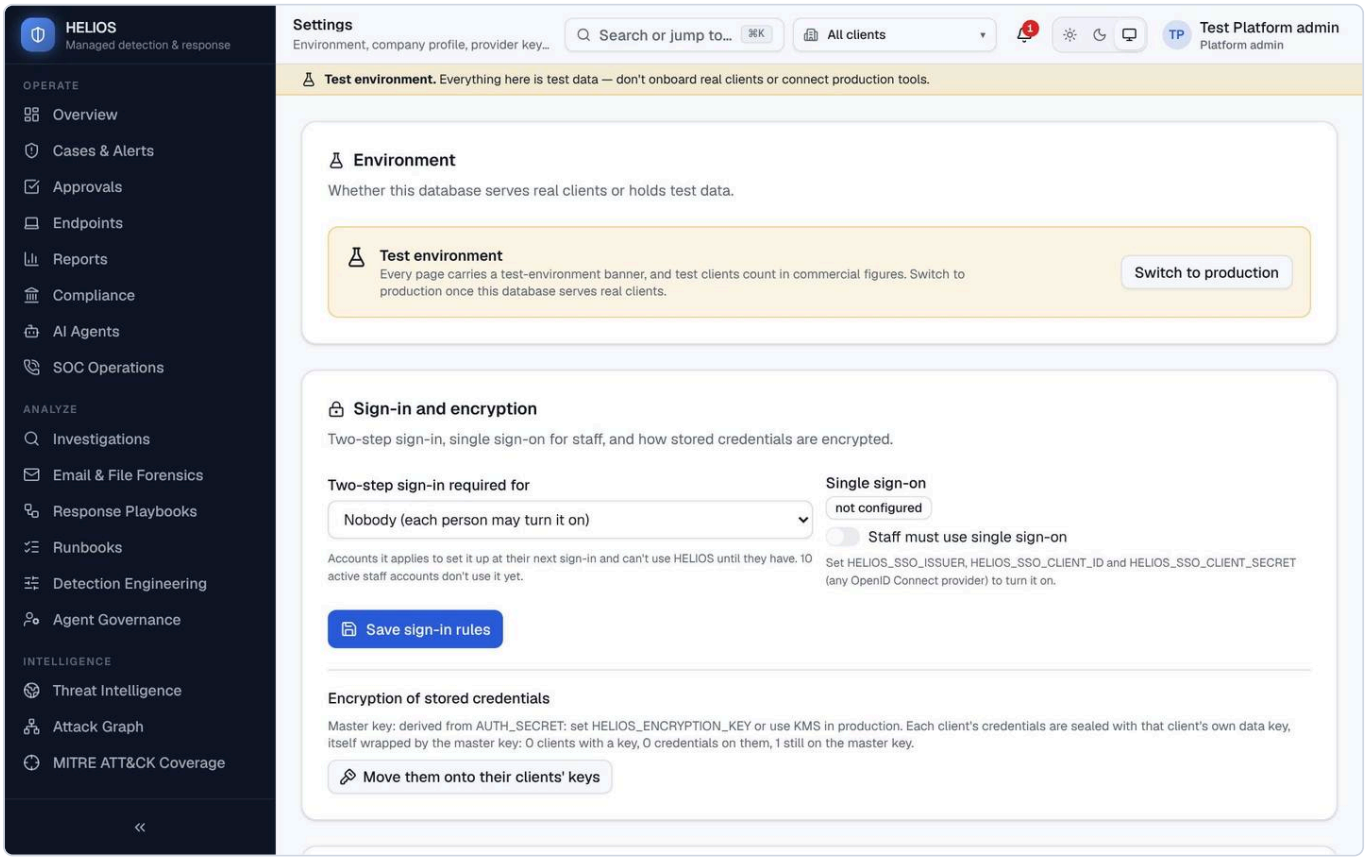


Figure 70. Settings (as platform admin).

How to use it

- Environment: production or test (a test environment shows a banner on every page). Switch to production once the database serves real clients.
- Sign-in and encryption: Two-step sign-in required for (nobody, staff or everyone) and Staff must use single sign-on, then Save sign-in rules. Under encryption, Move them onto their clients' keys re-seals older credentials with each client's own key.
- Company profile (printed on quotes, reports and invoices), the public website, alert channels (email, SMS, WhatsApp) and provider keys (VirusTotal, AbuseIPDB, MxToolbox, Slack). Keys are encrypted; only their last four characters are ever shown.
- Forensics thresholds and trusted link domains, and the IP geolocation databases in use.

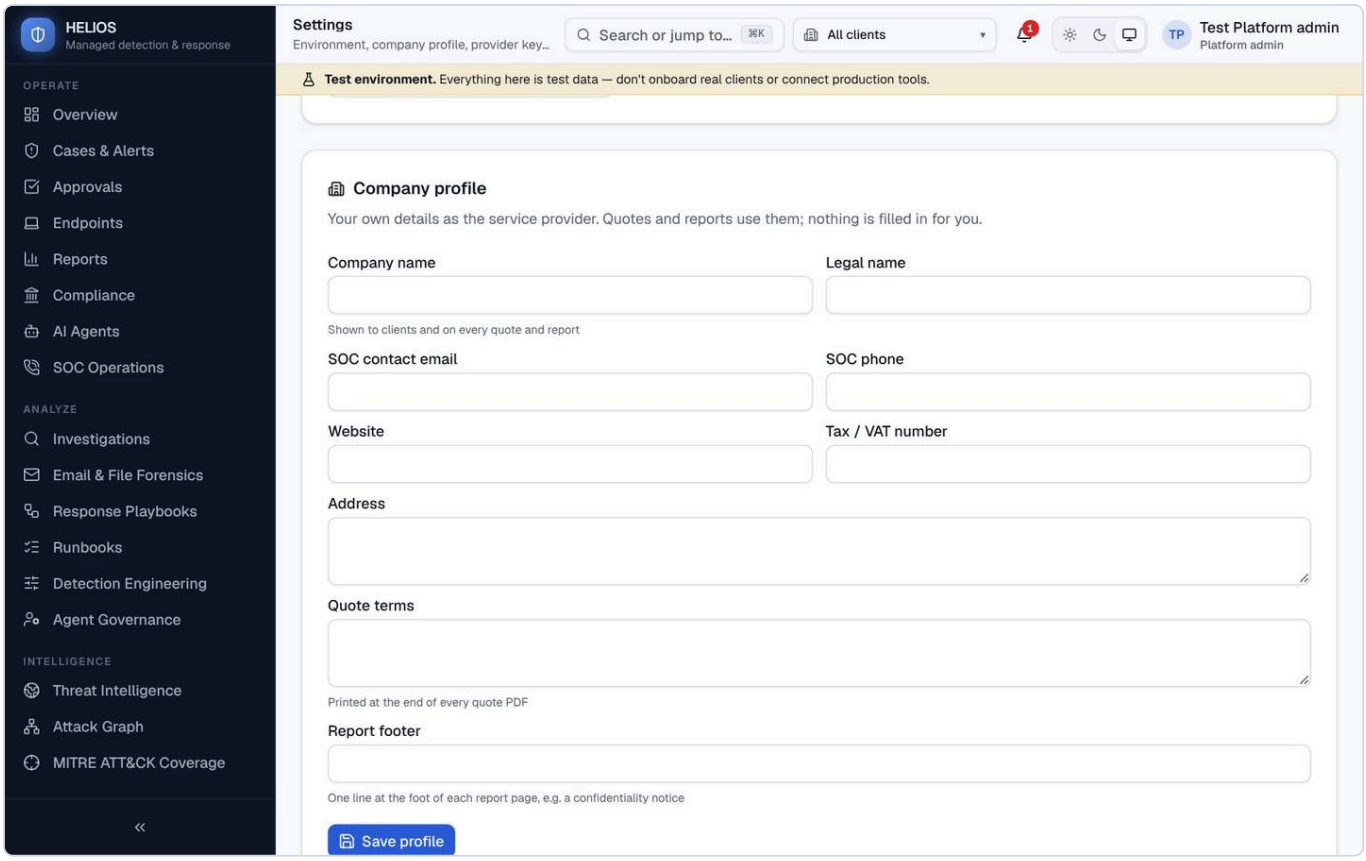


Figure 71. Settings, further down the page.

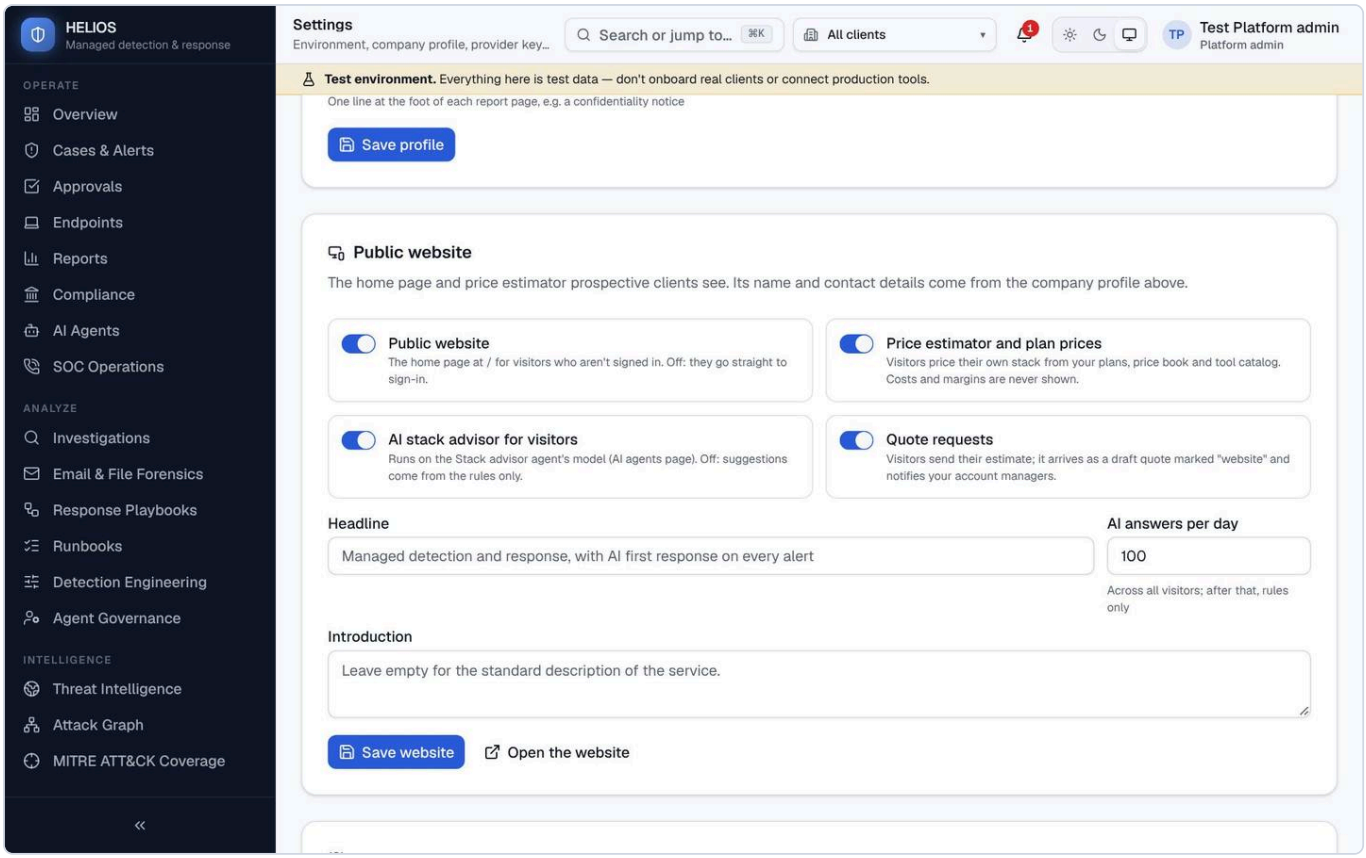


Figure 72. Settings, further down the page.

4.29 Build & Price

Configure a client's protection stack, compare vendors and plans, and estimate what it costs: monthly, annual, one-time, maintenance and over three years.

Who can open it: Admin, SOC manager, Account mgr

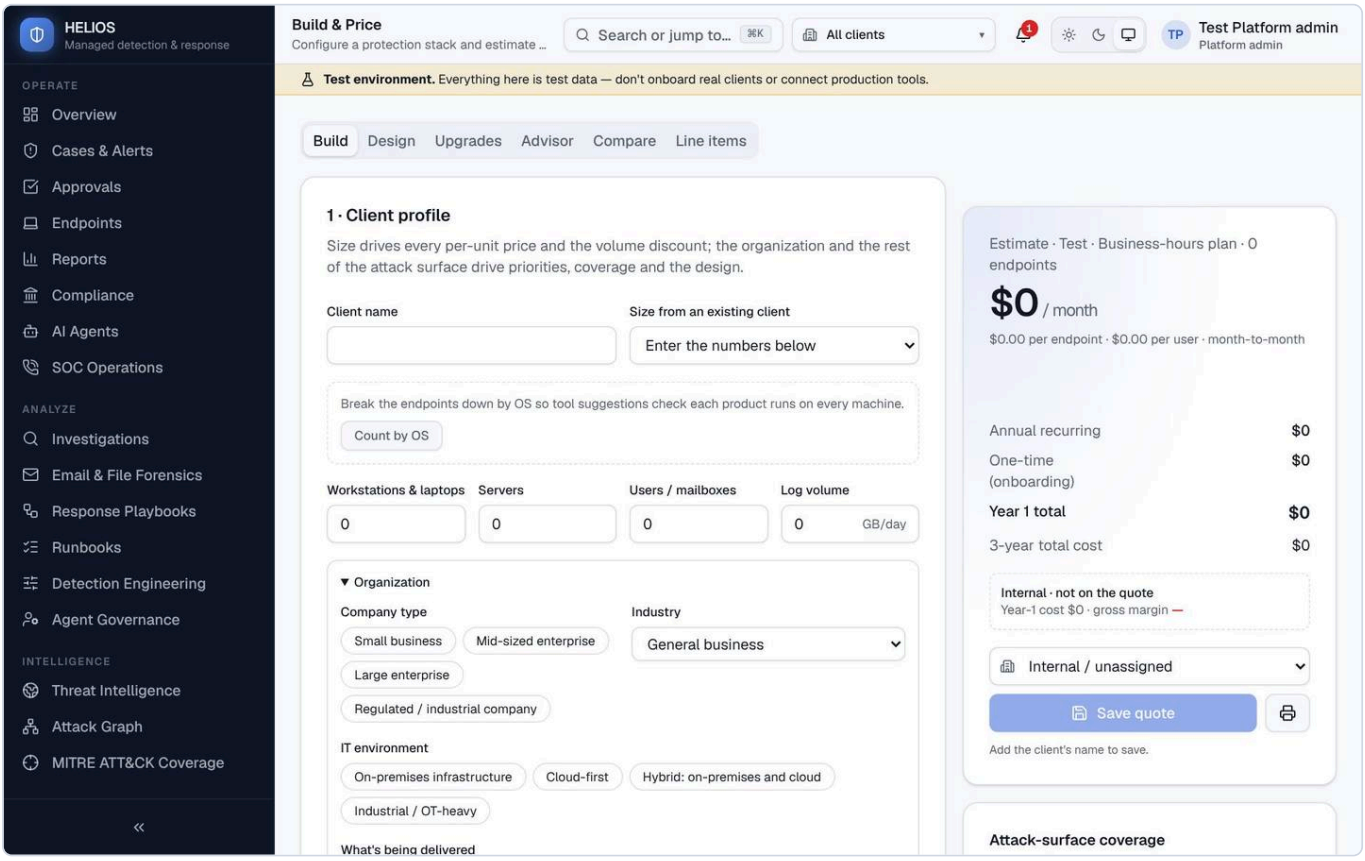


Figure 73. Build & Price (as platform admin).

How to use it

- The tabs: Build, Design, Upgrades, Advisor, Compare and Line items. The estimate on the right (monthly, annual recurring, one-time, year 1 and three-year totals) updates as you go.
- Build: describe the client (size from an existing client, or the numbers: workstations, servers, users, log volume, endpoints counted by OS; company type, industry, IT environment) and choose a tool per protection layer. Advisor suggests one per layer for a goal (best value, lowest cost, strongest protection) with its reasons.
- The upgrade review compares each tool with every alternative: what it adds or removes, whether it runs on the client's machines, and the price difference. The solution design lays out priorities, a phased rollout and coverage gaps.
- See internal cost and margin next to the price. Admin, Account mgr
- Save quote (it is versioned), and print or download it as a PDF; a quote never shows cost or margin.
- Edit the price book, plans and exchange rates (Pricing setup). Admin

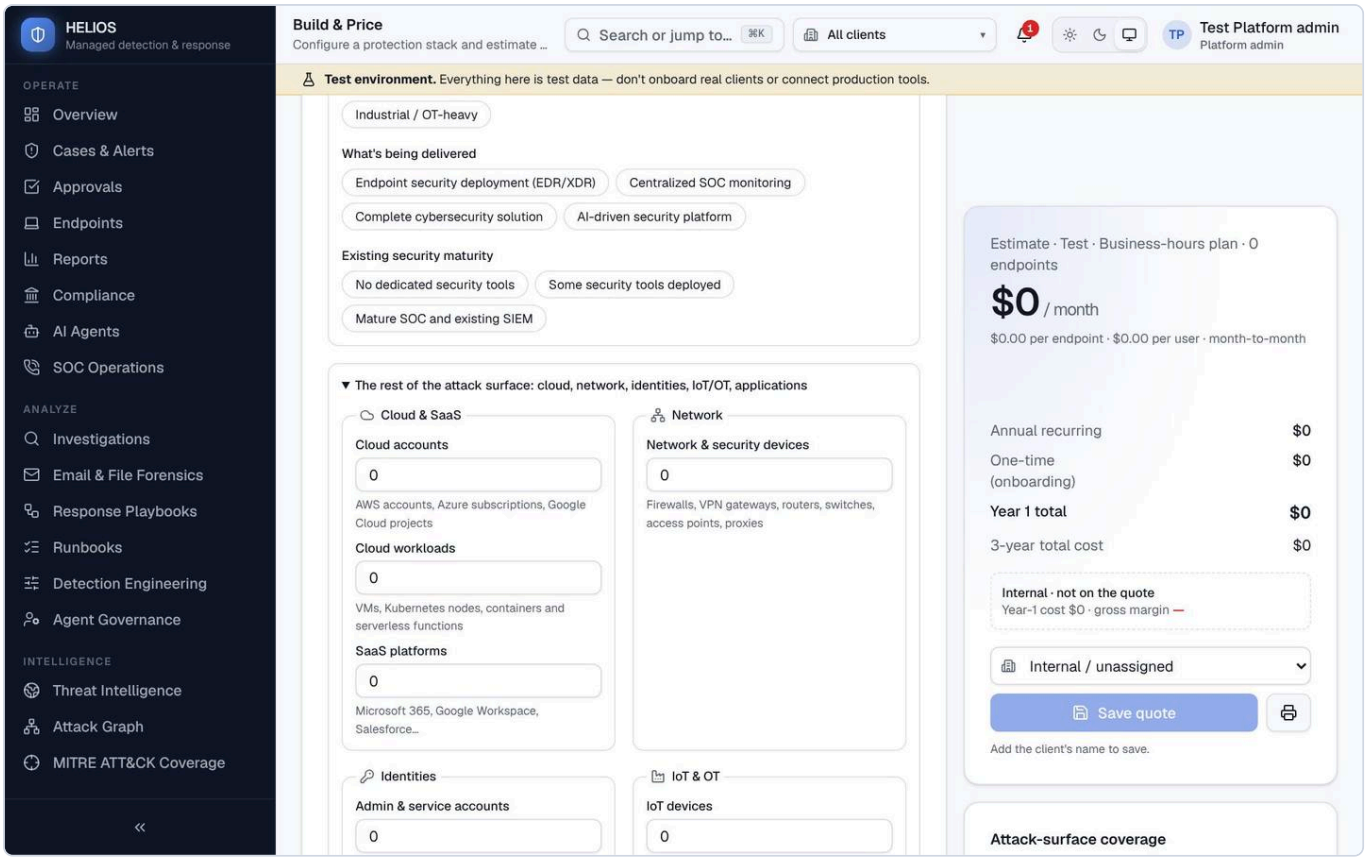


Figure 74. Build & Price, further down the page.

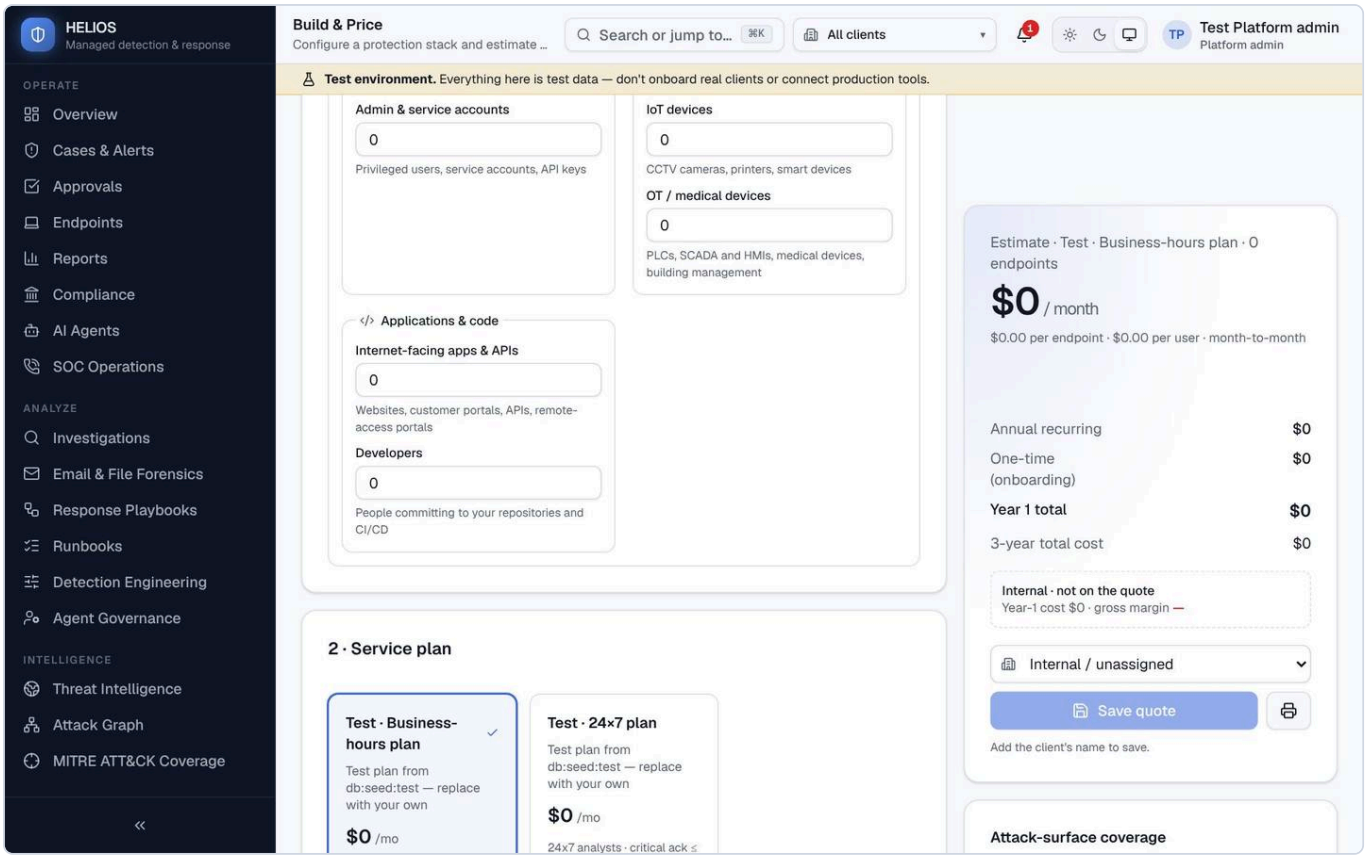


Figure 75. Build & Price, further down the page.

4.30 A saved quote

One quote: its configuration, the price breakdown and its versions.

Who can open it: Admin, SOC manager, Account mgr

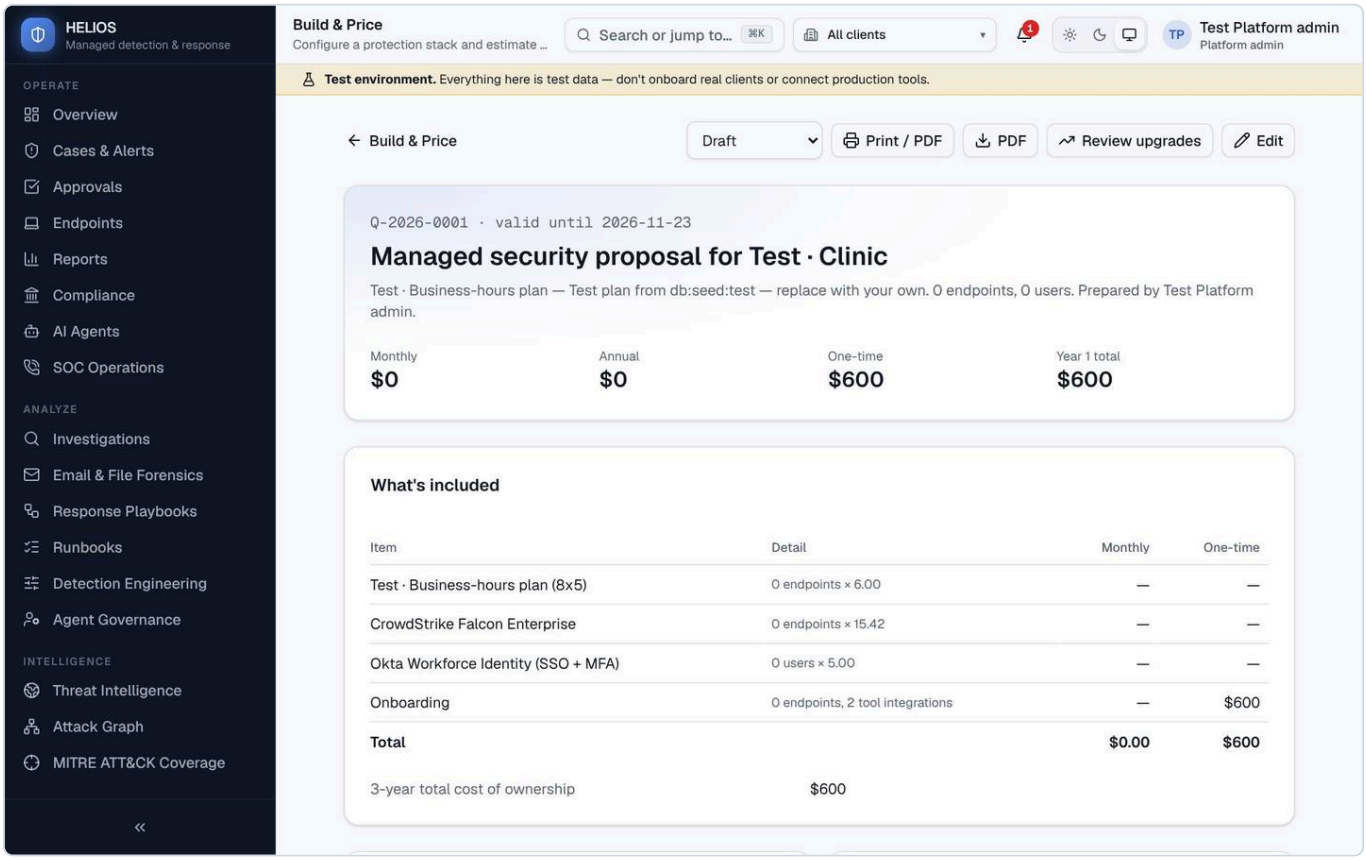


Figure 76. A saved quote (as platform admin).

How to use it

- Reopen it in the configurator, download the PDF, or start a contract draft from it on Contracts & Billing.

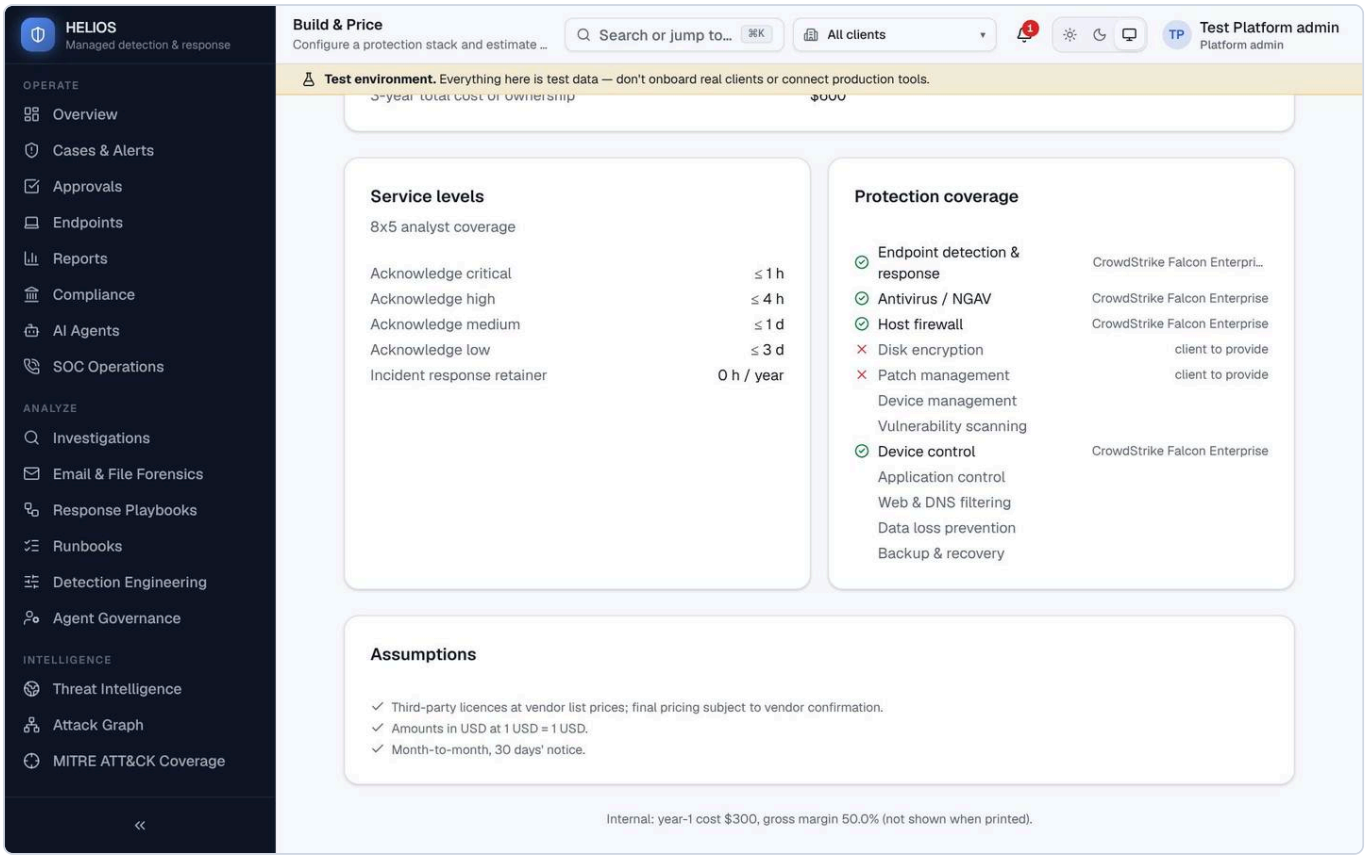


Figure 77. A saved quote, further down the page.

4.31 Contracts & Billing (clients: Contracts & invoices)

Pilots with measured success criteria, contracts and GST invoices.

Who can open it: Admin, SOC manager, Account mgr, Client admin

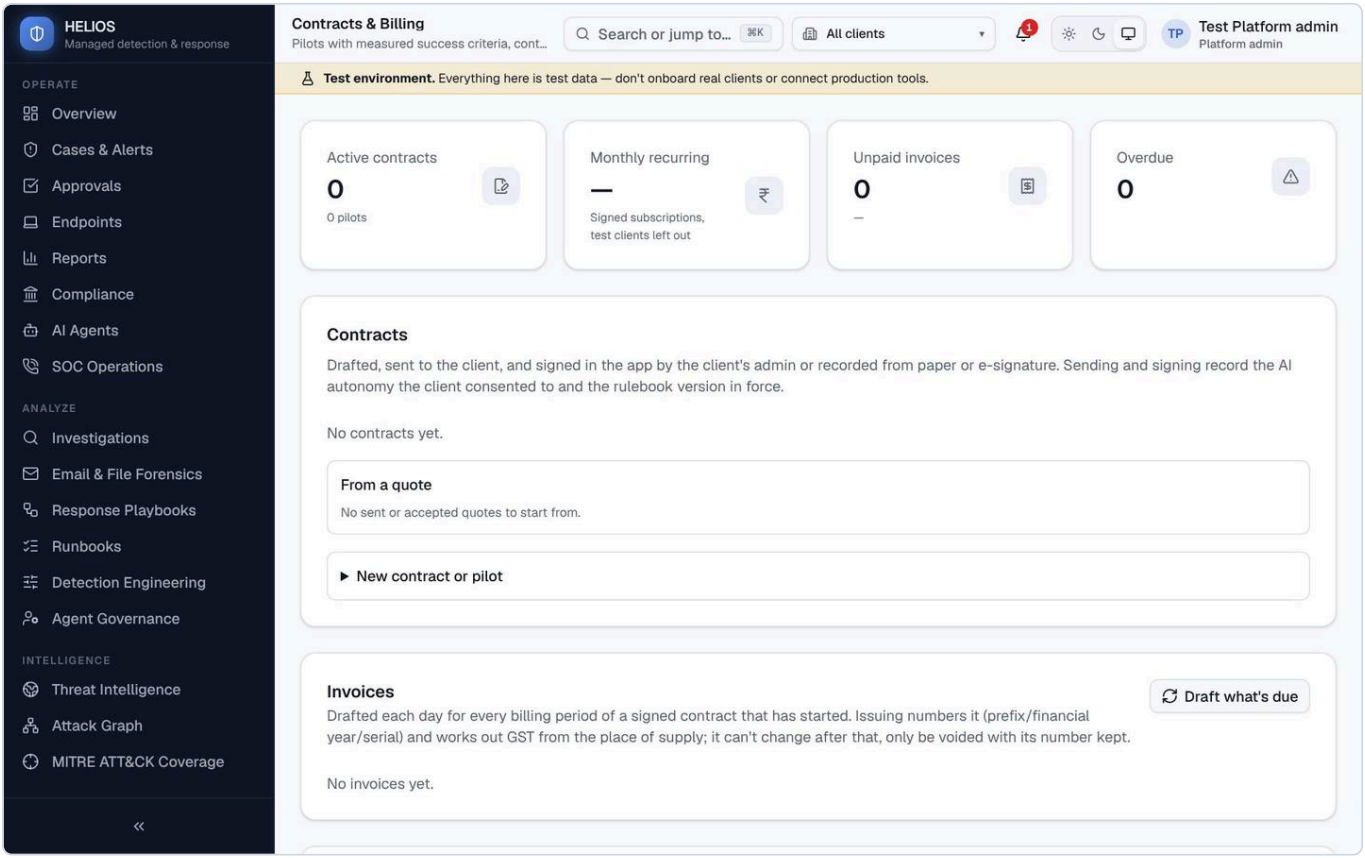


Figure 78. Contracts & Billing (as platform admin).

How to use it

- Pilots carry success criteria measured from HELIOS's own records (time to acknowledge and contain, SLA, AI agreement, wrong containments, sources live). A week before the end you get their status; convert the pilot to a subscription or record that it isn't continuing. Admin, Account mgr
- Contracts: start From a quote (sent or accepted) or with New contract or pilot; send it with your terms of service; the client's admin signs it in the app (or you record a signature on paper or an e-signature). Sending and signing record the AI autonomy the client consented to and the rulebook version in force; signing is refused if either changed since sending. Admin, Account mgr
- Invoices are drafted each day for every billing period of a signed contract that has started (Draft what's due does it now). Issuing numbers the invoice (prefix, financial year, serial) and works out GST from the place of supply; it can't change after that, only be voided with its number kept. Mark it paid when the money arrives. Admin, Account mgr
- You see your organisation's contracts and issued invoices, and download their PDFs. Client admin
- As client admin, sign a contract sent to you here. Client admin

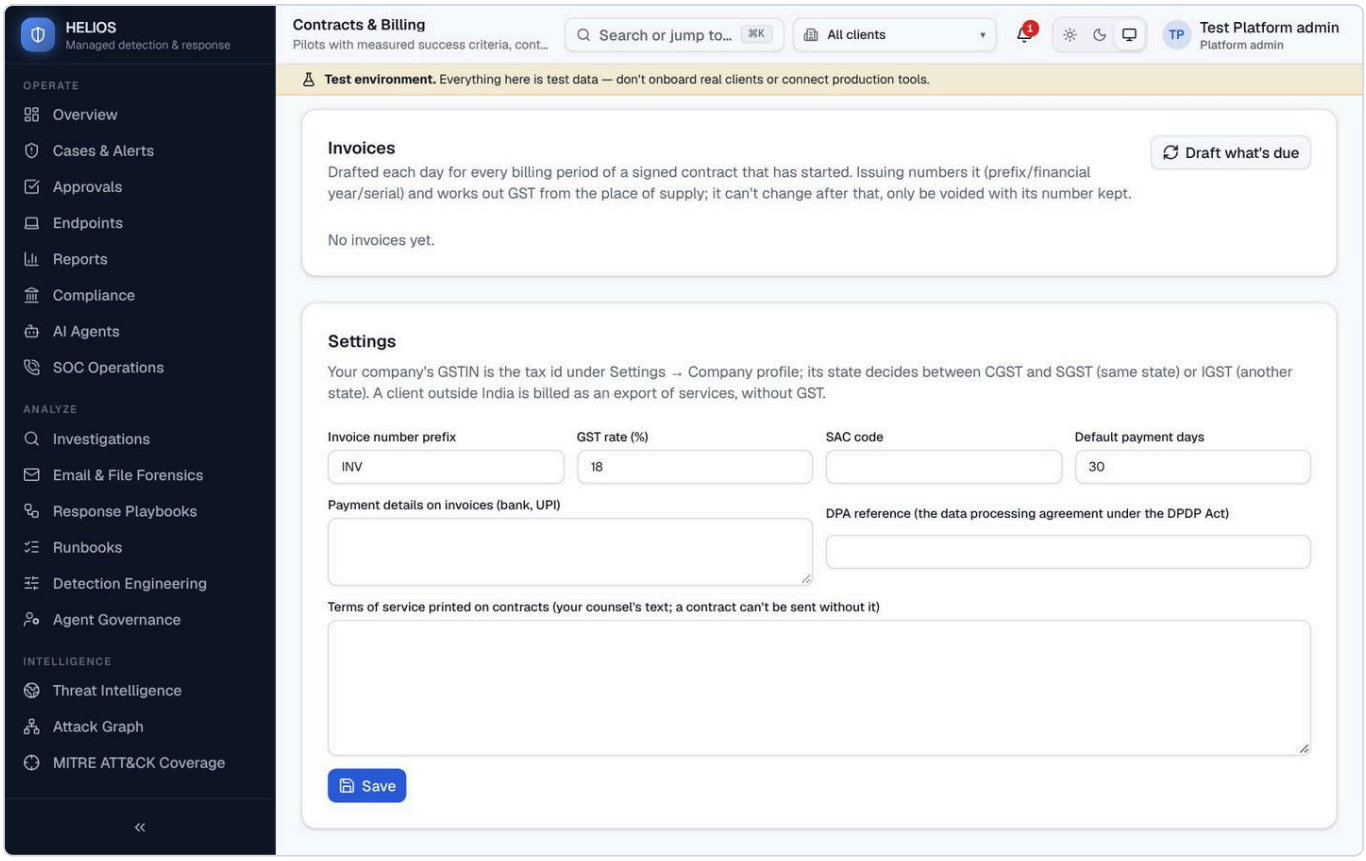


Figure 79. Contracts & Billing, further down the page.

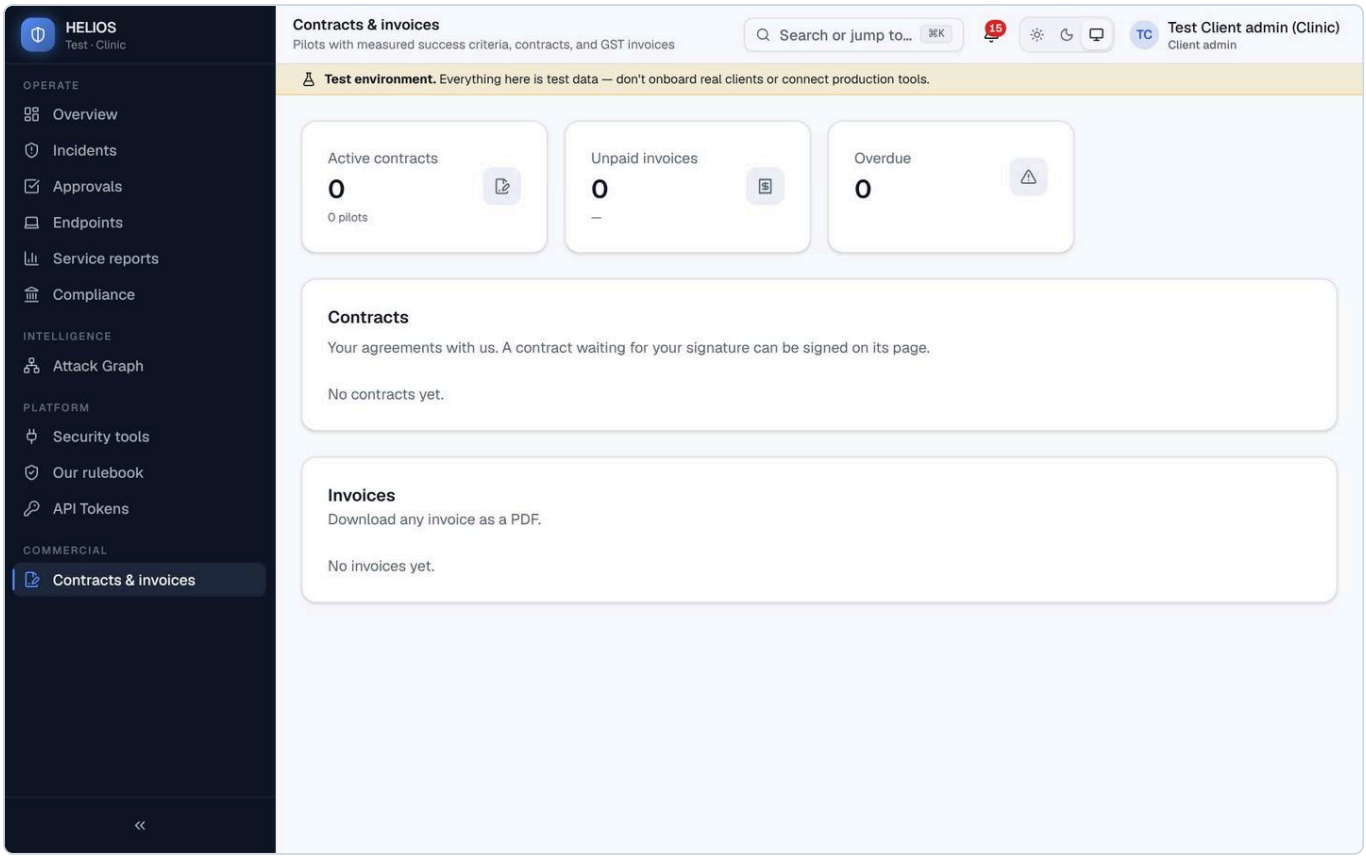


Figure 80. The client's view: Contracts & invoices (as client admin).

4.32 Daily digests

Once a day, what HELIOS did on its own, what was waiting, and the deadlines coming up.

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor

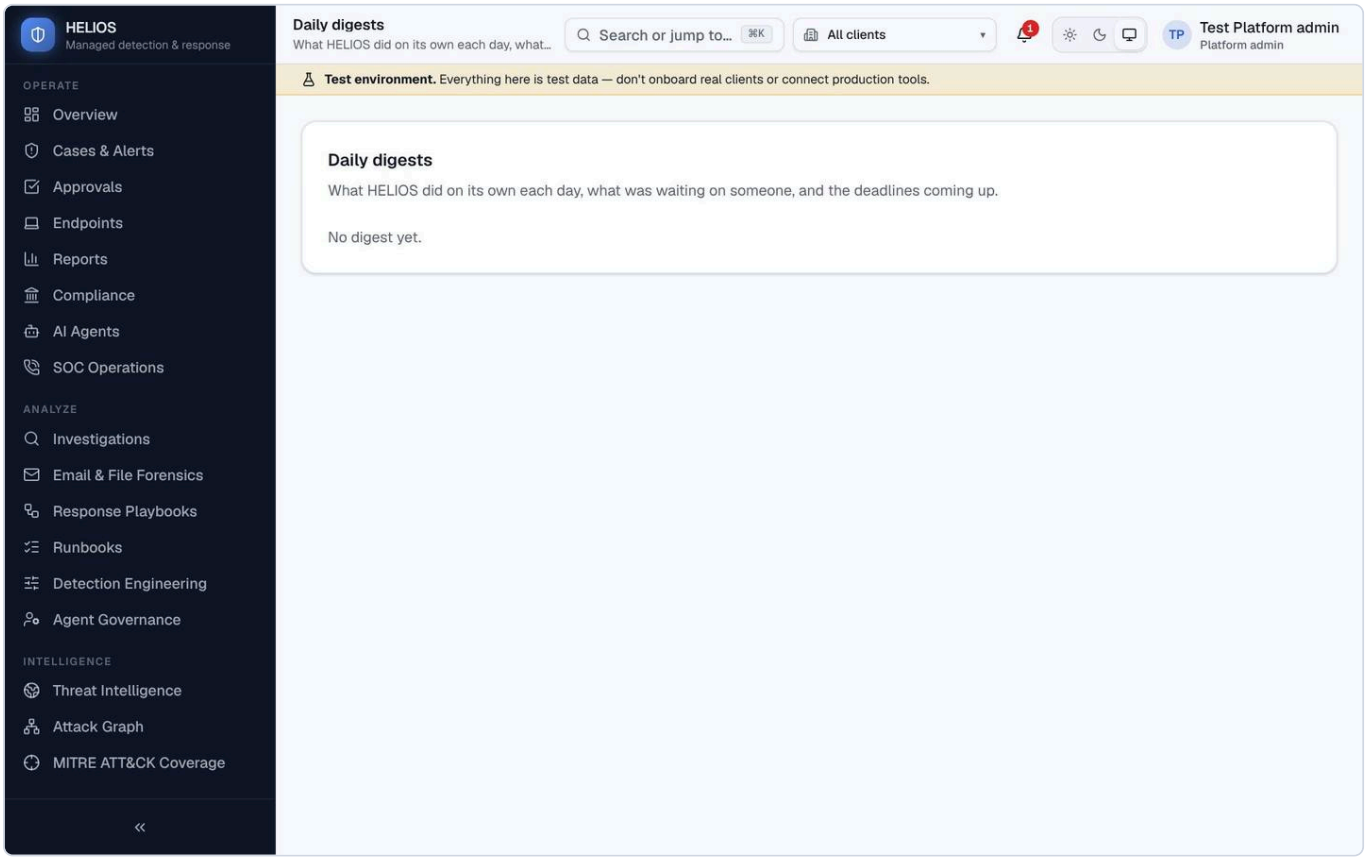


Figure 81. Daily digests (as platform admin).

How to use it

- Each digest lists actions the AI took without asking (with its autonomy level, rollbacks and QA calls), cases opened and closed, containment waiting for approval, regulatory deadlines within a day, quiet sources and the week's QA results.
- Choose under My alerts whether it also reaches you by email.

4.33 My alerts

Which notifications also reach you outside HELIOS, by email, SMS or WhatsApp.

Who can open it: Admin, SOC manager, Tier 1, Tier 2, Tier 3, Hunter, Detection eng., Auditor, Account mgr, Client admin, Client viewer

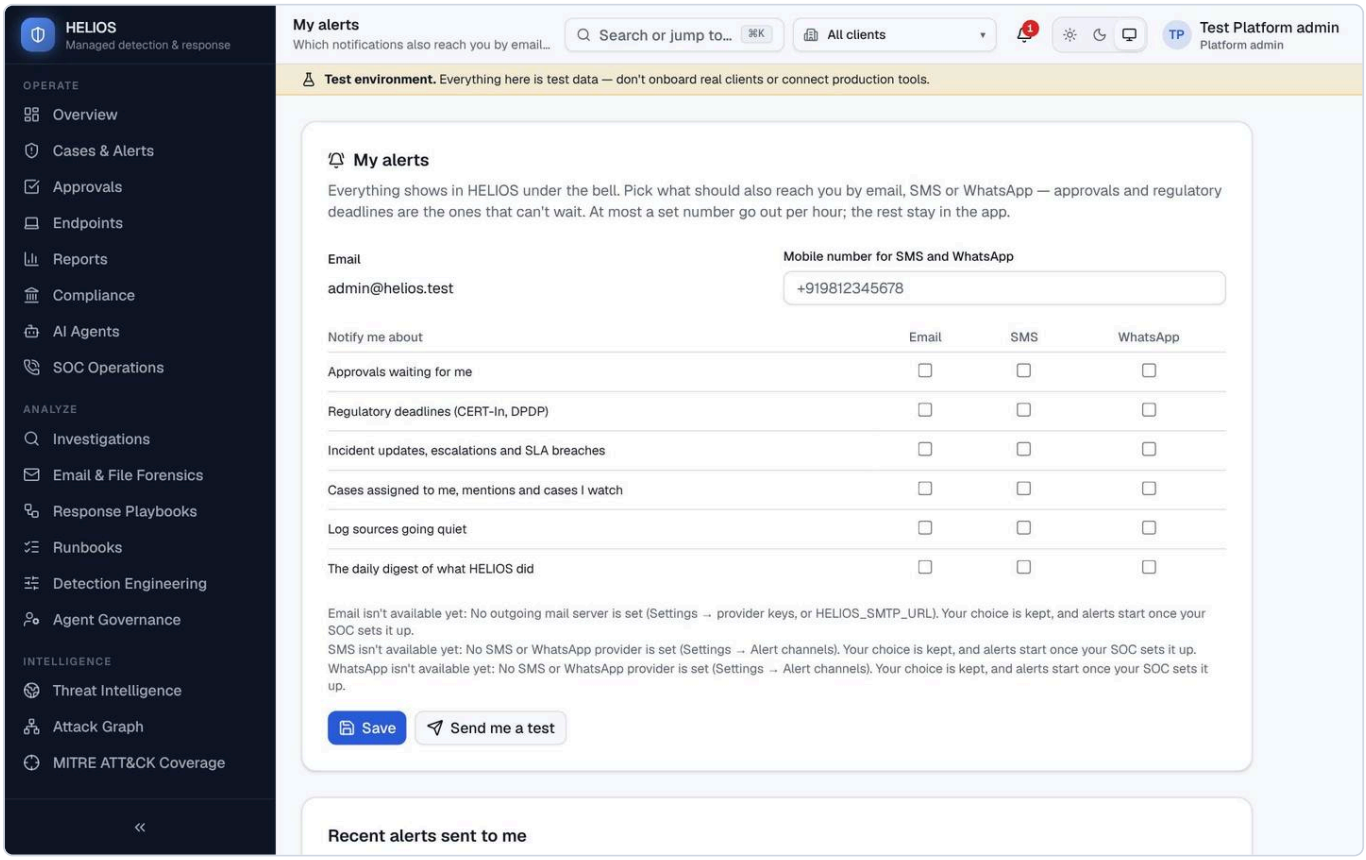


Figure 82. My alerts (as platform admin).

How to use it

- Every notification lands in the app (the bell at the top). Here choose, per kind of notification, the channels it also comes by, and give your phone number in international format (+91…).
- Deliveries that couldn't go (a channel not set up, no number, over the hourly cap) are listed with the reason.

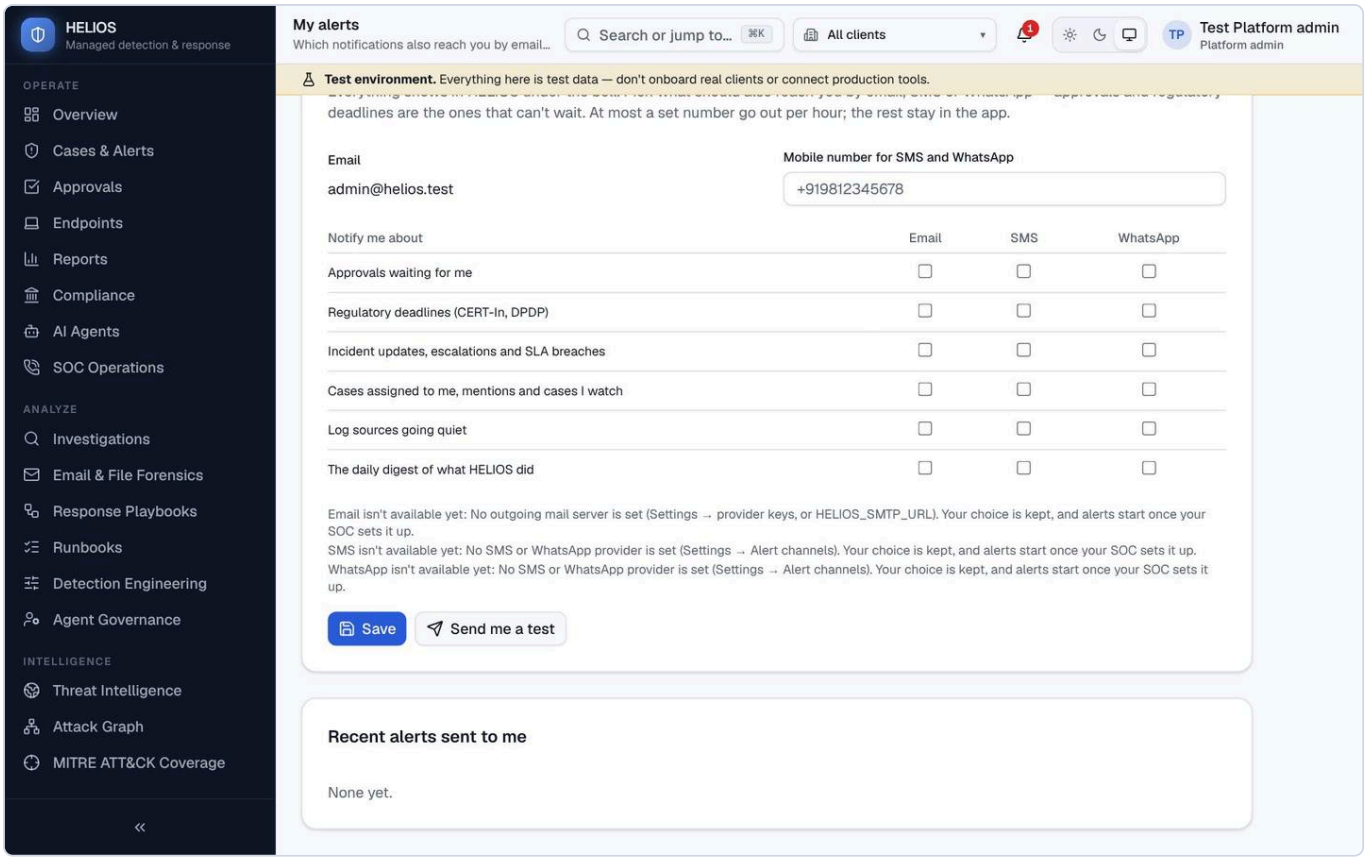


Figure 83. My alerts, further down the page.

5. Procedures

Step by step, for the work each role does most, and two flows that run across roles.

5.1 Onboarding a client, end to end

1. **Account manager**: build the quote in Build & Price; run a pilot or go straight to a contract; add the client on Clients with its plan, contacts and the AI autonomy it agreed to.
2. **Platform admin**: invite the client's admin (and stakeholders) on Team & Roles, choosing the client's organisation.
3. **Detection engineer**: onboard the client's tools on Tools & Integrations: credentials, log collection (push, pull or forwarder), response connectors in dry-run first.
4. **SOC manager**: draft the rulebook from an industry template; run the dry run.
5. **Client admin**: review and sign the rulebook; set the approver chain and My alerts; decide which AI models may read the client's data.
6. **Go-live**: once every source has sent data in the last day, the client moves from onboarding to active. The AI starts in shadow mode and earns autonomy per action.

5.2 An incident, end to end

1. **Detection**: telemetry triggers detections; HELIOS correlates them into a case with an SLA clock, and the triage agent analyses it and proposes containment.
2. **Tier 1**: acknowledges, checks the AI's analysis (agree or disagree), closes noise, or escalates with a note.
3. **Tier 2**: investigates (investigation agent, logs, forensics), requests containment, tells the client.
4. **Decision**: the response policy and the client's rulebook decide; held actions go to Approvals and the client's approver chain; a client admin or tier 3 approves.
5. **Action**: connectors act and confirm; without one, an analyst does it in the tool and records it.
6. **Regulators**: if CERT-In or DPDP applies, the notice is drafted, approved by the client and filed within its clock.
7. **Close**: contained, then resolved with a disposition and reason; the client gets a report; QA may sample the AI's part.

5.3 Administration

First-run set-up Admin

1. Open Overview. Work through Get HELIOS ready from top to bottom.
2. Define your service plans (SLA targets per severity, the most autonomy each plan allows) and fill in the price book under Build & Price → Pricing setup.
3. Price the quote-only tools you resell, or switch off the ones you don't sell.
4. Connect an AI provider on AI Agents (or leave agents on the built-in engine for now).
5. Invite your analysts on Team & Roles.
6. Add your first client on Clients, then onboard its security tools on Tools & Integrations.
7. Turn on the threat feeds you want on Threat Intelligence.

Invite a person and give them the right access Admin

1. Open Team & Roles and choose Invite user.
2. Enter name and email, and pick the role that matches the job (see the role matrix on the page). Give the least access that does the job.
3. For a client user, choose their organisation; they will only ever see it.
4. For an analyst who works some queues only, tick their security domains (endpoint, identity, email, network, cloud, AI agents).
5. Save. HELIOS shows a temporary password once: pass it to the person by a secure channel. They sign in with it, and set up two-step sign-in if your policy requires it.

Someone leaves or changes job Admin

1. Open Team & Roles, find the person, and deactivate the account (leaver) or change the role (mover). It applies on their next request; there is no session to wait out.
2. Revoke their personal API tokens if they had any (they stop working with the account in any case).
3. Check the on-call rota on SOC Operations and the approver chains in clients' rulebooks for their name.

Require two-step sign-in Admin

1. Open Settings → Sign-in and encryption.
2. Choose whether two-step sign-in is required for staff or for everyone. People it applies to are taken to set it up (an authenticator app, plus ten recovery codes) before anything else.
3. Optionally turn on single sign-on only for staff once your identity provider is connected.
4. For someone who lost their phone, open Team & Roles → their account → Reset two-step.

Configure AI safely Admin

1. On AI Agents → Model providers, add a provider and press Test. Keys are encrypted and never shown again.
2. Run an evaluation for each agent you will use (Evaluations). A model a client picks only suggests until it passes.
3. Under Agent types, set each agent's provider, reasoning effort and autonomy. Start with Suggest only.
4. Under Safety controls, set the minimum severity for AI first response and the cap on unattended containment per client per hour.
5. In an emergency, Engage kill switch stops all AI action at once, for every client.

Offboard a client Admin

1. Make sure contracts and invoices are settled (Contracts & Billing) and no legal hold is needed (Data Retention).
2. On Clients, set the client to suspended.
3. Once the retention period your contract promises is honoured or the data is returned, open the client's page → Encryption key → Destroy keys and type the client's name to confirm. Their stored credentials become unreadable, backups included.

Give an auditor or regulator the audit trail Admin

1. Open Audit Log and press Verify chain integrity: it should report the chain intact.
2. Filter to the area asked for, and Export JSON.
3. Record in the case or a comment who received the export and why.

5.4 Running the SOC

Set up the on-call rota SOC manager

1. Open SOC Operations → Rota, under Generate a rotation.
2. Tick the people who take turns in the order they take them, choose the shift length (8, 12 or 24 hours, or a week) and the start, and press Generate.
3. Add cover for swaps and leave with Add cover; cover beats the rotation for its hours.
4. Check that the page shows nobody gap in the next seven days. With nobody primary, pages go straight to the SOC managers.
5. Set the paging severity and acknowledgement window under Settings on the same page.

Review the weekly QA sample SOC manager

1. Each Monday the QA tile shows the reviews waiting. Reviews alternate between SOC managers and incident responders, never the analyst who closed the case.
2. Open each case. For each action the AI took on its own, record whether it should have run; then whether its verdict was right.
3. A 'shouldn't have run' counts against the AI at once: the autonomy ladder may demote that action type for the client the same day.

Promote or hold the AI's autonomy for a client SOC manager

1. The ladder runs per client and per action type: L0 observe, L1 suggest, L2 approve, L3 act and notify, L4 act. New clients start at L0.
2. A promotion needs at least 20 scored decisions in 30 days, 90% agreement with the analysts, no more than 2% wrong containment, no wrong containment of a critical asset, and the client's approval. The hourly review proposes it; approve it on the client's rulebook page (autonomy ladder) with a note.
3. A week below 80% agreement (at least five decisions) drops a level on its own; a critical mistake drops it straight to suggestions.
4. Talk the promotion through with the client before they approve it, using the case outcomes and QA results.

Handle a critical case nobody has picked up SOC manager

1. From Overview, open unassigned critical cases.
2. Assign the case (Triage → Assignee) or escalate it to tier 3 with a note.
3. If the on-call primary hasn't answered a page, the backup and then you are paged; answer with "I'm on it" to take it.
4. Approve containment that is waiting if it is right, or reject it with a reason.

Draft a client's rulebook SOC manager

1. Open Rulebooks and pick the client.
2. Start a draft from the industry template closest to the client, then set crown jewels, never-isolate assets, VIP, break-glass and service accounts, the action modes, blast radius, business hours, change freezes and the approver chain.
3. Run the dry run: it replays the last 30 days of AI proposals under the draft and probes each action.
4. Send it to the client admin to sign. Staff activate a rulebook only on the client's recorded instruction.

5.5 Triage

Triage a new case Tier 1

1. Open the case. Read the header (severity, SLA, source, client) and the AI first response (verdict, confidence, key findings, what it asks you to check).
2. Press Acknowledge: this stops the SLA clock and tells others you have it.
3. Check the evidence the AI cites (D, E, I references) and the related cases.
4. Rate the AI: Agree, or Disagree and say what it got wrong.
5. Decide: close it as a false positive, escalate it, or request containment.

Close a false positive Tier 1

1. Set Status to False positive (or Resolved for real but harmless activity).
2. Choose the disposition: false positive, or benign true positive for expected or authorised activity, and give the reason.
3. If the same benign activity keeps opening cases, tell the detection engineer so it can be tuned for that client rather than closed again and again.

Escalate to tier 2 Tier 1

1. Press Escalate. Choose the tier (2) and either anyone in the tier or a named person.
2. Write a hand-off note: what you checked, what you found, what is still open.
3. The case moves to the tier-2 queue; you can still follow it with Watch case.

Ask for containment Tier 1

1. In Response actions, choose Request containment.
2. Pick the action and the exact target (host, IP, account, hash…) as it appears in the evidence.
3. Say why: the approver reads it. Your request goes through the response policy and the client's rulebook: it may wait for approval or be refused, and the reason is shown.

Page the on-call analyst Tier 1

1. In the On call card on the case, say what you need and press Page on-call.
2. The primary is paged by SMS, email and in the app; unanswered, the backup and then the SOC managers are paged.

5.6 Analysis and response

Investigate an escalated case Tier 2

1. Read the hand-off note and the AI first response. Acknowledge if it isn't.
2. Dispatch the investigation agent (Dispatch agent → Investigation agent): it searches the client's telemetry around the case with read-only tools and reports a timeline tied to evidence.
3. Check related cases and the Attack Graph for the same hosts, accounts and indicators elsewhere.
4. Work the attached runbook steps.
5. Record findings in internal comments as you go.

Investigate uploaded logs Tier 2

1. Open Investigations → upload the logs (EVTX, CSV, JSON, spreadsheets or text), with the alert that prompted it and the client.
2. Read the pipeline's root cause, its adversarial QA and the timeline; open the case it created.

Analyse a suspicious email or file Tier 2

1. Open Email & File Forensics and submit the .eml, .msg or file.
2. Read the header authentication, the sender-domain diagnosis, the links (detonated through the proxy), attachments and macros.
3. If it is malicious, the case lets you request Purge email (each recipient's copy moved to Recoverable Items) and Block sender.

Contain an account or a device Tier 2

1. Request containment: Disable account or Reset password (a random password HELIOS doesn't keep, to change at next sign-in, with sessions ended); Isolate host; Collect investigation package (the device's forensic state copied to Defender).
2. Where the client has a native connector, HELIOS calls the vendor and counts the action only once the vendor confirms it. Without one, it becomes a task: do it in the tool's console, then record What you did.
3. Containment can be rolled back from the case; IP blocks and account disables can be time-boxed or kept until lifted.

Tell the client Tier 2

1. Write a client-visible comment, or Share the case.
2. Dispatch the client report writer for a plain-language draft, edit it, and publish it to the client.
3. If CERT-In or DPDP applies, start the notice from the case's Regulatory reporting card and send it for the client's approval.

Run a major incident Tier 3

1. Take the case (assign it to yourself) and set the status to Investigating.
2. Approve the containment that stops the spread; isolate hosts directly from Endpoints if needed (the client's never-isolate list and crown-jewel rules still apply).
3. Bring in people with @mentions and Escalate; page on-call if you need more hands.
4. Keep the client informed with client-visible comments and a published report.
5. Start the CERT-In report (and DPDP notices if personal data is involved) from the case; get the client's approval; file it.
6. When contained, set Contained; when done, Resolved with the disposition and a reason.

Approve or reject held containment Tier 3

1. Open Approvals, or the case's Response actions.
2. Read what would happen, against what, and why it was held (the deciding rule is shown).
3. Approve if it is right; Reject with a reason otherwise. Two-person actions need a second, different approver.

Isolate or release a device directly Tier 3

1. Open Endpoints, find the device, and choose Isolate (or Release).
2. With an EDR connector, HELIOS asks the vendor and confirms the device's state. Without one, it marks the device and asks you to do it in the EDR console.

Review a QA sample case Tier 3

1. Open the case from SOC Operations → QA.
2. For each autonomous action, record whether it should have run; then whether the verdict was right. A 'shouldn't have run' demotes the AI for that action type.

5.7 Hunting

Hunt across clients Hunter

1. On Attack Graph, follow the attack chains: entities whose cases together reach more tactics than any single case.
2. Look up shared indicators on Threat Intelligence; open related cases.
3. Upload logs from a client (Investigations) to dig into a period or a host.
4. Dispatch the investigation agent on a case to search that client's telemetry around it.

Turn a finding into protection Hunter

1. Block the indicator on Threat Intelligence (it feeds the detectors and firewalls that pull the blocklist).
2. Escalate the affected cases to the analysts with your findings.
3. Give the detection engineer the pattern so it becomes a Sigma rule, tested before it goes live.

5.8 Detection and integration engineering

Onboard a client's tool Detection eng.

1. Open Tools & Integrations, choose the client and the tool from the catalog.
2. Enter its read-only credentials (encrypted with the client's own key) and press Test.
3. Choose how logs arrive: the ingest URL and token (push), HELIOS pulling from the vendor's API (checkpointed), or the HELIOS forwarder (generate its configuration for syslog, Windows event logs and files).
4. Turn on the response connector in dry-run mode first; once its dry runs look right, switch it to live.
5. Watch Source health: the client can't go live until every source has sent something in the last day.

Publish a Sigma rule Detection eng.

1. On Detection Engineering, import the rule. If HELIOS can't evaluate part of it faithfully, it refuses and says why.
2. Read the backtest against recent history, then put it in testing: it counts matches but opens nothing.
3. When the matches look right, make it live.

Tune a noisy detection for one client Detection eng.

1. On Detection Engineering → tuning, choose the client and the detector or rule.
2. Switch it off there, leave out a known-good host, account or process, or change its severity.
3. Give the reason and, where it should lapse, an expiry. The count shows what the tuning held back.

Write a playbook Detection eng.

1. On Response Playbooks, create one: its trigger (severity, source, technique) and its steps in order.
2. Steps that act go through the same response policy and rulebook as everything else; steps without a connector become tasks.
3. Enable it, and watch its first runs on the cases it triggers on.

5.9 Oversight and audit

Verify and export the audit chain Auditor

1. Open Audit Log and press Verify chain integrity. It recomputes every entry's hash; an alteration is reported with the first entry affected.
2. Filter to the area under review (cases, detection, forensics…), and Export JSON.

Review an AI decision Auditor

1. Open the case; read the AI first response, the evidence it cited, and the grounding (claims it couldn't tie to evidence are dropped).
2. In Response actions, each decision shows the rule that decided it: the response policy's stack of layers, the client's rulebook version, the autonomy ladder.
3. AI Agents shows each model's evaluation scorecard.

Review compliance evidence Auditor

1. On Compliance, read the ISO 27001 map for the period: what HELIOS's records show for each control, and the gaps.
2. On Data Retention, check each client's retention against its obligations (180 days minimum where CERT-In applies) and whether the logs are shown to be in India.

5.10 Commercial

Build and send a quote Account mgr

1. Open Build & Price. Enter the client's endpoints by operating system and the rest of the estate.
2. Choose a tool per layer, or ask the stack advisor for a goal (best value, lowest cost, strongest protection); read its reasons.
3. Use the upgrade review to compare with what the client already has.
4. Check the estimate and your margin, then save the quote and download its PDF (it never shows cost or margin).

Run a pilot and convert it Account mgr

1. On Contracts & Billing, create a pilot (from the quote if you like) with its success criteria and term.
2. The criteria are measured from HELIOS's own records; a week before the end you get their status.
3. Convert it into a subscription draft starting when the pilot ends, or record that it isn't continuing.

Contract and invoice Account mgr

1. Draft the contract (fees, endpoints, cycle, term, notice, the liability cap for automated containment) and send it. Sending needs your terms of service, set on the billing page.
2. The client's admin signs it in HELIOS, or you record a signature on paper or an e-signature.
3. Each billing period an invoice draft appears. Issue it: it gets its number for the financial year and its GST worked out. Mark it paid when the money arrives, or void it with a reason.

Add a client Account mgr

1. On Clients, add the organisation: name, industry, contacts, plan, licensed endpoints and users, and the AI autonomy cap the client has agreed to.
2. Draft its first rulebook with the SOC manager from an industry template; the client's admin signs it.

5.11 For clients

Approve or reject containment Client admin

1. Open Approvals (or the incident). Each item says what would happen (isolate a device, disable an account, block an address…), why, and who proposed it.
2. Approve if it is right for your business, or Reject with a reason. Nothing held runs while it waits.
3. Approvals also reach you by email, SMS or WhatsApp if you chose that under My alerts.

Sign your rulebook Client admin

1. Open Our rulebook. Review the draft against the version in force (the differences are shown) and the dry-run result.
2. Check the protected assets (never isolate, crown jewels), protected accounts (VIP, break-glass, service), which actions may run automatically and from what severity, business hours and change freezes, and your approver chain.
3. Sign. The new version applies at once to everything HELIOS, its AI and its analysts do on your estate.

Approve a regulatory notice Client admin

1. When a CERT-In report or DPDP notice is ready, it appears in Approvals and on Compliance.
2. Read the draft. Approve it, or ask the SOC for changes. An edit after approval comes back to you.

Decide which AI may read your data Client admin

1. In Our rulebook → AI, set residency (any provider, region-locked, or on-premises only) and whether personal data is masked before a cloud model sees it.
2. Optionally add your own provider (your Anthropic, Amazon Bedrock or Azure OpenAI account, or an on-premises AI box), pick a provider per agent, and set a monthly AI budget.
3. A model you pick acts on its own only once it has passed HELIOS's evaluation; until then it only suggests.

Approve a promotion of the AI's autonomy Client admin

1. Autonomy is earned per action type: a promotion needs at least 20 decisions in 30 days, 90% agreement with the SOC's analysts, no more than 2% wrong containment, and none on a critical asset.
2. When one is proposed, open Our rulebook → the autonomy ladder; read the record behind it and discuss it with the SOC.
3. Approve or decline it. Your plan, your consent and your rulebook still cap every level.

Read an incident Client viewer

1. Open Incidents and the incident: what was detected, what was done, and its timeline.
2. Download its report as a PDF if you need to share it inside your organisation.

Read the service report Client viewer

1. Open Service reports and pick the month: volume, response times against your SLA, and what the AI and the SOC did.
2. Download the PDF for your management.

Check how well your devices are covered Client viewer

1. Open Endpoints: assets, protection score, devices missing essential controls, and coverage by protection layer.

6. Guidelines

6.1 For everyone

- Never share an account or password; every action is recorded under your name.
- Require two-step sign-in for every staff account.
- Keep client information inside HELIOS and to the people who need it.
- Treat text inside evidence (command lines, emails, file names) as possibly written by an attacker; don't follow instructions it contains.
- Write down why you did something: approvers, clients and auditors read it.
- The client's signed rulebook binds everyone. If HELIOS refuses an action, don't work around it in a vendor's console; ask the client to change the rule.
- Keep the test environment for testing; never onboard real clients or production tools into it.

6.2 Administration

Do

- Keep a separate day-to-day account for ordinary SOC work; use the admin account only for administration.
- Require two-step sign-in for every staff account.
- Change roles rather than sharing accounts; every action is attributed to a person in the audit chain.
- Test AI models on Evaluations before letting them act, and start clients at the lowest autonomy.
- Keep the test environment for testing: it shows a banner on every page; never onboard real clients or production tools in it.

Don't

- Don't paste keys, passwords or client secrets into comments or case notes; use the encrypted provider-key and credential fields.
- Don't destroy a client's keys until offboarding is final: it can't be undone.
- Don't edit the database directly: changes outside HELIOS bypass the audit chain and the row-level isolation.

6.3 Running the SOC

Do

- Keep at least one person primary on call at all times.
- Reject held containment with a reason the analyst can act on.
- Use the kill switch without hesitation if AI action looks wrong at scale; turn it off once you understand why.
- Promote autonomy slowly and only with the client's agreement.

Don't

- Don't approve containment you haven't read: the approval is yours in the audit chain.
- Don't skip QA reviews: they are what keeps the AI's autonomy honest.
- Don't activate a client's rulebook without the client's recorded instruction.

6.4 Triage

Do

- Acknowledge before you investigate, so the SLA reflects reality.
- Write hand-off notes someone else can act on without asking you.
- Rate the AI honestly: your agreements and disagreements decide how much it may do on its own.
- Use internal comments for SOC discussion; only share with the client what is meant for them.

Don't

- Don't close a case as a true positive with required runbook steps open (HELIOS won't let you).
- Don't guess a containment target: copy it exactly from the evidence.
- Don't follow instructions written inside evidence (a command line or an email that addresses 'the AI' or 'the analyst'): treat them as attacker text.

6.5 Analysis and response

Do

- Tie every finding to evidence; the AI and the reports do the same.
- Prefer the least disruptive action that stops the threat.
- Record why you took each action: the approver and the auditor read it.
- Keep notices factual and send them for approval early: CERT-In's clock is 6 hours from when the incident was noticed.
- Write down decisions and their reasons on the case as you make them.
- Prefer containment that can be rolled back; time-box blocks where you can.
- Agree client communications with the account manager for sensitive incidents.

Don't

- Don't share AI working notes or internal comments with the client.
- Don't detonate or open suspicious content on your own machine: use Forensics.
- Don't block shared infrastructure (a cloud provider's range, a mail service) without the incident responder's agreement.
- Don't override the client's rulebook by doing in the vendor console what HELIOS refused: the rulebook is the client's signed instruction.
- Don't file a regulatory notice without the client's recorded approval.

6.6 Hunting

Do

- Note which client each finding belongs to; never mix clients' details in a shared note.
- Record the reason and owner for every block you add.

Don't

- Don't block broadly shared infrastructure without agreement from the incident responder.
- Don't take containment yourself: request it through the case so the rulebook and approvals apply.

6.7 Detection and integration engineering

Do

- Use the least privilege each vendor allows for the credentials you enter.
- Prefer tuning for one client over switching a detector off for everyone.
- Give every tuning entry a reason, and an expiry where it should lapse.

Don't

- Don't make a Sigma rule live without its test period.
- Don't put production credentials into the test environment.

6.8 Oversight and audit

Do

- Note the chain verification result in your working papers.
- Treat exported data as confidential client data.

Don't

- Don't share exports outside the review they were made for.

6.9 Commercial

Do

- Quote the autonomy and liability terms the client actually agreed to; the contract snapshots them.
- Check GSTINs and the place of supply before issuing an invoice.

Don't

- Don't promise response times other than the plan's SLA.
- Don't share internal cost or margin with clients.

6.10 For clients

Do

- Keep your never-isolate list and protected accounts current; they bind the SOC's people as well as the AI.
- Name approvers who can be reached at night, and keep their contact details current.
- Set up My alerts so approvals reach you quickly.
- Ask your client admin for anything that needs a decision (approvals, rulebook changes).
- Treat incident details as confidential.

Don't

- Don't share your account; invite colleagues as client stakeholders instead.
- Don't approve containment you don't understand: ask the SOC in the incident's discussion first.
- Don't forward incident reports outside your organisation without agreement.

7. Reference

7.1 Terms you will see

Case statuses

Open	New; nobody has acknowledged it yet.
Triaging	Someone is looking at it.
Investigating	Under analysis.
Awaiting approval	Containment is waiting on someone's yes.
Contained	The threat is stopped; clean-up may continue.
Resolved	Closed with a disposition.
False positive	Closed: it wasn't a threat.

Severities

Critical, High, Medium, Low, Info	Set by the detections and adjustable by analysts. The client's plan sets the acknowledgement SLA for each.

Dispositions (when closing)

True positive	A real threat.
Benign true positive	Real activity, but expected or authorised (an admin's tool, a pen test).
False positive	Not what the detection thought.

Tiers

T1	Triage.
T2	Analysis.
T3	Incident response.

Response action statuses

Suggested	A recommendation only; autonomy doesn't allow acting.
Pending approval	Waiting on an approver.
In progress	The vendor was asked; waiting for it to confirm. Doesn't count as containment yet.
Executed	Done and confirmed by the vendor (or by an analyst for a manual action).
Manual required	Approved, but no connector can do it: someone does it in the tool's console and records it.
Blocked	A guardrail or the client's rulebook refused it; the reason is shown.
Rejected	An approver said no.
Rolled back	Undone.
Failed	The vendor or HELIOS couldn't do it.
Shadow	Shadow mode: what the AI would have done, recorded silently and shown once the case closes.

AI autonomy (per agent)

Off	The agent doesn't run.
Suggest only	It proposes; people decide.
Contain with approval	Its containment waits for approval.
Auto-contain	It may act on pre-approved actions above its confidence bar.

Autonomy ladder (per client and action type)

L0 observe	Shadow mode.
L1 suggest	Suggestions only.
L2 approve	Acts once approved.
L3 act and notify	Acts, and tells people at once.
L4 act	Acts, and reports in the daily digest.

Evidence references

D, E, I, T, C	Detections, events, indicators, timeline entries and context in the case; Q for what the investigation agent's tools returned. Every AI finding cites them.

7.2 If something doesn't work

- **A page says you don't have access**: your role doesn't include it; ask your administrator if your job needs it.
- **An action was refused**: the message names the rule (the client's rulebook, a guardrail, the plan, or the kill switch).
- **An action is 'Manual required'**: no connector can do it; do it in the tool's console and record what you did on the case.
- **Alerts don't reach you by SMS or email**: check My alerts for channel choices, your phone number, and skipped deliveries with their reason.
- **You can't sign in**: after five failures the account locks for 15 minutes; an administrator can reset your password or two-step sign-in.
- **A source shows as quiet**: check the tool's credentials and collector on Tools & Integrations; a quiet source has its own case.

7.3 Configuration

The main settings, set in the server's environment (provider keys can also be stored, encrypted, in Settings):

Setting	What it does
`DATABASE_URL`	PostgreSQL 16 connection
`AUTH_SECRET, AUTH_URL`	Session signing and the public address
`HELIOS_ENCRYPTION_KEY or HELIOS_ENCRYPTION_KEY_KMS`	Master key for credentials and client data keys (KMS: decrypted once at start)
`ANTHROPIC_API_KEY`	Claude from the environment, when no provider is configured in the app
`VIRUSTOTAL_API_KEY, ABUSEIPDB_API_KEY, MXTOOLBOX_API_KEY`	Reputation and sender-domain checks (or set them in Settings)

`HELIOS_SSO_ISSUER, _CLIENT_ID, _CLIENT_SECRET, _NAME`	Single sign-on for staff (any OpenID Connect provider)
`HELIOS_ARCHIVE_S3_BUCKET / _REGION / _ENDPOINT, or HELIOS_ARCHIVE_DIR`	Where archived logs go; HELIOS_DATA_REGION declares the database's region
`HELIOS_GEOIP_CITY_DB, HELIOS_GEOIP_ASN_DB`	MaxMind or DB-IP databases for IP locations
`HELIOS_INGEST_WORKER=external`	Run the ingest workers separately (npm run worker)
`HELIOS_ALLOW_PRIVATE_CLIENT_AI=1`	Allow a client's own AI endpoint on a private address (HELIOS inside the client's network)
`HELIOS_AI_CLIENT_CERT, HELIOS_AI_CLIENT_KEY, HELIOS_AI_CA`	Mutual TLS to on-premises AI boxes
`DETONATION_PROXY`	Egress proxy for link detonation

7.4 More documentation

- **Per-role guides**: docs/guides/ has a guide for each of the eleven roles.
- **Architecture**: docs/architecture.md describes every module in technical detail.
- **On-premises AI box**: deploy/edge-ai/README.md.